Tema 36 · Bloque II | 60 preguntas de test

Seguridad y protección en redes de comunicaciones

Principios, amenazas y mecanismos por capa · El ENS en la red · Seguridad perimetral: cortafuegos, proxy, IDS/IPS y DMZ · Segmentación y confianza cero · Acceso remoto seguro, MFA y AAA · Redes privadas virtuales: IPsec, SSL/TLS y túneles de nivel 2 · Seguridad en el puesto del usuario

Enunciado oficial del programa (BOAM n.º 10.032, de 23 de diciembre de 2025): Seguridad y protección en redes de comunicaciones. Seguridad perimetral. Acceso remoto seguro a redes. Redes privadas virtuales (VPN). Seguridad en el puesto del usuario.

EXTENSIÓN
~27.500 palabras · 19 diagramas · 60 preguntas de test

TIEMPO ESTIMADO DE ESTUDIO
23-25 horas (primera vuelta completa, sin contar repasos)

Índice

- [ ] **1. Fundamentos de seguridad y protección en redes de comunicaciones**
  - [ ] **1.1. Principios de la seguridad de la información y de las comunicaciones**
  - [ ] **1.2. Amenazas, vulnerabilidades y vectores de ataque en redes informáticas**
  - [ ] **1.3. Mecanismos de protección en la pila de protocolos TCP/IP**
  - [ ] **1.4. Cumplimiento del Esquema Nacional de Seguridad en redes de la Administración Pública**
- [ ] **2. Seguridad perimetral**
  - [ ] **2.1. Concepto y arquitectura del perímetro de seguridad**
  - [ ] **2.2. Elementos de filtrado e inspección de tráfico**
  - [ ] **2.3. Sistemas de prevención y detección de intrusiones**
  - [ ] **2.4. Segmentación de redes y gestión de zonas de seguridad**
- [ ] **3. Acceso remoto seguro a redes**
  - [ ] **3.1. Requisitos y arquitectura de acceso remoto en el ámbito público**
  - [ ] **3.2. Control de acceso, identificación y autenticación**
  - [ ] **3.3. Protocolos y servicios para la gestión remota segura**
- [ ] **4. Redes privadas virtuales (VPN)**
  - [ ] **4.1. Conceptos generales y clasificaciones de VPN**
  - [ ] **4.2. Protocolos de tunelización y cifrado en VPN**
- [ ] **5. Seguridad en el puesto del usuario**
  - [ ] **5.1. Protección del sistema operativo y del hardware del puesto**
  - [ ] **5.2. Soluciones de protección del punto final**
  - [ ] **5.3. Gestión centralizada de directivas de seguridad y actualizaciones**
  - [ ] **5.4. Concienciación y buenas prácticas para la seguridad del empleado público**
- [ ] **Los ocho datos que no se pueden fallar**

Conceptos clave para memorizar

Concepto	Dato clave
Las cinco dimensiones de seguridad del ENS	**Confidencialidad (C)**, **Integridad (I)**, **Trazabilidad (T)**, **Autenticidad (A)** y **Disponibilidad (D)**. La regla nemotécnica es **CITAD**. No son tres («la tríada CIA») sino **cinco**: el ENS añade trazabilidad y autenticidad, y de ellas depende el **nivel** de cada medida. Confundir dimensión (C, I, T, A, D) con **categoría** del sistema (BÁSICA, MEDIA, ALTA) es el error conceptual más penalizado
Categoría frente a nivel	El **nivel** (BAJO, MEDIO, ALTO) se fija **por dimensión**. La **categoría** del sistema (BÁSICA, MEDIA, ALTA) se deriva de la **dimensión más exigente**: si alguna es ALTO, el sistema es de categoría ALTA; si ninguna es ALTO pero alguna es MEDIO, es MEDIA; en el resto, BÁSICA
Principios básicos del ENS (arts. 5-11)	Seguridad **integral** · gestión de la seguridad basada en el **riesgo** · **prevención, detección, respuesta y conservación** · existencia de **líneas de defensa** (**art. 9**: capas organizativas, físicas y lógicas) · **vigilancia continua y reevaluación periódica** (art. 10) · **diferenciación de responsabilidades** (art. 11: información, servicio, seguridad y sistema, separada de la explotación)
Defensa en profundidad	Traducción operativa del **art. 9**: varias capas independientes, de modo que el compromiso de una **no** comprometa el sistema entero. Es la razón de que exista a la vez cortafuegos perimetral, segmentación, VPN, MFA y antimalware en el puesto: **ninguna medida sustituye a las demás**
Amenaza, vulnerabilidad, riesgo e impacto	**Amenaza**: evento que puede causar daño (existe con independencia de nosotros). **Vulnerabilidad**: debilidad propia que la amenaza puede aprovechar. **Riesgo** = probabilidad × impacto, y solo se puede reducir actuando sobre la **vulnerabilidad** o sobre el **impacto**, nunca sobre la amenaza. **Salvaguarda** o medida: lo que reduce el riesgo. Metodología de referencia en las AAPP españolas: **MAGERIT v3** y la herramienta **PILAR**
Cifras de amenaza (ENISA, ETL 2025)	**4.875 incidentes** analizados entre el **1-7-2024 y el 30-6-2025**. El **DDoS** es el **77 %** de los incidentes notificados, pero solo el **2 %** provocó una interrupción real. El **ransomware** es la amenaza de **mayor impacto**. El **phishing** es el vector de entrada dominante: **60 %**, seguido de la **explotación de vulnerabilidades** con el **21,3 %**. Más del **80 %** de la ingeniería social observada a principios de 2025 se apoya ya en **IA**
Ataques por capa	**Enlace**: envenenamiento **ARP**, saturación de la tabla **CAM**, **VLAN hopping**, **rogue AP**. **Red**: **suplantación de IP**, escaneo, **DDoS** volumétrico, encaminamiento malicioso. **Transporte**: **SYN flood**, secuestro de sesión TCP,

Concepto	Dato clave
	escaneo de puertos. **Aplicación**: **phishing**, inyección **SQL**, **XSS**, envenenamiento de caché **DNS**, DDoS de aplicación
Mecanismo de protección por capa	**Enlace**: **MACsec** (IEEE **802.1AE**), **802.1X** con EAP, port security, **WPA3** en inalámbrica. **Red**: **IPsec** (AH, ESP, IKEv2), filtrado en cortafuegos. **Transporte**: **TLS** y **DTLS**. **Aplicación**: **SSH**, HTTPS, **DNSSEC**, S/MIME. La regla: **cuanto más baja la capa, más tráfico protege y menos contexto entiende**
Las tres medidas de red del ENS	`mp.com.1` **Perímetro seguro** (todas las dimensiones, **aplica en BÁSICA, MEDIA y ALTA**): sistema de protección perimetral que separe la red interna del exterior y por el que **todo el tráfico debe pasar**, con **todos los flujos autorizados previamente**. `mp.com.2` **Protección de la confidencialidad**: exige **VPN cifradas** cuando la comunicación sale del dominio de seguridad propio. `mp.com.4` **Separación de flujos de información en la red**: **no aplica** en BÁSICA; en MEDIA exige `+ [R1 o R2 o R3]` (VLAN, VPN o separación física)
El detalle del ENS que casi nadie sabe	`mp.com.1` remite a una **«Instrucción Técnica de Seguridad de Interconexión de Sistemas de Información»** que fijará los requisitos del perímetro por categoría. **Esa ITS no se ha publicado**: a agosto de 2026 solo hay **cuatro ITS** en el BOE — **Conformidad** e **Informe del Estado de la Seguridad** (2016), **Auditoría** y **Notificación de Incidentes** (2018)
Segmentación mínima del ENS	`mp.com.4.r1.2` obliga a segregar la red, **como mínimo**, en tres subredes: **usuarios**, **servicios** y **administración**. Y `mp.com.4.2`: si hay **comunicaciones inalámbricas**, irán **en un segmento separado**
Perímetro	Frontera entre la red bajo control propio y las que no lo están. **No es un dispositivo**, es una **función**. Regla de oro: **política por defecto de denegación** (*default deny*) — se prohíbe todo y se autoriza lo imprescindible, nunca al revés
Generaciones de cortafuegos	**1.ª filtro de paquetes** (sin estado, capa 3-4, listas de control de acceso) · **2.ª con estado** (*stateful*, tabla de conexiones, entiende el saludo TCP) · **3.ª pasarela de aplicación / proxy** (capa 7, rompe la conexión en dos) · **UTM** (varias funciones en una caja) · **NGFW** (identifica **aplicación y usuario**, no solo puertos, e integra IPS y antimalware). El **WAF** protege **una aplicación web**, no la red
Cortafuegos con estado	Mantiene una **tabla de estados** con las conexiones abiertas. El tráfico de vuelta se acepta **porque pertenece a una conexión establecida**, sin necesidad de una regla explícita. Es lo que distingue una ACL de un cortafuegos real

Concepto	Dato clave
Proxy directo e inverso	**Directo** (*forward*): se pone delante de los **clientes** internos para salir a internet — control de navegación, caché, filtrado de URL, y es donde se aplican `mp.s.3` y su **lista negra** o **lista blanca**. **Inverso** (*reverse*): se pone delante de los **servidores** publicados — termina el TLS, equilibra la carga, oculta el servidor y suele integrar el **WAF**
IDS frente a IPS	**IDS**: **fuera de línea** (modo *promiscuo*, con puerto espejo o TAP), **detecta y avisa**, no bloquea; si falla no corta el servicio. **IPS**: **en línea**, todo el tráfico lo atraviesa, **detecta y bloquea**; un falso positivo **corta tráfico legítimo** y una avería puede dejar la red sin servicio si no hay *bypass*. **HIDS** es de máquina; **NIDS**, de red
Firmas frente a anomalías	Detección por **firmas** (patrones conocidos): muy precisa, **no ve el ataque nuevo** (día cero). Detección por **anomalías** (desviación de una línea base): puede ver lo desconocido, pero genera **falsos positivos**. Los cuatro resultados posibles: verdadero positivo, **falso positivo** (alerta sin ataque), verdadero negativo y **falso negativo** (ataque no detectado, el peor)
ENS y detección	`op.mon.1` **Detección de intrusión**: **aplica ya en BÁSICA** («se dispondrá de herramientas de detección o prevención de intrusiones»); **MEDIA** añade R1 (**basada en reglas**) y **ALTA** R2 (**procedimientos de respuesta**). `op.mon.3` **Vigilancia**: recolección automática de eventos en BÁSICA; **correlación** (R1) en MEDIA — que es lo que se llama **SIEM**
DMZ	**Zona desmilitarizada**: subred intermedia donde se colocan los servicios **publicados a internet** (web, correo entrante, DNS externo). Regla que la define: desde la DMZ **no se puede iniciar** una conexión hacia la red interna; la interna sí puede ir a la DMZ. Dos arquitecturas: **cortafuegos de tres patas** (una sola caja con tres interfaces: exterior, DMZ e interna) y **doble cortafuegos** (dos equipos en serie, idealmente de fabricantes distintos)
Confianza cero	**NIST SP 800-207** (agosto de 2020). Idea central: **«nunca confíes, verifica siempre»** — desaparece la confianza implícita por estar «dentro» de la red. Componentes lógicos: **Motor de Políticas (PE)** y **Administrador de Políticas (PA)**, que forman el **punto de decisión (PDP)**, y el **Punto de Aplicación (PEP)**, que deja pasar o no. Cada acceso se concede **por sesión** y se reevalúa
Confianza cero ≠ fin del perímetro	La confianza cero **no elimina** el perímetro ni el cortafuegos: **complementa** el modelo perimetral, que sigue siendo obligatorio en España por `mp.com.1`. Lo que sustituye es la idea de **red interna de confianza**

Concepto	Dato clave
Acceso remoto en el ENS	`op.acc.4.5` : «Se establecerá una **política específica de acceso remoto**, requiriéndose **autorización expresa**». Es la medida que hay que citar en cualquier pregunta de teletrabajo. Y `mp.eq.3.3` : cuando un portátil se conecta por redes no controladas, el servidor limitará información y servicios **a los mínimos imprescindibles**
Base legal del teletrabajo público	**Art. 47 bis del TREBEP**, introducido por el **Real Decreto-ley 29/2020, de 29 de septiembre**. Teletrabajo **expresamente autorizado**, **voluntario y reversible**, compatible con la modalidad presencial, y con **la Administración obligada a proporcionar los medios tecnológicos** necesarios
Los tres factores de autenticación	**Algo que se sabe** (contraseña, PIN) · **algo que se tiene** (tarjeta criptográfica, token OTP, móvil, certificado en dispositivo) · **algo que se es** (biometría: huella, iris, facial). **MFA** exige **dos factores de categorías distintas**: contraseña + PIN **no** es MFA, porque los dos son «algo que se sabe»
MFA en el ENS	`op.acc.5` (usuarios externos) y `op.acc.6` (usuarios de la organización). En **nivel BAJO** basta `+ [R1 o R2 o R3 o R4]` ; en **MEDIO y ALTO** se exige `+ [R2 o R3 o R4] + R5` , es decir, **se cae la contraseña sola (R1)** y entra **OTP (R2)** o **certificado cualificado con segundo factor (R3/R4)**, más el **registro de accesos con éxito y fallidos (R5)**
AAA	**Autenticación** (¿quién eres?) · **Autorización** (¿qué puedes hacer?) · **Contabilidad/auditoría** (*accounting*: ¿qué has hecho?). Protocolos: **RADIUS** (RFC **2865**, **UDP 1812** autenticación y **1813** contabilidad, cifra **solo la contraseña**, combina AuthN y AuthZ), **TACACS+** (RFC **8907**, **TCP 49**, **separa** los tres servicios y cifra **todo el cuerpo** del mensaje, típico de administración de equipos de red) y **Diameter** (RFC **6733**, sucesor de RADIUS, sobre TCP o SCTP con TLS/DTLS)
Novedades AAA verificadas	**TACACS+ sobre TLS 1.3**: **RFC 9887**, de **diciembre de 2025** — resuelve la debilidad histórica del cifrado propio de TACACS+. **RADIUS/1.1**: **RFC 9765**, de **abril de 2025**, elimina el uso de **MD5** apoyándose en **ALPN**; está en estado **Experimental**

Concepto	Dato clave
802.1X	Control de acceso **a nivel de puerto** (IEEE **802.1X**). Tres actores: **suplicante** (el equipo), **autenticador** (conmutador o punto de acceso) y **servidor de autenticación** (RADIUS). Transporta **EAP** (RFC **3748**); **EAP-TLS** (RFC **5216**, actualizado por el **RFC 9190** para TLS 1.3) es el método con **certificado en ambos extremos**, el más robusto. Hasta autenticarse, el puerto solo deja pasar EAPOL
Gestión remota segura	**SSH** (RFC **4251-4254**, **TCP 22**) sustituye a **Telnet (23)**, **rlogin** y **FTP**: los tres van **en claro** y no deben usarse jamás. **SFTP** y **SCP** viajan **dentro** de SSH. **RDP** (**TCP/UDP 3389**) **nunca se publica directamente a internet**: se accede por VPN o por pasarela de escritorio remoto. **SNMPv1 y v2c** usan «comunidades» en claro: solo **SNMPv3** ofrece autenticación y cifrado
VPN: definición	Red **lógica y privada** construida **sobre una infraestructura pública o compartida**, mediante **tunelización** (encapsular un paquete dentro de otro) y **criptografía**. Aporta **confidencialidad, integridad y autenticidad del origen**; **no** aporta por sí sola disponibilidad ni anonimato. **Túnel ≠ VPN**: GRE encapsula pero **no cifra**
Los dos tipos de VPN	**Sitio a sitio** (*site-to-site*): une **dos redes** de forma permanente entre pasarelas; el usuario final **no instala nada** ni sabe que existe. **De acceso remoto**: une **un dispositivo** con una red; requiere **cliente** o navegador y **autenticación de usuario**. Variante de sitio a sitio: **extranet**, con un organismo tercero
Túnel completo o dividido	**Túnel completo** (*full tunnel*): **todo** el tráfico del portátil sale por la VPN, incluida la navegación — es lo que exige el control de `mp.s.3` y lo recomendable en la Administración. **Túnel dividido** (*split tunnel*): solo va por la VPN el tráfico corporativo — mejora el rendimiento pero **deja el equipo con un pie en cada red** y rompe la monitorización
IPsec: los tres protocolos	**AH** (RFC **4302**, protocolo IP **51**): integridad y autenticación, **NO cifra**. **ESP** (RFC **4303**, protocolo IP **50**): cifra **y** autentica — es el que se usa. **IKEv2** (RFC **7296**, **STD 79**, **UDP 500**, y **UDP 4500** con travesía de NAT): negocia las claves y las asociaciones de seguridad. Arquitectura general: **RFC 4301**
IPsec: los dos modos	**Modo transporte**: cifra **solo la carga útil**, conserva la cabecera IP original; extremo a extremo entre dos equipos. **Modo túnel**: cifra **el paquete IP completo** y le pone una **cabecera IP nueva**; es el de las **VPN entre pasarelas**. Regla: **VPN de sitio a sitio ⇒ ESP en modo túnel**

Concepto	Dato clave
IPsec: detalles clave	La **SA** (asociación de seguridad) es **unidireccional**: una conexión bidireccional necesita **dos**. Se identifica por el trío **SPI + dirección de destino + protocolo**. **AH no sobrevive a NAT** (protege la cabecera IP); por eso con NAT se usa **ESP encapsulado en UDP 4500** (RFC **3948**). **IKEv1 está formalmente declarado obsoleto** por el **RFC 9395** (abril de 2023)
SSL/TLS VPN	Aprovecha **TLS sobre TCP 443**, que **atraviesa cualquier cortafuegos**. Dos modalidades: **sin cliente** (*clientless*, por navegador, típicamente un portal con acceso a aplicaciones web) y **con cliente ligero** (túnel completo de nivel de red). Ventaja: despliegue y compatibilidad. Inconveniente: rendimiento y menor control del puesto
Novedad TLS verificada	El **RFC 8446** (TLS 1.3, 2018) ha sido **obsoletado por el RFC 9846, de julio de 2026**, que reedita la especificación y obsoleta también el RFC 5246 (TLS 1.2). **TLS 1.0 y 1.1 están prohibidos** por el **RFC 8996** y **SSL 3.0** por el **RFC 7568**: en 2026 **solo son admisibles TLS 1.2 (bien configurado) y TLS 1.3**
Protocolos de nivel de enlace	**PPTP** (RFC **2637**): **roto criptográficamente, prohibido**. **L2TP** (RFC **2661**; **L2TPv3**, RFC **3931**): **no cifra por sí solo** — se combina como **L2TP/IPsec**. **GRE** (RFC **2784**): encapsula, **no cifra**; se usa con IPsec para transportar multidifusión y protocolos de encaminamiento. **MPLS**: aísla el tráfico entre clientes de un operador, pero **no lo cifra**
Post-cuántico en VPN	Amenaza **«cosecha ahora, descifra después»**. En IKEv2: **RFC 8784** (mezcla de claves precompartidas) y **RFC 9370** (**múltiples intercambios de claves**). En TLS 1.3: **RFC 9954** (jul-2026, informativo) y **RFC 10024** (**agosto de 2026**, norma propuesta) para el intercambio **híbrido PQ/T**. Hoja de ruta de la UE: **31-12-2026** planes nacionales, **31-12-2030** casos de alto riesgo, **31-12-2035** transición completa
Protección del puesto en el ENS	`mp.eq.1` **Puesto de trabajo despejado** (aplica en BÁSICA) · `mp.eq.2` **Bloqueo del puesto** (dimensión **A**: **no aplica** en BAJO, sí desde MEDIO; ALTO añade el **cierre de sesiones**) · `mp.eq.3` **Protección de dispositivos portátiles** (inventario, procedimiento de pérdida o robo, mínimos imprescindibles, evitar guardar claves de acceso remoto; **R1 = cifrado de disco** cuando la confidencialidad es de nivel MEDIO) · `mp.eq.4` **Otros dispositivos conectados a la red** (impresoras, multimedia, **IoT** y **BYOD**)
Antivirus, EPP, EDR y XDR	**Antivirus** clásico: **firmas**, ficheros. **EPP**: plataforma de protección del punto final — antivirus, cortafuegos personal, control de dispositivos, cifrado, todo gestionado en consola. **EDR**: **detección y respuesta**, registra el

Concepto	Dato clave
	comportamiento, permite **investigar y aislar** el equipo; es lo que exige el ENS en `op.exp.6.r4` para **categoría ALTA**. **XDR** amplía la correlación a red, correo y nube; **MDR** es el mismo servicio, operado por un tercero
Código dañino en el ENS	`op.exp.6` : software antimalware **en todos los equipos: puestos, servidores y elementos perimetrales**, con bases **permanentemente actualizadas** y **protección en tiempo real**. **BÁSICA**: la medida. **MEDIA**: `+ R1 + R2` (escaneo periódico y revisión al arranque). **ALTA**: `+ R1 + R2 + R3 + R4` — **R3 lista blanca de aplicaciones** y **R4 EDR**
Cifrado del puesto	**Cifrado de disco completo** (BitLocker, LUKS, FileVault), anclado normalmente a un **TPM** (módulo de plataforma segura). Protege frente a **pérdida o robo** del equipo apagado; **no** protege frente a malware con el equipo encendido y la sesión abierta. **Arranque seguro** (*Secure Boot*) y **UEFI** protegen la cadena de arranque
Gestión centralizada	**Línea base de seguridad** (*baseline*) aplicada por **GPO** en dominio o por **MDM/UEM** en móviles, más **despliegue de parches** con ventana de mantenimiento y anillos de despliegue. Base normativa: **art. 20 del ENS** (mínimo privilegio y **guías de configuración de seguridad**), `op.exp.2` (retirar cuentas estándar, **mínima funcionalidad**, **seguridad por defecto**) y `op.exp.4` (procedimiento para **analizar, priorizar y decidir cuándo** aplicar cada actualización; **R1** exige probarlo antes en preproducción)
Fin de soporte	Un sistema sin soporte **no recibe parches** y ningún antivirus lo compensa. **Windows 10 terminó su soporte el 14 de octubre de 2025**; el programa de pago **ESU** solo alarga las actualizaciones **críticas e importantes** hasta el **12 de octubre de 2027**. Mantener puestos fuera de soporte es un **incumplimiento directo de** `op.exp.4`
Concienciación	`mp.per.3` **Concienciación** y `mp.per.4` **Formación aplican en las tres categorías**, incluida la BÁSICA. `mp.per.3` obliga a recordar periódicamente **la normativa de buen uso y las técnicas de ingeniería social**, **cómo identificar** un incidente y **el procedimiento para informar**, sean reales o falsas alarmas. Y `mp.s.3.2` exige **higiene de navegación**
El dato que cierra el tema	**El factor humano es el vector dominante**: el phishing es el **60 %** de los accesos iniciales (ENISA, 2025). Por eso la última capa de defensa no es un dispositivo: es **el empleado público formado**, y la normativa lo trata como una medida más, con el mismo rango que un cortafuegos

Contenido

Convenciones del documento

Este tema incluye cuatro tipos de **cajas callout** para facilitar el estudio:

> **DATO CLAVE**
> Información de alta densidad memorística: puertos, códigos de medida del ENS, números de RFC, siglas y umbrales.

> **EJERCICIO RESUELTO**
> Problema + solución paso a paso: leer una regla de cortafuegos, decidir un modo de IPsec, calcular el efecto de un falso positivo, elegir entre IDS e IPS.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
> Aplicación real de la teoría al entorno municipal (red del IAM, oficinas de distrito, teletrabajo del empleado municipal, sede electrónica).

> **RELACIÓN CON OTROS TEMAS**
> Enlace conceptual a otros temas del temario oficial.

Advertencia de frontera, y es la primera cosa que hay que fijar. El Tema 36 se toca con **cuatro temas vecinos**, y el error más frecuente al estudiarlo es responder con la materia del tema de al lado. El criterio seguido aquí es este:

- **El Tema 32** («Conceptos de seguridad de los sistemas de información. Seguridad física. Seguridad lógica. Amenazas y vulnerabilidades. Técnicas criptográficas y protocolos seguros. Mecanismos de firma digital») explica **qué es** un algoritmo simétrico, qué es una función resumen, cómo funciona una firma digital y qué es una PKI. **El Tema 36 no vuelve a explicar la criptografía: la aplica a la red.** Aquí interesa qué protocolo usa qué mecanismo y en qué capa, no cómo funciona el mecanismo por dentro.
- **El Tema 34** («El modelo TCP/IP y el modelo de referencia OSI de ISO. Protocolos TCP/IP») explica **los protocolos**: cabeceras, saludo en tres pasos, direccionamiento. Aquí se da por sabido y solo se usa para situar en qué capa actúa cada defensa.
- **El Tema 35** («Internet: arquitectura de red… Protocolos HTTP, HTTPS y SSL/TLS») desarrolla **TLS y HTTPS** como protocolos de la Web. Aquí TLS aparece **solo** en dos papeles: como mecanismo de protección de la capa de transporte (§1.3.2) y como base de las **VPN SSL/TLS** (§4.2.2).

- **El Tema 37** («Redes locales. Tipología. Técnicas de transmisión. Métodos de acceso. Dispositivos de interconexión») describe **la red local y sus equipos**. Aquí solo se toma de él lo que es una medida de seguridad: **VLAN, 802.1X, segmentación**.
- **El Tema 39** («Principios básicos del Esquema Nacional de Seguridad y el Esquema Nacional de Interoperabilidad») desarrolla el **ENS como marco**: su ámbito, su gobernanza, sus principios, la categorización de sistemas, la auditoría y la conformidad, junto con el ENI. En este tema el ENS aparece **solo por las medidas concretas que se aplican a la red y al puesto** — `mp.com`, `op.mon`, `mp.eq`, `op.acc`, `op.exp.6` —, y los principios de los artículos 5 a 11 se resumen en §1.1 **únicamente como llave de lectura** de esas medidas, no como materia propia. Si en el examen la pregunta es «cuáles son los principios básicos del ENS», la respuesta corresponde al T39; si es «qué medida del ENS obliga a disponer de perímetro», corresponde a este tema.

Y en sentido inverso: **este tema es el que hay que citar** cuando en cualquier otro aparezcan las palabras **cortafuegos, DMZ, IDS/IPS, VPN, acceso remoto, antivirus, EDR o puesto de trabajo**.

La segunda advertencia es de método. Este tema une **cinco materias completas** que en la práctica profesional pertenecen a equipos distintos —arquitectura de red, perímetro, identidad, comunicaciones cifradas y puesto de usuario—, y por eso es uno de los más extensos del temario. Se aprueba fijando **cuatro cosas** y no intentando memorizarlo entero:

1. **La tabla de medidas del ENS** que aparece al final de §1.4, porque es lo que convierte una respuesta técnica en una respuesta de oposición.
2. **Las parejas que se confunden**: IDS/IPS, AH/ESP, transporte/túnel, proxy directo/inverso, EPP/EDR, túnel completo/dividido.
3. **Los puertos y números de protocolo**, concentrados en las tablas de §3.3 y §4.2.1.
4. **Qué medida aplica en qué categoría**, que es donde está la mayor dificultad.

Las fuentes se citan con etiquetas breves tipo `[ENS]`, `[RFC4301]` o `[NIST-ZT]`; el registro completo está en la pestaña Fuentes. **Todas las medidas y textos del ENS citados en este tema proceden del PDF oficial del BOE** (Real Decreto 311/2022, texto consolidado), no de fuentes secundarias; y **el número, título, fecha, estado y relaciones de obsolescencia de todos los RFC citados se han contrastado contra el índice oficial del RFC Editor**.

Caso de referencia usado en todo el tema (contexto Ayuntamiento de Madrid, supuesto simplificado): la **red corporativa municipal** gestionada por el **IAM**, con tres piezas que reaparecen en cada sección — el **CPD** donde viven las aplicaciones y la sede electrónica, una **oficina de atención a la ciudadanía de distrito** conectada a la red municipal, y el **portátil de un empleado que teletrabaja** desde su domicilio. Las cinco secciones del tema son, en realidad, cinco preguntas sobre ese mismo escenario: qué amenaza le acecha (§1), cómo se protege su frontera (§2), cómo entra el empleado desde fuera (§3), por qué canal viaja (§4) y cómo se protege el equipo desde el que trabaja (§5).

1. Fundamentos de seguridad y protección en redes de comunicaciones

1.1. Principios de la seguridad de la información y de las comunicaciones

Qué se protege exactamente. La seguridad de las redes de comunicaciones no protege «la red»: protege **la información que circula por ella** y **los servicios que dependen de ella**. Esa distinción no es retórica, porque de ella se deriva el modo de medir el riesgo: un conmutador averiado no es un problema de seguridad por sí mismo, lo es porque deja sin servicio a una oficina de atención a la ciudadanía.

La formulación clásica del objetivo son las tres propiedades de la llamada **tríada CIA**: **confidencialidad**, **integridad** y **disponibilidad**. La normativa española va más allá y trabaja con **cinco dimensiones**.

> DATO CLAVE
>
> Las **cinco dimensiones de seguridad** del Esquema Nacional de Seguridad son **confidencialidad (C)**, **integridad (I)**, **trazabilidad (T)**, **autenticidad (A)** y **disponibilidad (D)** [ENS]. Nemotécnica: **CITAD**. Toda pregunta que hable de «las tres dimensiones del ENS» o que cite solo la tríada CIA está mal planteada: en el marco español son **cinco**, y de cada una se predica un **nivel** (BAJO, MEDIO o ALTO) que determina qué medidas y qué refuerzos son exigibles.

Definidas con precisión, y en los términos que emplea el propio ENS:

Dimensión	Qué garantiza	Qué la rompe en una red	Mecanismo típico
Confidencialidad (C)	Que la información solo sea accesible para quien esté autorizado	Escucha del tráfico (*sniffing*), acceso a un segmento no autorizado	**Cifrado**: IPsec, TLS, MACsec; segmentación
Integridad (I)	Que la información no se altere de forma no autorizada, y que se detecte si ocurre	Alteración de un paquete en tránsito, inyección de información espuria	**Resúmenes y códigos de autenticación de mensaje** (HMAC) dentro de IPsec, TLS o SSH
Trazabilidad (T)	Que se pueda reconstruir quién hizo qué y cuándo	Borrado o falta de registros, relojes desincronizados	**Registro de actividad** (`op.exp.8`), sincronización horaria, SIEM
Autenticidad (A)	Que quien dice ser el origen lo sea realmente	Suplantación de IP o de MAC, punto de acceso falso, secuestro de sesión	**Certificados digitales**, autenticación mutua, 802.1X, firma
Disponibilidad (D)	Que el servicio esté accesible cuando se necesita	**DDoS**, corte de enlace, saturación de un cortafuegos	Redundancia, mitigación anti-DDoS, dimensionado, `mp.s.4`

La diferencia entre nivel y categoría, que es la trampa habitual. El **nivel** se fija **por cada dimensión** por separado: un sistema puede tener confidencialidad MEDIA y disponibilidad ALTA. La **categoría del sistema** (BÁSICA, MEDIA o ALTA) se deriva de la dimensión **más exigente**: si alguna dimensión es ALTO, el sistema es de categoría ALTA; si ninguna es ALTO pero alguna es MEDIO, es MEDIA; y si todas son BAJO, es BÁSICA. Después, cada medida del anexo II se aplica **según el nivel de su dimensión** (si la medida se predica de una dimensión concreta, como `mp.com.2`, que es de confidencialidad) **o según la categoría** (si se predica de todas, como `mp.com.1`).

Los principios básicos del ENS. Los artículos 5 a 11 del Real Decreto 311/2022 fijan los principios que ordenan todo lo demás [ENS]. Tres de ellos son los que importan aquí:

- **La seguridad como proceso integral** (art. 6): la seguridad la componen elementos técnicos, humanos, materiales y organizativos, y se ve comprometida por el eslabón más débil. La consecuencia práctica: no existe la seguridad «comprada», existe la seguridad gestionada.
- **Existencia de líneas de defensa** (art. 9): el sistema debe disponer de **múltiples capas de seguridad**, de modo que, cuando una sea comprometida, permita reaccionar y **minimizar el**

impacto final. El apartado 2 añade que esas líneas serán de naturaleza **organizativa, física y lógica**.

- **Vigilancia continua y reevaluación periódica** (art. 10): detección de comportamientos anómalos y **reevaluación de las medidas**, porque la seguridad de ayer no es la de hoy.

> DATO CLAVE
>
> El **artículo 9 del ENS** es la base normativa de lo que técnicamente se llama **defensa en profundidad**. Es la respuesta correcta a cualquier pregunta del tipo «¿por qué hay que poner antivirus en el puesto si ya hay un cortafuegos perimetral?»: porque **ninguna capa sustituye a otra** y el diseño debe suponer que **alguna fallará**. Añádase el **art. 11**, que exige diferenciar **responsable de la información, del servicio, de la seguridad y del sistema**, y que la responsabilidad de la seguridad esté **separada de la de explotación**.

Los principios de diseño que se derivan. De esos principios generales salen cinco reglas operativas que aparecen literalmente en el articulado y que conviene poder citar:

1. **Mínimo privilegio** (art. 20): funcionalidad imprescindible, funciones de operación y administración **mínimas**, ejercidas **solo por personas autorizadas y desde equipos autorizados**, pudiendo exigirse restricciones de **horario y puntos de acceso**.
2. **Mínima funcionalidad y seguridad por defecto** (`op.exp.2`): se retiran cuentas y contraseñas estándar, se desactiva lo innecesario y **para reducir la seguridad el usuario tiene que realizar un acto consciente**.
3. **Denegación por defecto**: en la red, la traducción de lo anterior es que **se prohíbe todo y se autoriza lo imprescindible**. `mp.com.1.2` lo dice sin rodeos: «Todos los flujos de información a través del perímetro deben estar **autorizados previamente**».
4. **Segregación de funciones** (`op.acc.3`): quien desarrolla no opera; quien audita no administra.
5. **Necesidad de conocer** (`op.acc.4.3`): los privilegios se conceden por lo que hace falta saber para el puesto, no por jerarquía.

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> Un sistema municipal de gestión de expedientes de licencias tratará datos personales y documentos administrativos. Si su confidencialidad se valora MEDIA, su integridad MEDIA, su trazabilidad MEDIA y su disponibilidad BAJA, el sistema es de **categoría MEDIA** (la más exigente de las dimensiones). A partir de ahí, `mp.com.4` («separación de flujos de información en la red») pasa de **no aplicar** —que es lo que ocurriría en BÁSICA— a exigir `+ [R1 o R2 o R3]` : VLAN, VPN o separación física. Es decir: la decisión de arquitectura de red **no la toma el técnico, la impone la categorización**.

Un apunte que evita un error frecuente. La seguridad de las comunicaciones **no es lo mismo** que la protección de datos personales, aunque se solapen. El **artículo 32 del RGPD** exige medidas técnicas y organizativas apropiadas e **menciona expresamente el cifrado**, y los **artículos 33 y 34** obligan a notificar las violaciones de seguridad a la autoridad de control **en 72 horas** [RGPD]. Pero el RGPD protege **a las personas**; el ENS protege **al servicio público**. Un mismo incidente puede exigir dos notificaciones distintas y por vías distintas: al **CCN-CERT** por el ENS y a la **AEPD** por el RGPD.

1.2. Amenazas, vulnerabilidades y vectores de ataque en redes informáticas

Cuatro palabras que no son sinónimos. El vocabulario del análisis de riesgos es fácil de confundir:

- **Activo**: cualquier elemento con valor para la organización — información, servicio, equipo, instalación, personal.
- **Amenaza**: evento que puede causar un daño sobre un activo. **Existe con independencia de nosotros**: no se puede eliminar un terremoto ni un grupo de ciberdelincuentes.
- **Vulnerabilidad**: debilidad **propia** del activo que una amenaza puede aprovechar. Un servidor sin parchear, una contraseña débil, un empleado no formado.
- **Riesgo**: estimación del daño esperado, función de la **probabilidad** de que la amenaza se materialice y del **impacto** si lo hace.
- **Salvaguarda** o **medida de seguridad**: lo que reduce el riesgo, actuando sobre la probabilidad (medidas **preventivas**) o sobre el impacto (medidas **de reacción y recuperación**).

> DATO CLAVE
>
> Sobre la **amenaza no se puede actuar**; solo se actúa sobre la **vulnerabilidad** y sobre el **impacto**. De ahí que el riesgo nunca llegue a cero: siempre queda un **riesgo residual**, que la dirección debe **aceptar formalmente**. La metodología de referencia en la Administración española es **MAGERIT v3** (2012), y su herramienta de apoyo, **PILAR**, del Centro Criptológico Nacional [MAGERIT].

Cómo se clasifican las amenazas de red. La clasificación más útil combina dos ejes. Por su **origen**: amenazas **externas** (internet, cadena de suministro) e **internas** (personal propio, con o sin intención — el llamado *insider*). Por su **naturaleza**: **accidentales** (errores, averías, desastres) e **intencionadas** (ataques). Y por su **efecto sobre las dimensiones**, que es la clasificación que conecta con el ENS:

Tipo de ataque	Qué dimensión rompe	Ejemplos en red
Interceptación (ataque **pasivo**)	Confidencialidad	Escucha de tráfico, análisis de tráfico, captura de credenciales en claro
Modificación (ataque **activo**)	Integridad	Alteración de un paquete en tránsito, envenenamiento de caché DNS o ARP
Fabricación (activo)	Autenticidad	Suplantación de IP o MAC, correo falsificado, punto de acceso inalámbrico impostor
Interrupción (activo)	Disponibilidad	DoS y **DDoS**, corte físico de un enlace, agotamiento de recursos

DATO CLAVE

El **ataque pasivo** solo escucha: **no altera nada**, y por eso **es muy difícil de detectar** — se combate **previniéndolo** con cifrado, no detectándolo. El **ataque activo** modifica, inyecta o interrumpe: **sí se detecta**, y por eso se combate con integridad, autenticación y monitorización. El ENS lo recoge en `mp.com.3.2`, que enumera como ataques activos exactamente tres: **la alteración de la información en tránsito**, **la inyección de información espuria** y **el secuestro de la sesión por una tercera parte**.

El estado real de la amenaza, con cifras verificadas. El informe **ENISA Threat Landscape 2025** analizó **4.875 incidentes** ocurridos entre el **1 de julio de 2024 y el 30 de junio de 2025** en la Unión Europea [ENISA-ETL]. Sus conclusiones desmienten varias intuiciones:

- El **DDoS** representa el **77 %** de los incidentes notificados, pero **solo el 2 %** provocó una interrupción real del servicio: la mayoría son acciones hacktivistas de bajo nivel con más ruido que efecto.
- El **ransomware** es, en cambio, **la amenaza de mayor impacto** en la UE, y concentra la gran mayoría de los incidentes de ciberdelincuencia contra organizaciones.
- El **phishing** es el punto de entrada dominante: **60 %** de los accesos iniciales, seguido de la **explotación de vulnerabilidades** con el **21,3 %**.
- A principios de 2025, **más del 80 %** de la actividad de ingeniería social observada en el mundo se apoyaba ya en **contenido generado o mejorado con inteligencia artificial**.

DATO CLAVE

Las dos cifras que hay que retener del ETL 2025 son **60 % de phishing** como vector de entrada y **21,3 % de explotación de vulnerabilidades**. Juntas explican **más de ocho de cada diez** intrusiones, y explican también por qué las dos medidas más rentables de todo este tema son **la formación del empleado** (§5.4) y **el parcheado** (§5.3), no el cortafuegos. La lectura del DDoS es la contraria a lo que sugiere el titular: es el ataque **más frecuente** y el **menos dañino**.

Los ataques que hay que saber nombrar. No se trata de conocerlos todos, sino de saber **qué hace cada uno y en qué capa actúa**, porque así se deduce la contramedida:

- **Escaneo y reconocimiento**: barrido de puertos y de servicios para levantar el mapa de la víctima. Es la fase previa de casi todo.
- **Suplantación** (*spoofing*): falsificar una dirección de origen — de IP, de MAC, de correo o de DNS — para hacerse pasar por otro.
- **Intermediario** (*man in the middle*, hoy **atacante en el medio**): situarse entre dos partes leyendo o alterando lo que se dicen, normalmente tras un envenenamiento ARP o un punto de acceso impostor.
- **Denegación de servicio distribuida (DDoS)**: agotar ancho de banda, tabla de estados o capacidad de la aplicación desde miles de orígenes. Tres familias: **volumétrico** (inundar el enlace), **de protocolo** (agotar recursos, como el **SYN flood**) y **de aplicación** (peticiones legítimas pero costosas).
- **Ransomware**: cifrado del dato con extorsión, hoy casi siempre con **doble extorsión** (además roban y amenazan con publicar). Entra por phishing, por credencial robada o por un servicio de acceso remoto expuesto.
- **Amenaza persistente avanzada (APT)**: intrusión dirigida y prolongada, con permanencia y sigilo. El ENS la menciona expresamente en `op.mon.3.r3.2`, que exige detectarla por **anomalías significativas en el tráfico de la red**.
- **Ataque a la cadena de suministro**: comprometer a un proveedor o a una actualización legítima para llegar al objetivo final.
- **Ingeniería social**: manipular a una persona. Variantes: **phishing** (masivo), **spear phishing** (dirigido), **whaling** (a directivos), **vishing** (por voz), **smishing** (por SMS) y **fraude del CEO**.

EJERCICIO RESUELTO

Problema: una oficina de distrito informa de que «internet va lentísimo» y de que varios equipos ven las páginas de la intranet «raras». Al analizar el tráfico se observa que un equipo está enviando continuamente respuestas ARP no solicitadas asociando su propia MAC a la IP de la pasarela. ¿Qué ataque es, qué dimensión compromete y con qué medida se corta? **Solución**. Es un **envenenamiento de la caché ARP** (*ARP spoofing*), un ataque de **capa de enlace**: el equipo atacante convence al resto de la red de que él es el encaminador, y todo el tráfico pasa por él. Compromete la **confidencialidad** (lee lo que no va cifrado) y la **integridad y autenticidad** (puede alterarlo), y de rebote la **disponibilidad**, porque el equipo intermedio no da abasto — de ahí la lentitud. La contramedida no está en el cortafuegos perimetral, que **no ve este tráfico** porque nunca sale del segmento: está en el **conmutador**, con **inspección dinámica de ARP**, *port security* y **802.1X** para que un equipo no autorizado no llegue a tener enlace; y estructuralmente, en la **segmentación** (`mp.com.4`), que limita el alcance del ataque a una sola VLAN. La lección es esa: **un ataque de capa 2 no lo para un cortafuegos de capa 3**.

1.3. Mecanismos de protección en la pila de protocolos TCP/IP

La idea que ordena toda la sección. Cada capa de la pila TCP/IP tiene su propio mecanismo de protección, y todos hacen lo mismo —autenticar, cifrar, comprobar integridad— pero con un alcance distinto. La regla que permite elegir es simple:

DATO CLAVE

Cuanto más baja es la capa en la que se protege, más tráfico se protege de golpe y menos se entiende de lo que se está protegiendo. Cifrar en la **capa de enlace** (MACsec) protege absolutamente todo lo que pasa por un cable, pero solo entre dos equipos contiguos. Cifrar en la **capa de red** (IPsec) protege todas las aplicaciones sin tocarlas, pero no distingue entre ellas. Cifrar en la **capa de transporte** (TLS) protege una conexión concreta de una aplicación concreta, extremo a extremo, pero deja fuera todo lo demás. Ninguna sustituye a las otras: por eso conviven.

1.3.1. Seguridad en la capa de red y acceso al medio

Capa de acceso al medio: el enlace físico y la red local. Es la capa más olvidada y la que más ataques silenciosos concentra, porque quien tiene acceso físico a una roseta ya está «dentro».

- **IEEE 802.1X — control de acceso a la red basado en puerto.** Antes de dar conectividad, el conmutador o el punto de acceso exige que el equipo se autentique. Se estudia en detalle en §3.2.2 porque es también un mecanismo de identidad, pero conviene fijar aquí que **es la única medida que impide que un equipo desconocido enchufado a una roseta obtenga red**.

- **IEEE 802.1AE — MACsec.** Cifrado e integridad **salto a salto** en la propia trama Ethernet. Protege el cableado entre conmutadores o entre el puesto y el conmutador. Su ámbito es un enlace, no una comunicación completa.
- **Seguridad de puerto** (*port security*): limitar cuántas y qué direcciones MAC pueden aparecer en un puerto, para frenar la **saturación de la tabla CAM** —un ataque que fuerza al conmutador a comportarse como un concentrador y difundir todo el tráfico.
- **Inspección dinámica de ARP** y **vigilancia de DHCP** (*DHCP snooping*): impiden el envenenamiento ARP y la aparición de un **servidor DHCP no autorizado**, que es el modo más sencillo de convertirse en intermediario de toda una planta.
- **VLAN**: separación lógica de dominios de difusión. Es el mecanismo con el que se implementa la segmentación exigida por `mp.com.4.r1.1`. Su ataque característico es el **salto de VLAN** (*VLAN hopping*), que se previene desactivando la negociación automática de enlaces troncales y no dejando la VLAN nativa en uso.
- **Redes inalámbricas**: **WPA2** con AES-CCMP fue el estándar durante quince años; **WPA3** (2018) añade **SAE** —autenticación simultánea de iguales—, que resiste el ataque de diccionario fuera de línea sobre la contraseña, y **cifrado individualizado** en redes abiertas. En un entorno corporativo lo correcto es **WPA2/WPA3-Enterprise con 802.1X y EAP**, nunca clave compartida.

> DATO CLAVE
>
> El ENS obliga a que, **si se emplean comunicaciones inalámbricas, sea en un segmento separado** (`mp.com.4.2`). Es una obligación literal y de categoría, no una recomendación: la red Wi-Fi de invitados de un edificio municipal **no puede** compartir segmento con la red de puestos de trabajo.

Capa de red: IPsec. Es el mecanismo de seguridad **nativo del protocolo IP** y el corazón de la §4 de este tema. Aquí basta con fijar su papel: proporciona **confidencialidad, integridad, autenticación del origen y protección frente a repetición** a **todo** el tráfico IP entre dos puntos, **sin que las aplicaciones se enteren**. Esa transparencia es su gran virtud —no hay que modificar ni un programa— y su gran limitación —no distingue si lo que transporta es un correo o una copia de seguridad—. Su arquitectura la define el **RFC 4301**, y se desarrolla en §4.2.1.

Otros mecanismos de la capa de red. El **filtrado** en cortafuegos y encaminadores (§2.2.1) es en sí mismo un mecanismo de capa 3-4. Y en el plano del **encaminamiento**, la protección consiste en autenticar los protocolos de encaminamiento y, en el ámbito de internet, en validar el origen de los anuncios BGP mediante **RPKI**, para evitar los secuestros de prefijo.

1.3.2. Seguridad en la capa de transporte y aplicación

Capa de transporte: TLS y DTLS. TLS (*Transport Layer Security*) protege una **conexión TCP** concreta: negocia algoritmos, autentica al servidor mediante **certificado** —y opcionalmente al cliente—, establece claves de sesión y cifra el flujo. **DTLS** hace lo mismo sobre **UDP**, para tráfico que no tolera la retransmisión ordenada, como voz, vídeo o telemetría.

> DATO CLAVE
>
> Situación de TLS en 2026, verificada contra el índice del RFC Editor. **SSL 2.0 y 3.0**: prohibidos (**RFC 7568** deprecó SSL 3.0). **TLS 1.0 y 1.1**: prohibidos por el **RFC 8996** (marzo de 2021). **TLS 1.2**: admisible **solo bien configurado**; el **RFC 10015**, de **julio de 2026**, ha declarado obsoletos sus métodos de intercambio de claves antiguos. **TLS 1.3**: especificado en el **RFC 8446** (2018) y **reeditado por el RFC 9846 en julio de 2026**, que obsoleta tanto el 8446 como el 5246 (TLS 1.2). La respuesta correcta a «¿qué versiones se admiten hoy?» es **TLS 1.2 y TLS 1.3**, y la referencia de buenas prácticas es el **RFC 9325** (BCP 195).

Capa de aplicación: cada protocolo, su versión segura. La regla general es que los protocolos originales de internet nacieron **en claro** y que todos tienen hoy una variante protegida, casi siempre por TLS:

Protocolo en claro	Puerto	Alternativa segura	Puerto
Telnet	23	**SSH**	22
FTP	21 (control)	**SFTP** (dentro de SSH) · **FTPS** (FTP sobre TLS)	22 · 990/989
HTTP	80	**HTTPS** (HTTP sobre TLS)	443
SMTP	25	**SMTP con STARTTLS** · envío desde cliente con TLS implícito	587 · 465
POP3 / IMAP	110 / 143	**POP3S / IMAPS**	995 / 993
LDAP	389	**LDAPS**	636
SNMPv1 / v2c	161	**SNMPv3** (autenticación y cifrado)	161
DNS	53	**DoT** (DNS sobre TLS) · **DoH** (DNS sobre HTTPS)	853 · 443
rlogin / rsh / rcp	513 / 514	**SSH** y sus derivados	22

DATO CLAVE

Tres matices sobre esta tabla. Primero: **SFTP y FTPS no son lo mismo** — SFTP es un subsistema **de SSH** (un solo puerto, el 22), mientras que FTPS es **FTP envuelto en TLS** y arrastra los problemas de FTP con los cortafuegos por usar dos canales. Segundo: **DNSSEC no cifra** — firma las respuestas y aporta **autenticidad e integridad**, mientras que **DoT y DoH cifran** y aportan **confidencialidad**; son complementarios, no alternativos. Tercero: **SNMPv2c no es seguro** pese al «2»: la «c» es de *community*, cadenas que viajan en claro.

Y el mecanismo de la capa de aplicación que no es un protocolo: el filtrado de contenido. Un proxy o un cortafuegos de aplicación puede leer lo que un cortafuegos de red no ve —una URL, una consulta SQL, un adjunto—, y es la única capa donde se pueden aplicar reglas del tipo «este usuario no puede subir un fichero a este servicio». Se desarrolla en §2.2.2.

RELACIÓN CON OTROS TEMAS

El funcionamiento interno de los algoritmos criptográficos, de las funciones resumen, de la firma electrónica y de la PKI corresponde al **Tema 32**. El detalle de HTTP, HTTPS y del saludo TLS, al **Tema 35**. Las cabeceras de IP, TCP y UDP y el saludo en tres pasos, al **Tema 34**. Las VLAN, los conmutadores y los métodos de acceso al medio, al **Tema 37**.

1.4. Cumplimiento del Esquema Nacional de Seguridad en redes de la Administración Pública

Por qué esta sección decide la nota. Un opositor puede describir perfectamente un cortafuegos y aun así suspender la pregunta si no la ancla en la norma. En un examen del Ayuntamiento de Madrid, **la respuesta técnica se convierte en respuesta administrativa cuando cita la medida**. Esta sección reúne, verificadas contra el PDF del BOE, **todas** las medidas del ENS que este tema necesita.

El encaje normativo, de arriba abajo. El **artículo 156.2 de la Ley 40/2015** habilita al Esquema Nacional de Seguridad, aprobado por el **Real Decreto 311/2022, de 3 de mayo**. Su ámbito de aplicación (art. 2) alcanza a todo el sector público —y por tanto a las entidades locales— y, en lo que aquí importa, también a **los sistemas que tratan información clasificada** y a **los proveedores privados que prestan servicios a las Administraciones**. Por encima, el marco europeo: la **Directiva (UE) 2022/2555 (NIS2)**.

DATO CLAVE

NIS2 no es directamente aplicable en España en agosto de 2026. Es una **directiva**, y necesita transposición. El **anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad** fue aprobado por el Consejo de Ministros el **14 de enero de 2025** y **sigue en tramitación**, sin publicación en el BOE. España incumplió el plazo de transposición del **17 de octubre de 2024** y la Comisión Europea le remitió **dictamen motivado** en 2025. Para las Administraciones Públicas españolas, la norma de seguridad **exigible hoy** sigue siendo **el ENS** [NIS2].

Los artículos del ENS que hablan de red. Tres, y conviene poder citarlos por número:

- **Art. 22 — Protección de la información almacenada y en tránsito**: obliga a prestar «especial atención» a la información en tránsito por **equipos o dispositivos portátiles o móviles**, **dispositivos periféricos**, **soportes** y **comunicaciones sobre redes abiertas**. Es el fundamento general del cifrado en red y del cifrado del portátil.
- **Art. 23 — Prevención ante otros sistemas de información interconectados**: «Se protegerá el **perímetro** del sistema de información, especialmente, si se conecta a **redes públicas**… reforzándose las tareas de prevención, detección y respuesta». Y añade: «se analizarán los riesgos derivados de la **interconexión** del sistema con otros sistemas y se controlará su **punto de unión**».
- **Art. 24 — Registro de actividad y detección de código dañino**: habilita el registro de la actividad de los usuarios «con plenas garantías del derecho al honor, a la intimidad personal y familiar y a la propia imagen», reteniendo **la información estrictamente necesaria**.

DATO CLAVE

El **artículo 23** es la base legal de la seguridad perimetral en la Administración española y **la respuesta correcta** cuando una pregunta pide el precepto que obliga a proteger el perímetro. No confundirlo con `mp.com.1`, que es la **medida** del anexo II que lo desarrolla.

Las medidas del anexo II que este tema necesita. Reproducidas con su denominación literal y su tabla de aplicación:

Medida	Denominación oficial	Dim.	BÁSICA	MEDIA	ALTA
`mp.com.1`	Perímetro seguro	Todas	aplica	aplica	aplica
`mp.com.2`	Protección de la confidencialidad	C	aplica	+ R1	+ R1 + R2 + R3
`mp.com.3`	Protección de la integridad y de la autenticidad	I A	aplica	+ R1 + R2	+ R1 + R2 + R3 + R4
`mp.com.4`	Separación de flujos de información en la red	Todas	**n. a.**	+ [R1 o R2 o R3]	+ [R2 o R3] + R4
`op.mon.1`	Detección de intrusión	Todas	aplica	+ R1	+ R1 + R2
`op.mon.3`	Vigilancia	Todas	aplica	+ R1 + R2	+ R1 … + R6
`op.acc.4`	Proceso de gestión de derechos de acceso	Todas	aplica	aplica	aplica
`op.acc.5`	Mecanismo de autenticación (usuarios externos)	Todas	+ [R1 o R2 o R3 o R4]	+ [R2 o R3 o R4] + R5	+ [R2 o R3 o R4] + R5
`op.exp.6`	Protección frente a código dañino	Todas	aplica	+ R1 + R2	+ R1 + R2 + R3 + R4
`mp.eq.1`	Puesto de trabajo despejado	Todas	aplica	+ R1	+ R1
`mp.eq.2`	Bloqueo de puesto de trabajo	A	**n. a.**	aplica	+ R1
`mp.eq.3`	Protección de dispositivos portátiles	Todas	aplica	aplica	+ R1 + R2
`mp.eq.4`	Otros dispositivos conectados a la red	C	aplica	+ R1	+ R1
`mp.s.3`	Protección de la navegación web	Todas	aplica	aplica	+ R1

Medida	Denominación oficial	Dim.	BÁSICA	MEDIA	ALTA
`mp.s.4`	Protección frente a denegación de servicio	D	**n. a.**	aplica	+ R1
`mp.per.3`	Concienciación	Todas	aplica	aplica	aplica
`mp.per.4`	Formación	Todas	aplica	aplica	aplica

El contenido literal de las tres medidas centrales:

- `mp.com.1` **Perímetro seguro.** «Se dispondrá de un sistema de protección perimetral que **separe la red interna del exterior**. **Todo el tráfico deberá atravesar dicho sistema**» (`mp.com.1.1`). «Todos los flujos de información a través del perímetro deben estar **autorizados previamente**» (`mp.com.1.2`).
- `mp.com.2` **Protección de la confidencialidad.** «Se emplearán **redes privadas virtuales cifradas** cuando la comunicación discurra por **redes fuera del propio dominio de seguridad**» (`mp.com.2.1`). Refuerzos: **R1** algoritmos y parámetros **autorizados por el CCN**; **R2** dispositivos **hardware**; **R3** productos que cumplan `op.pl.5` .
- `mp.com.4` **Separación de flujos.** «El tráfico por la red se segregará para que **cada equipo solamente tenga acceso a la información que necesita**» (`mp.com.4.1`); «Si se emplean **comunicaciones inalámbricas**, será en un **segmento separado**» (`mp.com.4.2`). **R1** = **VLAN**, y exige segregar como mínimo en **usuarios, servicios y administración**; **R2** = **VPN**; **R3** = **medios físicos separados**; **R4** = control en los **puntos de interconexión**.

> DATO CLAVE
>
> Tres cosas de esta tabla que casi nadie sabe. **Primera**: `mp.com.1` (perímetro) **aplica ya en categoría BÁSICA** — no hay sistema del ENS sin perímetro. **Segunda**: `mp.com.4` (segmentación) **no aplica en BÁSICA**; empieza en MEDIA. **Tercera**: `mp.eq.2` (bloqueo del puesto) es de dimensión **autenticidad** y **no aplica en nivel BAJO**; empieza en MEDIO, y en ALTO añade el **cierre de las sesiones abiertas**. La confusión entre «medida de categoría» y «medida de nivel de una dimensión» es la fuente número uno de errores sobre el ENS.

DATO CLAVE

El detalle que distingue a un opositor bien preparado. `mp.com.1` remite a una **«Instrucción Técnica de Seguridad de Interconexión de Sistemas de Información»** que «determinará los requisitos establecidos en el perímetro que han de cumplir todos los componentes del sistema en función de la categoría». **Esa instrucción técnica no está publicada.** A agosto de 2026, las **únicas cuatro ITS** aprobadas y publicadas en el BOE son: **Conformidad con el ENS** e **Informe del Estado de la Seguridad** (ambas de octubre de 2016) y **Auditoría de la Seguridad** y **Notificación de Incidentes de Seguridad** (ambas de 2018). Tampoco están publicadas la de **Criptología** ni la de **Adquisición de productos de seguridad**, aunque el ENS también las anuncia [ITS].

Y las guías del CCN, que es lo que se usa en la práctica. Donde no llega la ITS, llega la serie **CCN-STIC**, de obligada referencia en pliegos y auditorías:

Guía	Contenido	Dónde aparece en este tema
CCN-STIC-408	Seguridad perimetral — cortafuegos	§2.2.1
CCN-STIC-836	Seguridad en VPN en el marco del ENS	§4 completa
CCN-STIC-807	Criptología de empleo en el ENS: algoritmos y parámetros **autorizados por el CCN**	`mp.com.2.r1`, `mp.com.3.r2`
CCN-STIC-105	**Catálogo de Productos y Servicios STIC (CPSTIC)** — productos aprobados y cualificados. Actualizado en **agosto de 2026**	`op.pl.5`, `mp.com.2.r3`
CCN-STIC-140	**Taxonomía** de referencia de productos y servicios de seguridad TIC, con los requisitos fundamentales de seguridad por familia	Selección de cortafuegos, VPN y EDR
Series **500 y 600**	Guías de **bastionado** por tecnología	`op.exp.2`, §5.1

DATO CLAVE

`op.pl.5` **Componentes certificados** obliga, **desde categoría MEDIA** (no aplica en BÁSICA), a utilizar el **CPSTIC** del CCN para seleccionar los productos de terceros que formen parte de la **arquitectura de seguridad** del sistema. En un pliego municipal, esto significa que el cortafuegos, la pasarela VPN o el EDR **deben estar en el catálogo**; y si no existe producto que cubra la funcionalidad, se acude a productos **certificados** conforme al artículo 19.

EJEMPLO DE APLICACIÓN EN EL AYTO

El IAM va a renovar la pasarela VPN por la que teletrabajan los empleados municipales. Con el sistema categorizado **MEDIA**, la lista de obligaciones que hay que escribir en el pliego sale entera de esta sección: `mp.com.2 + R1` (VPN cifrada con algoritmos **autorizados por el CCN**, es decir, conforme a la **CCN-STIC-807**); `mp.com.3 + R1 + R2` (integridad y autenticidad, con VPN y algoritmos autorizados); `op.acc.5 + [R2 o R3 o R4] + R5` (segundo factor obligatorio y registro de accesos con éxito y fallidos); `op.acc.4.5` (política específica de acceso remoto con **autorización expresa**); `op.pl.5` (producto **en el CPSTIC**); y `op.mon.1 + R1` (detección de intrusiones **basada en reglas**). Ninguna de esas seis líneas es una opinión técnica: **todas son texto normativo**.

---

2. Seguridad perimetral

2.1. Concepto y arquitectura del perímetro de seguridad

Definición. El **perímetro de seguridad** es la **frontera lógica** que separa el conjunto de sistemas y redes bajo control de la organización de todo lo que queda fuera de ese control. La **seguridad perimetral** es el conjunto de medidas —tecnológicas, físicas y organizativas— destinadas a **controlar todo lo que cruza esa frontera** en ambos sentidos.

DATO CLAVE

El perímetro no es un dispositivo: es una función. El cortafuegos es el elemento más visible del perímetro, pero el perímetro incluye también el proxy de salida, la pasarela de correo, la pasarela VPN, el IPS, el equilibrador con WAF y la propia política de autorización de flujos. Confundir «perímetro» con «cortafuegos» es el error conceptual básico de esta sección.

Las dos reglas que definen un perímetro bien construido, y que están tomadas literalmente de `mp.com.1`:

1. **Concentración del tráfico**: «Todo el tráfico deberá atravesar dicho sistema». Si existe una salida alternativa —un módem 4G en un equipo, una línea de un proveedor conectada directamente a un servidor, un punto de acceso Wi-Fi doméstico enchufado a una roseta—, **el perímetro no existe**. A esa salida no controlada se la llama *shadow IT* o **camino de derivación**, y es el hallazgo más habitual de una auditoría.
2. **Autorización previa de todos los flujos**: «Todos los flujos de información a través del perímetro deben estar autorizados previamente». Se traduce en la política de **denegación por defecto**.

> DATO CLAVE
>
> **Denegación por defecto** (*default deny*, también llamada **lista blanca**): la última regla del cortafuegos deniega **todo lo que no haya sido autorizado antes**. La política opuesta —**permitir por defecto** y prohibir lo conocido como malo, o **lista negra**— es **incorrecta** en cualquier entorno del ENS, porque obliga a acertar enumerando amenazas, que son infinitas, en lugar de enumerando necesidades, que son finitas.

Las tres zonas clásicas. Un perímetro tradicional divide el mundo en tres:

Zona	Qué contiene	Confianza	Quién puede iniciar conexiones hacia ella
Red externa (internet)	Todo lo no controlado	Ninguna	Cualquiera
DMZ (zona desmilitarizada)	Servicios **publicados**: web, sede electrónica, correo entrante, DNS externo, pasarela VPN	Intermedia	Externa e interna
Red interna	Puestos, servidores internos, bases de datos, directorio	Alta (en el modelo clásico)	**Solo la interna**

La crisis del modelo perimetral. Durante veinte años ese esquema funcionó porque se cumplían tres supuestos: los usuarios estaban dentro del edificio, los datos estaban dentro del CPD y las aplicaciones eran propias. Los tres han saltado:

- El **teletrabajo** saca al usuario fuera del perímetro de forma permanente y masiva.
- La **nube** saca al servicio fuera: la aplicación ya no está en el CPD municipal, sino en el centro de datos de un proveedor.
- Los **dispositivos móviles y el BYOD** meten dentro equipos que no son de la organización.

- La **movilidad lateral** demostró que la premisa «lo de dentro es de fiar» es falsa: un solo puesto comprometido convierte la red interna plana en una autopista para el atacante.

De ahí la evolución en tres etapas que hay que saber contar: **perímetro-muralla** (una sola frontera, interior de confianza) → **perímetro segmentado y defensa en profundidad** (varias fronteras internas, art. 9 del ENS) → **confianza cero** (§2.4.2), donde la frontera se acerca hasta el propio recurso.

> DATO CLAVE
>
> Que el modelo perimetral esté en crisis **no significa que el perímetro haya desaparecido ni que sea opcional**. En España es **obligatorio** por `mp.com.1` en las tres categorías. La formulación correcta es: **el perímetro sigue siendo necesario pero ya no es suficiente**. Toda pregunta que afirme que «la confianza cero sustituye al cortafuegos» es falsa.

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> La red del IAM no tiene **un** perímetro, sino varios anidados: el que separa la red municipal de internet; el que separa la red municipal de las **redes de otras Administraciones** —la red **SARA**, por la que se intercambian datos con la AGE y con la Comunidad de Madrid—; el que separa la **DMZ** donde vive la sede electrónica del CPD interno; y el que separa la red de **puestos de trabajo** de la red de **administración** de los sistemas. Cada uno de esos puntos de unión es, en términos del art. 23 del ENS, una **interconexión** cuyos riesgos hay que analizar y cuyo punto de unión hay que controlar.

2.2. Elementos de filtrado e inspección de tráfico

2.2.1. Cortafuegos de red, estado e inspección de aplicación

Qué es. Un **cortafuegos** (*firewall*) es un sistema —físico, virtual o software— situado entre dos redes que **inspecciona el tráfico que las atraviesa y decide, regla a regla, si lo permite, lo deniega o lo descarta**.

Las cinco generaciones. Conviene tenerla ordenada por **qué capa mira cada una**:

Generación	Capa	Qué examina	Limitación característica
1.ª Filtro de paquetes (*stateless*)	3 y 4	Cada paquete **aislado**: IP origen y destino, protocolo, puertos, banderas	**No recuerda nada**: para permitir el tráfico de vuelta hay que abrir reglas en los dos sentidos, lo que amplía la superficie de exposición
2.ª Con estado (*stateful inspection*)	3 y 4 (+ contexto)	El paquete **y la conexión a la que pertenece**, mediante una **tabla de estados**	No entiende el **contenido**: para él, cualquier cosa por el puerto 443 es «web»
3.ª Pasarela de aplicación (*proxy*)	7	El **contenido** del protocolo; **rompe la conexión en dos**	Coste de proceso, y hay que implementar un proxy **por protocolo**
UTM (*Unified Threat Management*)	3-7	Varias funciones integradas: cortafuegos, IPS, antivirus, filtro web, antispam, VPN	Todo en una caja: **punto único de fallo** y penalización de rendimiento al activarlo todo
NGFW (cortafuegos de nueva generación)	3-7	**Aplicación** e **identidad de usuario**, no solo puerto e IP; integra IPS, antimalware y descifrado TLS	Necesita **descifrar TLS** para ver el contenido, con implicaciones legales y de privacidad

DATO CLAVE

La diferencia entre **filtro de paquetes** y **cortafuegos con estado** es la **tabla de estados** (o tabla de conexiones). El cortafuegos con estado sabe que un paquete de respuesta pertenece a una conexión que **él mismo** vio establecerse, y por eso lo acepta **sin regla explícita de vuelta**. Consecuencia práctica: en un cortafuegos con estado **se escriben las reglas en un solo sentido**. Consecuencia de seguridad: esa tabla es un **recurso finito**, y agotarla es exactamente lo que persigue un **SYN flood**.

Anatomía de una regla. Toda regla, en cualquier fabricante, se compone de los mismos elementos: **origen** (dirección o grupo), **destino**, **servicio** (protocolo y puerto), **acción** y, en los equipos modernos, **usuario**, **aplicación** y **horario**. Y tres detalles operativos:

- **El orden importa**: las reglas se evalúan **de arriba abajo** y **gana la primera que coincide**. Una regla permisiva colocada por encima anula todas las restrictivas que vengan después.

- **Denegar frente a descartar**: **rechazar** (*reject*) responde al origen con un mensaje de error — más cortés, más rápido para el usuario legítimo, pero **confirma al atacante que ahí hay algo**—; **descartar** (*drop*) no responde nada — el origen se queda esperando, lo que ralentiza los escaneos y no revela información. En el perímetro externo, la práctica recomendada es **descartar**.
- **La regla de cierre**: la última debe ser **denegar todo y registrar**. Sin el registro no hay trazabilidad (`op.exp.8`).

EJERCICIO RESUELTO

Problema. Un técnico propone este conjunto de reglas para el cortafuegos que publica la sede electrónica municipal. ¿Qué tres errores tiene?

Nº	Origen	Destino	Servicio	Acción
1	Cualquiera	Cualquiera	ICMP	Permitir
2	Cualquiera	DMZ-web (10.20.0.10)	TCP/443	Permitir
3	DMZ-web (10.20.0.10)	Interna-BD (10.10.0.5)	TCP/1521	Permitir
4	Interna	Cualquiera	Cualquiera	Permitir
5	Cualquiera	Cualquiera	Cualquiera	Denegar

> **Solución**. **Error 1 — la regla 1 es demasiado amplia y está la primera.** Permitir ICMP de cualquiera a cualquiera regala al atacante el mapa de la red (barrido de *ping*, descubrimiento de rutas) y, al estar en primera posición, se evalúa antes que ninguna restricción. Debe limitarse a los tipos ICMP imprescindibles y a orígenes concretos. **Error 2 — la regla 4 rompe el principio de denegación por defecto.** «Interna hacia cualquier sitio y cualquier servicio» es una lista negra encubierta: permite que un equipo comprometido saque datos por cualquier puerto y contacte con su servidor de mando y control. La salida debe ir **forzada a través del proxy** (§2.2.2) y limitada a los servicios necesarios. **Error 3 — la regla 3 está en la dirección prohibida.** Permite que un servidor de la **DMZ** inicie una conexión hacia la **red interna**, que es precisamente lo que la DMZ debe impedir: si comprometen el servidor web, tienen vía directa a la base de datos. Lo correcto es que la conexión la inicie la red interna, o interponer un servicio intermedio en la propia DMZ. Como cuarto apunte: falta el **registro** en la regla 5, y no aparece por ningún lado el **límite de conexiones** que protegería la tabla de estados.

Dónde se coloca y cómo se rompe. Un cortafuegos perimetral es un **punto único de fallo** por diseño: si se cae, o no pasa nada o pasa todo, según se haya configurado. De ahí que en

producción se despliegue en **alta disponibilidad** (par activo-pasivo o activo-activo con sincronización de la tabla de estados). Y de ahí también el ataque que más le duele: el **agotamiento de la tabla de conexiones**, que se mitiga con **cookies SYN**, límites de conexiones por origen y servicios anti-DDoS aguas arriba, en el operador — porque un ataque volumétrico satura **el enlace** antes de llegar al equipo, y ahí ya no hay cortafuegos que valga.

> DATO CLAVE
>
> Contra un **DDoS volumétrico** el cortafuegos propio **no sirve**: cuando el tráfico llega a él, el enlace ya está saturado. La mitigación tiene que ocurrir **aguas arriba**, en el operador o en un servicio de depuración. Esto es lo que respalda `mp.s.4` (**protección frente a la denegación de servicio**), que **no aplica en nivel BAJO** de disponibilidad y **sí desde MEDIO**.

El WAF, que no es un cortafuegos de red. El **cortafuegos de aplicaciones web** (*Web Application Firewall*) se sitúa delante de **una aplicación web concreta** e inspecciona las peticiones HTTP buscando patrones de ataque de la aplicación: inyección SQL, secuencias de comandos entre sitios, recorrido de directorios. Protege **la aplicación**, no la red, y **no sustituye** al desarrollo seguro: es una mitigación, no una corrección.

> DATO CLAVE
>
> `mp.s.2` **Protección de servicios y aplicaciones web** es la medida que ampara el WAF, y tiene una particularidad: **ya en categoría BÁSICA exige** `+ [R1 o R2]`, es decir, alguna forma de refuerzo desde el primer nivel. Es una de las poquísimas medidas del anexo II que no se conforma con «aplica» en la categoría más baja.

2.2.2. Pasarelas de aplicación y servidores proxy de seguridad

Qué es un proxy. Un **servidor intermediario** (*proxy*) es un sistema que **se interpone en una comunicación actuando como servidor para una parte y como cliente para la otra**. Rompe la conexión directa en dos conexiones independientes, y esa ruptura es su valor: **entiende el protocolo** que transporta y puede decidir sobre su contenido.

Los dos sentidos, que es la distinción clave:

	Proxy directo (*forward*)	Proxy inverso (*reverse*)
A quién protege y oculta	A los **clientes internos** que salen a internet	A los **servidores publicados**
Dónde se sitúa	Entre la red interna e internet	Entre internet y la granja de servidores
Quién sabe que existe	El cliente (si es explícito) o nadie (si es transparente)	Nadie: el cliente cree hablar con el servidor final
Funciones típicas	Filtrado de URL y de categorías, control de descargas, caché, autenticación del usuario, registro de navegación	Terminación **TLS**, equilibrado de carga, caché, **WAF**, ocultación de la topología interna
Medida del ENS asociada	`mp.s.3` — protección de la navegación web	`mp.s.2` — protección de servicios y aplicaciones web

DATO CLAVE

Un **proxy inverso** no es un cortafuegos, no es un WAF y no es un equilibrador de carga, aunque en la práctica el mismo aparato haga las tres cosas. Y el error que más se ve: llamar «proxy» solo al directo. En una pregunta de examen, «el elemento que termina el TLS de la sede electrónica y reparte las peticiones entre varios servidores» es un **proxy inverso**, no un cortafuegos.

Qué permite hacer un proxy directo que ningún cortafuegos de red puede hacer. Aquí está la razón de su existencia:

- **Filtrar por URL y por categoría de contenido**, no por dirección IP — que es inútil cuando miles de sitios comparten la misma dirección de una red de distribución de contenidos.
- **Autenticar al usuario** antes de dejarle salir, y por tanto **registrar quién** visitó qué, no solo qué máquina.
- **Analizar el fichero descargado** con antimalware antes de entregarlo.
- **Almacenar en caché** contenidos repetidos y ahorrar ancho de banda.
- **Aplicar cuotas y horarios**.

La inspección del tráfico cifrado, y su límite legal. Hoy más del 95 % del tráfico web va por HTTPS, de modo que un proxy que no descifre solo ve **a qué dominio** se conecta el usuario. Para ver el contenido hay que hacer **ruptura del canal cifrado**: el proxy termina el TLS, inspecciona y vuelve a cifrar hacia el destino, presentando al navegador un certificado emitido por una autoridad interna instalada en los puestos.

DATO CLAVE

La ruptura de canales cifrados **no es una decisión técnica libre: el ENS la regula**. `mp.s.3.r1.2` —refuerzo **R1**, exigible en **categoría ALTA**— dice que «se establecerá una función para la **ruptura de canales cifrados** a fin de inspeccionar su contenido, **indicando qué se analiza, qué se registra, durante cuánto tiempo se retienen los registros y qué uso prevé hacer el organismo** de estas inspecciones», y admite **excepciones** para «destinos de confianza». Junto a ello, `mp.s.3.r1.1` obliga a **registrar la navegación** definiendo elementos, periodo de retención y uso, y `mp.s.3.r1.3` a mantener una **lista negra de destinos vetados**; el refuerzo **R2** va más allá y exige **lista blanca**. En un examen, cualquier respuesta sobre inspección del tráfico del empleado debe mencionar que **hay que informar previamente** y que existen límites de protección de datos y de secreto de las comunicaciones.

Otras pasarelas del perímetro. Junto al proxy web, el perímetro de una Administración incluye habitualmente:

- **Pasarela de correo seguro**: antispam, antimalware, filtrado de adjuntos, comprobación de **SPF, DKIM y DMARC** y aislamiento de enlaces. Es la medida `mp.s.1`, **protección del correo electrónico**, que aplica en las tres categorías.
- **Pasarela de transferencia de ficheros** para intercambios con terceros, en sustitución del FTP abierto.
- **Diodo de datos** o pasarela unidireccional en entornos de máxima exigencia: hardware que **físicamente** solo permite el flujo en un sentido.
- **SOCKS** (RFC **1928**): proxy genérico de nivel de sesión, capaz de tunelizar cualquier protocolo TCP; útil, pero **no inspecciona contenido**, así que como medida de seguridad es débil.

2.3. Sistemas de prevención y detección de intrusiones

La pareja que más se confunde de todo el tema. Un **IDS** (*Intrusion Detection System*, sistema de detección de intrusiones) **observa** el tráfico y **avisa**. Un **IPS** (*Intrusion Prevention System*, sistema de prevención de intrusiones) **se interpone** en el tráfico y **bloquea**. Todo lo demás se deriva de esa única diferencia.

	IDS	IPS
Colocación	**Fuera de línea**, con puerto espejo (*SPAN*) o derivación (*TAP*): recibe una **copia**	**En línea**: el tráfico **pasa a través de él**
Capacidad	Detecta y **alerta**	Detecta y **bloquea, descarta o reinicia** la conexión
Efecto de una avería	Ninguno sobre el servicio: se deja de ver, pero se sigue trabajando	**Puede cortar la red entera** si no tiene *bypass* físico
Efecto de un falso positivo	Una alerta molesta	**Se corta tráfico legítimo**: un servicio público deja de funcionar
Latencia	No introduce	Introduce (analiza antes de reenviar)
Uso típico	Visibilidad, análisis forense, zonas donde no se puede arriesgar el corte	Perímetro y frente a los servicios publicados

Y una segunda clasificación, por **ámbito**: **NIDS/NIPS** (de red, vigilan un segmento) frente a **HIDS/HIPS** (de máquina, vigilan un servidor concreto: sus registros, la integridad de sus ficheros, sus procesos). Los dos son complementarios: el de red ve la propagación, el de máquina ve lo que ocurre dentro del servidor y **ve el tráfico ya descifrado**.

> DATO CLAVE
>
> Regla mnemotécnica infalible: **«IDS = espejo; IPS = camino»**. Si el tráfico **puede seguir circulando aunque el aparato esté apagado**, es un IDS. Si **el aparato apagado deja la red sin comunicación** (salvo que tenga derivación automática), es un IPS.

Los dos métodos de detección. También van en pareja:

- **Detección por firmas** (o **basada en conocimiento**): compara el tráfico con un catálogo de patrones de ataques conocidos. **Muy precisa**, con **pocos falsos positivos**, pero **ciega ante lo desconocido**: no detecta un **ataque de día cero** ni una variante nueva. Depende de que las firmas estén actualizadas.
- **Detección por anomalías** (o **basada en comportamiento**): construye una **línea base** de lo que es normal —volúmenes, horarios, protocolos, destinos— y alerta de las desviaciones. **Puede detectar lo desconocido**, pero genera **más falsos positivos** y exige un periodo de aprendizaje; además, si el sistema aprende con la red ya comprometida, **aprende que el ataque es normal**.

En la práctica todos los productos combinan ambos, y añaden **detección basada en reputación** (listas de direcciones y dominios maliciosos) y **análisis de comportamiento con aprendizaje automático**.

Los cuatro resultados posibles, que es la matriz que hay que saber leer:

	Hay ataque	No hay ataque
El sistema alerta	**Verdadero positivo** — funciona	**Falso positivo** — ruido; en un IPS, **corte de servicio legítimo**
El sistema calla	**Falso negativo** — el peor: intrusión no detectada	**Verdadero negativo** — normalidad

EJERCICIO RESUELTO

Problema. El IPS que protege la sede electrónica municipal genera unas 40.000 alertas al mes. El equipo estima que un **1 %** son verdaderos positivos. Se propone «subir la sensibilidad» para no perderse ningún ataque. ¿Es acertado y qué efecto tiene sobre el servicio? **Solución**. No es acertado tal cual, y por dos razones. **Primera, la aritmética**: 40.000 alertas al mes son unas 1.300 al día; con un 1 % de aciertos, el equipo revisa 1.287 falsas alarmas para encontrar 13 reales. Subir la sensibilidad **aumenta los verdaderos positivos y los falsos positivos a la vez**, y el cuello de botella no es la detección, es la **capacidad de análisis**: más alertas significa que **se atenderán peor**, con lo que en la práctica **bajará** la tasa de detección efectiva. Es la llamada **fatiga de alertas**. **Segunda, y crítica en un IPS**: como está **en línea**, cada falso positivo adicional es **tráfico legítimo cortado**; en un servicio público eso significa ciudadanos que no pueden presentar una solicitud, con el consiguiente impacto en **disponibilidad** y posibles efectos sobre plazos administrativos. Lo correcto es el camino inverso: **afinar** (*tuning*) las firmas al entorno real, desactivar las que no aplican a la tecnología desplegada, poner en modo **solo detección** las dudosas, agrupar y **correlacionar** en un SIEM (`op.mon.3.r1`) y definir **procedimientos de respuesta** a las alertas —que es exactamente lo que exige `op.mon.1.r2` , el refuerzo **R2**, en categoría **ALTA**.

El encaje normativo, que es lo que convierte esto en respuesta de oposición.

DATO CLAVE

`op.mon.1` **Detección de intrusión**: «Se dispondrá de **herramientas de detección o prevención de intrusiones**» — y **aplica ya en categoría BÁSICA**. **MEDIA** añade **R1**: detección **basada en reglas**. **ALTA** añade **R2**: **procedimientos de respuesta** a las alertas. Existe además un **R3** —acciones **automáticas** predeterminadas: terminar el proceso, deshabilitar servicios, desconectar usuarios, bloquear cuentas— que la tabla no exige ni siquiera en ALTA. Y `op.mon.3` **Vigilancia**: recolección **automática** de eventos en BÁSICA; **R1 correlación** —el **SIEM**— y **R2 análisis dinámico** de la superficie de exposición en MEDIA; en ALTA, hasta **R6**, incluyendo detección de **APT** por anomalías de tráfico (`op.mon.3.r3.2`) y **observatorios digitales** (R4).

Dónde acaba el IDS/IPS y empieza el resto. Tres siglas que conviene distinguir para no mezclarlas:

- **SIEM** (*Security Information and Event Management*): **recoge y correlaciona** eventos de todas las fuentes —cortafuegos, IPS, servidores, aplicaciones, EDR— y genera alertas de segundo nivel. Es la traducción tecnológica de `op.mon.3.r1` .
- **SOAR** (*Security Orchestration, Automation and Response*): **automatiza la respuesta** a esas alertas mediante manuales de actuación.
- **SOC** (*Security Operations Center*): el **equipo humano** que opera todo lo anterior, en turnos. Ninguna herramienta lo sustituye.
- **Honeypot** o señuelo: sistema falso, deliberadamente atractivo, cuya única función es que **cualquier interacción con él sea, por definición, sospechosa**. Aporta detección con tasa de falsos positivos prácticamente nula.

EJEMPLO DE APLICACIÓN EN EL AYTO

En un ayuntamiento, el punto de mayor rentabilidad de un IDS no es el perímetro externo —donde el ruido de internet es inmenso— sino el **tráfico entre segmentos internos**: entre la red de puestos de las oficinas de distrito y la red de servidores del CPD. Ahí, un equipo de una oficina que de pronto intenta abrir sesiones SMB contra doscientos servidores no es «ruido de internet»: es **movimiento lateral**, y es la señal más temprana y más fiable de un ransomware en curso. Es también el argumento que justifica la inversión en `mp.com.4` ante quien pregunte para qué sirve segmentar.

2.4. Segmentación de redes y gestión de zonas de seguridad

2.4.1. Redes desmilitarizadas y subredes internas

Por qué existe la DMZ. Un servicio publicado a internet es, por definición, **alcanzable por cualquiera**, y por tanto es el candidato número uno a ser comprometido. Si ese servicio vive en la

red interna, comprometerlo equivale a estar dentro. La **DMZ** resuelve el dilema colocándolo en una **tercera zona**, accesible desde fuera pero **sin capacidad de iniciar conexiones hacia dentro**.

> DATO CLAVE
>
> **La regla que define una DMZ**: desde la DMZ **no se puede iniciar** ninguna conexión hacia la red interna; desde la red interna **sí** se puede iniciar hacia la DMZ. Si un servidor de la DMZ necesita un dato de la red interna, la conexión debe **originarse en la interna**, o hacerse a través de un elemento intermedio situado en la propia DMZ. Una DMZ desde la que el servidor web abre sesiones contra la base de datos interna **no es una DMZ**: es una red interna con otro nombre.

Las dos arquitecturas clásicas:

- **Cortafuegos de tres patas** (*three-legged*): un solo equipo con **tres interfaces** —exterior, DMZ e interior— y una política que gobierna los seis sentidos posibles. Ventaja: **más sencillo y más barato**, política única. Inconveniente: **un solo dispositivo** y, por tanto, un solo fallo o un solo error de configuración separando internet de la red interna.
- **Doble cortafuegos** (*screened subnet*, subred apantallada): **dos cortafuegos en serie**, con la DMZ en medio. El exterior filtra de internet a la DMZ; el interior, de la DMZ a la red interna. Ventaja: **defensa en profundidad real**, sobre todo si los dos equipos son **de fabricantes distintos**, porque una vulnerabilidad del primero no afecta al segundo. Inconveniente: coste y complejidad de gestión.

Y la segmentación interna, que es donde está hoy el valor. Poner una DMZ y dejar la red interna **plana** —un único gran segmento donde todo se ve con todo— es el diseño que ha hecho posible casi todos los grandes incidentes de ransomware de la última década. La segmentación interna divide esa red por **zonas de seguridad**, y cada frontera entre zonas es un punto de control.

Criterios de segmentación, de mayor a menor granularidad:

1. **Por función**: usuarios, servidores, administración, impresión, voz, videovigilancia, control industrial, invitados, IoT. Es el mínimo que exige `mp.com.4.r1.2`: **usuarios, servicios y administración**.
2. **Por criticidad o categoría ENS**: no mezclar en el mismo segmento sistemas de categoría ALTA con sistemas de categoría BÁSICA.
3. **Por unidad organizativa o emplazamiento**: cada distrito, cada organismo autónomo.
4. **Microsegmentación**: la política se aplica **por carga de trabajo** —máquina virtual o contenedor—, no por subred; cada servidor solo habla con los que necesita. Es la implementación práctica de la confianza cero dentro del CPD.

Con qué se implementa:

Mecanismo	Nivel	Qué aísla	Refuerzo ENS
VLAN (IEEE 802.1Q)	2	Dominios de difusión dentro del mismo conmutador o campus	`mp.com.4.r1`
VRF y encaminamiento separado	3	Tablas de encaminamiento independientes	`mp.com.4.r1`
VPN entre segmentos	3	Segmentos unidos por canal cifrado	`mp.com.4.r2`
Separación física	1	Cables y equipos distintos: no hay camino posible	`mp.com.4.r3`
VXLAN (RFC 7348) y redes definidas por software	2 sobre 3	Segmentos superpuestos sobre una red IP, típico de CPD virtualizado	—
Microsegmentación por cortafuegos distribuido	3-7	Carga de trabajo individual	`mp.com.4.r4`

DATO CLAVE

Los cuatro refuerzos de `mp.com.4` en orden: **R1 segmentación lógica básica** (VLAN, y mínimo tres subredes: usuarios, servicios, administración) · **R2 segmentación lógica avanzada** (**VPN**) · **R3 segmentación física** (medios separados) · **R4 puntos de interconexión** (control de entrada de usuarios y de entrada y salida de información en cada segmento, con el punto de unión «particularmente asegurado, mantenido y monitorizado»). Aplicación: **MEDIA =** `+ [R1 o R2 o R3]` ; **ALTA =** `+ [R2 o R3] + R4` — es decir, en categoría ALTA **la VLAN sola ya no basta**.

EJEMPLO DE APLICACIÓN EN EL AYTO

Una oficina de atención a la ciudadanía de un distrito tiene, en el mismo armario, los puestos de los tramitadores, una impresora multifunción en red, dos pantallas de gestión de turnos, las cámaras de videovigilancia y un punto de acceso Wi-Fi para el público. Si todo comparte segmento, la cámara —un dispositivo IoT que probablemente nunca se ha parcheado— y el Wi-Fi público son la puerta de entrada a los puestos de tramitación. El ENS obliga a separar: `mp.com.4.2` saca **el Wi-Fi a un segmento propio**; `mp.com.4.r1.2` exige separar **usuarios de servicios y de administración**; y `mp.eq.4` alcanza expresamente a **impresoras, dispositivos multimedia, IoT y BYOD**, exigiéndoles configuración de seguridad adecuada, y en nivel MEDIO de confidencialidad, productos del **CPSTIC**.

2.4.2. Modelo de seguridad de confianza cero

Qué es. La **confianza cero** (*Zero Trust*) es un modelo de arquitectura de seguridad que **elimina la confianza implícita basada en la ubicación en la red**. Su formulación de referencia es la **NIST SP 800-207**, *Zero Trust Architecture*, de **agosto de 2020** [NIST-ZT]. La frase que lo resume: **«nunca confíes, verifica siempre»**.

Dicho de otro modo: en el modelo clásico, estar dentro de la red daba derecho a intentar hablar con todo; en confianza cero, **estar dentro no da ningún derecho**, y cada acceso a cada recurso se autentica, se autoriza y se registra **por separado y por sesión**.

Los siete principios de la NIST SP 800-207:

1. **Todas** las fuentes de datos y servicios de computación se consideran **recursos**.
2. **Toda** comunicación se protege **con independencia de la ubicación en la red** — también la comunicación interna.
3. El acceso a un recurso se concede **por sesión**, de una en una.
4. El acceso se determina mediante **política dinámica**: identidad del cliente, aplicación o servicio, estado del dispositivo solicitante y otros atributos de comportamiento y de entorno.
5. La organización **mide y vigila la integridad y el estado de seguridad** de todos sus activos: no hay activo de confianza permanente.
6. La autenticación y la autorización son **dinámicas y estrictamente exigidas antes** de permitir el acceso.
7. La organización **recopila toda la información posible** sobre el estado de sus activos, su infraestructura y sus comunicaciones, **y la usa para mejorar** su política de seguridad.

Los componentes lógicos:

- **Motor de Políticas** (*Policy Engine*, **PE**): decide **si** se concede el acceso, aplicando la política y las fuentes de información externas (identidad, cumplimiento del dispositivo, inteligencia de amenazas).
- **Administrador de Políticas** (*Policy Administrator*, **PA**): ejecuta la decisión, estableciendo o cortando el canal.
- Ambos forman el **punto de decisión de política** (**PDP**).
- **Punto de Aplicación de Políticas** (*Policy Enforcement Point*, **PEP**): el elemento que **deja pasar o no** — pasarela, agente en el puesto, proxy de aplicación. Es el único que está en el camino del tráfico.

DATO CLAVE

La separación **PDP / PEP** —quién **decide** frente a quién **ejecuta**— es el núcleo del modelo y lo que permite que la decisión sea **dinámica**: el PEP pregunta cada vez, en lugar de aplicar una regla estática escrita hace dos años. Y el segundo dato: el acceso se concede **por sesión** y **se reevalúa**; no existe la sesión indefinidamente confiable.

Cómo se materializa. En la práctica, una arquitectura de confianza cero se apoya en cuatro piezas que ya se han visto en este tema: **identidad fuerte** con MFA (§3.2), **evaluación del estado del dispositivo** —cifrado activo, parches al día, EDR funcionando (§5)—, **microsegmentación** (§2.4.1) y **acceso a la aplicación en lugar de acceso a la red**, que es lo que se conoce como **ZTNA** (*Zero Trust Network Access*) y que se compara con la VPN clásica en §4.1.2. Cuando esas funciones se consumen como servicio en la nube junto con la conectividad, la industria lo llama **SASE** (*Secure Access Service Edge*); conviene saber que **SASE y ZTNA son términos de mercado, no estándares**, a diferencia de la SP 800-207.

DATO CLAVE

Lo que la confianza cero no es: no es un producto que se compre, no elimina el cortafuegos, no elimina la VPN por decreto y no es incompatible con el ENS. Es un **modelo de arquitectura** que se implanta por fases y que **refuerza** las medidas del ENS: `op.acc.4` (todo acceso prohibido salvo autorización expresa, mínimo privilegio, necesidad de conocer) y `mp.com.4` (segmentación) son, leídas hoy, principios de confianza cero escritos en 2022.

RELACIÓN CON OTROS TEMAS

La **virtualización de servidores y del puesto de trabajo**, sobre la que se apoya la microsegmentación del CPD, se estudia en el **Tema 28**. La **administración de la red de área local**, los conmutadores y la monitorización del tráfico, en el **Tema 30**. Los **servicios en la nube** y sus modelos de responsabilidad compartida, en el **Tema 31**.

---

3. Acceso remoto seguro a redes

3.1. Requisitos y arquitectura de acceso remoto en el ámbito público

El problema, planteado con precisión. El acceso remoto consiste en permitir que un usuario o un sistema situado **fuera** del perímetro utilice recursos situados **dentro**. Es, por definición, **una excepción autorizada al principio de** `mp.com.1` : se abre deliberadamente un camino a través del perímetro. De ahí que todo el diseño gire en torno a una idea: **el camino se abre para una identidad concreta, hacia unos recursos concretos, por un canal protegido y bajo registro**.

Los casos de uso no son solo el teletrabajo:

- **Teletrabajo** del empleado público desde su domicilio.
- **Movilidad**: el mismo empleado desde una sede ajena, un juzgado o una reunión.
- **Administración remota** de servidores y equipos de red por el propio personal técnico.
- **Acceso de proveedores** para mantenimiento — el escenario de mayor riesgo, porque el equipo del proveedor **no está bajo control de la organización**.
- **Interconexión con otras Administraciones**, que técnicamente es acceso remoto entre organizaciones.

> DATO CLAVE
>
> La medida del ENS que hay que citar **siempre** en una pregunta de acceso remoto es `op.acc.4.5` : «Se establecerá una **política específica de acceso remoto**, requiriéndose **autorización expresa**». Está dentro de `op.acc.4` (proceso de gestión de derechos de acceso), que **aplica en las tres categorías** —BÁSICA, MEDIA y ALTA— y que contiene además los cuatro principios que ordenan toda la sección: **todo acceso prohibido salvo autorización expresa** (`op.acc.4.1`), **mínimo privilegio** (`op.acc.4.2`), **necesidad de conocer y responsabilidad de compartir** (`op.acc.4.3`) y **capacidad de autorizar** reservada a quien tenga competencia, con **revisión periódica** de los permisos (`op.acc.4.4`).

La segunda medida imprescindible, y la que más se olvida:

> DATO CLAVE
>
> `mp.eq.3.3` : «Cuando un dispositivo portátil se conecte remotamente a través de **redes que no están bajo el estricto control de la organización**, el ámbito de operación del servidor **limitará la información y los servicios accesibles a los mínimos imprescindibles**, requiriendo **autorización previa de los responsables** de la información y los servicios afectados. Este punto es de aplicación a conexiones a través de **internet y otras redes que no sean de confianza**». Traducción operativa: **el teletrabajador no debe ver la misma red que si estuviera en la oficina**. Y `mp.eq.3.4` añade: «Se evitará, en la medida de lo posible, que el dispositivo portátil **contenga claves de acceso remoto** a la organización que no sean imprescindibles».

La base legal del teletrabajo público. No es una decisión organizativa libre: tiene norma propia.

DATO CLAVE

El **artículo 47 bis del TREBEP** (texto refundido del Estatuto Básico del Empleado Público), introducido por el **Real Decreto-ley 29/2020, de 29 de septiembre**, regula el teletrabajo en las Administraciones Públicas. Sus notas esenciales: se presta **fuera de las dependencias** de la Administración **mediante el uso de tecnologías de la información y la comunicación**; ha de ser **expresamente autorizado**; es **compatible con la modalidad presencial**; tiene **carácter voluntario y reversible**; y **«la Administración proporcionará a la persona los medios tecnológicos necesarios»**. Ese último inciso es el fundamento jurídico de que el equipo de teletrabajo sea **corporativo y gestionado**, no personal [TREBEP].

Los siete requisitos de una arquitectura de acceso remoto, que es el esqueleto de respuesta que conviene memorizar:

1. **Identificación y autenticación fuerte** del usuario, con **MFA** (§3.2.1).
2. **Canal cifrado** de extremo a extremo entre el dispositivo y la organización — la **VPN** de §4, exigida por `mp.com.2.1`.
3. **Comprobación del estado del dispositivo** antes de conceder acceso (*posture check*): que sea un equipo corporativo conocido, cifrado, parcheado y con el antimalware activo.
4. **Autorización mínima**: acceso solo a los servicios necesarios para el puesto, aplicando `mp.eq.3.3`.
5. **Registro y trazabilidad**: quién entró, cuándo, desde dónde y a qué accedió (`op.exp.8`, y `op.acc.5.r5` para accesos con éxito y fallidos).
6. **Control de sesión**: caducidad por inactividad, cierre de sesión, número máximo de sesiones simultáneas.
7. **Procedimiento de revocación inmediata** cuando el empleado cesa, cambia de puesto o pierde el equipo (`op.acc.5.6`, `mp.eq.3.2`).

La arquitectura, de fuera adentro. Un acceso remoto bien construido en una Administración recorre esta secuencia:

1. El **portátil corporativo** arranca con **disco cifrado** y el usuario se autentica en el equipo.
2. El **cliente VPN** se conecta a la **pasarela**, situada en la **DMZ** —nunca en la red interna—, y publicada únicamente por los puertos estrictamente necesarios.
3. La pasarela exige **el segundo factor** y consulta al servidor **AAA** (§3.2.2), que a su vez consulta el **directorio corporativo**.
4. Se comprueba el **estado del dispositivo**; si no cumple, se deniega o se envía a una **red de cuarentena** para remediación.
5. Concedido el acceso, el usuario **no entra en «la red»**: entra en un **segmento de teletrabajo** con reglas propias, desde el que solo alcanza los servicios autorizados.

6. Todo queda **registrado** y se envía al SIEM.

> **DATO CLAVE**
>
> La pasarela de acceso remoto **se coloca en la DMZ**, no en la red interna, y se publica con la superficie mínima. Un servicio de **escritorio remoto (RDP, TCP/UDP 3389)** publicado directamente a internet es la causa documentada de una parte muy importante de los incidentes de **ransomware**: se ataca por fuerza bruta o con credenciales robadas y se entra directamente en el escritorio de un servidor. La regla es rotunda: **RDP nunca se publica a internet**; se accede a él **a través de la VPN** o de una **pasarela de escritorio remoto** con MFA.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> Supongamos 900 empleados municipales autorizados a teletrabajar dos días por semana. El diseño correcto **no** es «una VPN que les mete en la red de la oficina», sino un **segmento de teletrabajo** propio, con su propia política: desde él se alcanza el gestor de expedientes, el correo, la intranet y la impresión en cola, y **no** se alcanzan la red de administración de sistemas, la de videovigilancia ni los puestos de otros compañeros. Si un portátil se infecta en el domicilio, el daño queda acotado a lo que ese segmento puede tocar. Eso es `mp.eq.3.3` y `mp.com.4` trabajando juntos, y es también, sin necesidad de comprar nada nuevo, una arquitectura de **confianza cero** en su primer escalón.

3.2. Control de acceso, identificación y autenticación

Cuatro conceptos que hay que separar. Se usan como sinónimos en el lenguaje corriente, pero son distintos:

- **Identificación**: el sujeto **declara quién es** (usuario, DNI electrónico, número de empleado). Es una afirmación, todavía no probada. El ENS la regula en `op.acc.1` y exige **identificador único** y **cuentas nominales**.
- **Autenticación**: el sujeto **prueba** que es quien dice ser, aportando uno o varios **factores**. `op.acc.5` y `op.acc.6`.
- **Autorización**: el sistema decide **qué puede hacer** ese sujeto ya autenticado. `op.acc.2` y `op.acc.4`.
- **Trazabilidad o auditoría**: se **registra** lo que hizo, para poder atribuírselo después. `op.exp.8`.

DATO CLAVE

`op.acc.1.3` exige que **cada entidad** —persona, equipo o proceso— cuente con **un identificador singular**, y `op.acc.1.4` regula el ciclo de vida de las cuentas. La consecuencia práctica más importante: **las cuentas genéricas o compartidas están prohibidas**, porque destruyen la **trazabilidad**: si tres personas usan «admin», ninguna acción es atribuible a nadie. Y `op.acc.1.2` añade que, cuando un usuario tenga **distintos roles**, se usarán **identificadores diferentes** para cada uno: el administrador no administra con su cuenta ofimática.

Los modelos de control de acceso:

Modelo	Siglas	Cómo decide	Uso típico
Discrecional	**DAC**	El **propietario** del recurso decide quién accede	Permisos de ficheros en un sistema operativo
Obligatorio	**MAC**	Una **política central** con etiquetas de clasificación; el usuario no puede alterarla	Entornos de información clasificada
Basado en roles	**RBAC**	Los permisos se asignan al **rol**, y las personas se asignan a roles	El estándar en la Administración: «tramitador», «jefe de sección», «administrador»
Basado en atributos	**ABAC**	Reglas que combinan atributos de sujeto, recurso, acción y **contexto** (hora, ubicación, estado del dispositivo)	**Confianza cero** y políticas dinámicas

DATO CLAVE

RBAC es el modelo natural de una Administración porque **encaja con la relación de puestos de trabajo**: el permiso se ata al puesto, no a la persona, y así el cambio de destino de un empleado se resuelve cambiándolo de rol. **ABAC** es el modelo que exige la confianza cero, porque permite decidir con **contexto** (`op.acc` no lo nombra, pero el principio 4 de la NIST SP 800-207 lo describe exactamente).

3.2.1. Autenticación multifactor y uso de certificados digitales

Los tres factores. Un **factor de autenticación** es una categoría de prueba, y solo hay tres:

Factor	Categoría	Ejemplos	Debilidad característica
Algo que se sabe	Conocimiento	Contraseña, PIN, respuesta a pregunta	Se adivina, se reutiliza, se **phishea**, se filtra en brechas de terceros
Algo que se tiene	Posesión	Tarjeta criptográfica, token OTP, móvil con aplicación autenticadora, llave FIDO2, certificado en dispositivo	Se pierde, se roba, se puede **clonar** si no hay hardware seguro
Algo que se es	Inherencia	Huella, iris, geometría facial o de la mano, voz	**No se puede cambiar** si se compromete; tasas de falsa aceptación y falso rechazo

DATO CLAVE

Autenticación multifactor (MFA) exige **dos o más factores de categorías distintas**. Contraseña **+ PIN** no es MFA: los dos son «algo que se sabe». Contraseña **+ código enviado al móvil** sí lo es. Y un matiz: la **ubicación** («algo donde se está») y el **comportamiento** («algo que se hace») se citan a veces como cuarto y quinto factor, pero **no son factores en sentido estricto**: son **atributos de contexto** que refuerzan la decisión, no pruebas de identidad.

Los mecanismos, ordenados por robustez creciente, que es como los ordena el propio ENS:

1. **Contraseña sola**: es el refuerzo **R1** de `op.acc.5`, y solo se admite en **nivel BAJO**. Exige normas de **complejidad mínima y robustez frente a ataques de adivinación**.
2. **Contraseña de un solo uso (OTP)**: refuerzo **R2**. Puede ser por aplicación autenticadora basada en tiempo, por token físico o por SMS — siendo el SMS el más débil de los tres, por el riesgo de duplicado fraudulento de la tarjeta SIM.
3. **Certificado cualificado con segundo factor**: refuerzos **R3** y **R4**. El ENS es explícito: «Se emplearán **certificados cualificados**… El uso del certificado **estará protegido por un segundo factor**», y las credenciales deben haberse obtenido tras un **registro previo** presencial o equivalente.
4. **Llaves de seguridad FIDO2 y claves de acceso** (*passkeys*): criptografía asimétrica ligada al dominio, **resistentes al phishing** por diseño, porque la llave no responde a un dominio que no sea el legítimo. Es la tendencia actual y el camino hacia la autenticación **sin contraseña**.

DATO CLAVE

La tabla de aplicación de `op.acc.5` hay que sabérsela: **BAJO** = `op.acc.5 + [R1 o R2 o R3 o R4]` ; **MEDIO** = `op.acc.5 + [R2 o R3 o R4] + R5` ; **ALTO** = igual que MEDIO. Lo que dice esa tabla, en castellano: **a partir de nivel MEDIO desaparece la opción R1**, es decir, **la contraseña sola deja de ser suficiente**, y se hace obligatorio el **R5**, que exige **registrar los accesos con éxito y los fallidos** e **informar al usuario de su último acceso**. Junto a ello, `op.acc.5.8` obliga a **limitar el número de intentos** y bloquear.

Los certificados digitales en el acceso remoto. Un certificado X.509 vincula una **identidad** con una **clave pública**, avalado por una **autoridad de certificación**. En el acceso remoto se usa en tres papeles distintos, y confundirlos es error frecuente:

- **Certificado de servidor**: autentica **la pasarela** ante el cliente, para que el usuario sepa que se conecta a la VPN legítima y no a una impostora.
- **Certificado de cliente o de usuario**: autentica **a la persona**. En la Administración española es el terreno del **DNI electrónico** y de los certificados de la **FNMT-RCM**, y en el ámbito de empleado público, del **certificado de empleado público** previsto en la Ley 40/2015.
- **Certificado de dispositivo o de máquina**: autentica **el equipo**, con independencia de quién lo use. Es la pieza que permite exigir que la conexión venga **de un portátil corporativo** y no de un equipo doméstico con las mismas credenciales.

DATO CLAVE

La combinación **certificado de dispositivo + certificado o credencial de usuario + segundo factor** es la respuesta técnicamente completa a «cómo se garantiza que quien entra por la VPN es un empleado autorizado desde un equipo corporativo». El certificado de dispositivo responde a **desde dónde**; el de usuario, a **quién**; el segundo factor, a que la credencial no ha sido simplemente copiada. El marco jurídico europeo de los certificados es el **Reglamento eIDAS**, modificado por el **Reglamento (UE) 2024/1183** que crea el **marco europeo de identidad digital** y la **cartera digital** (*wallet*).

EJERCICIO RESUELTO

Problema. Un organismo municipal categorizado **MEDIA** permite el teletrabajo con usuario y contraseña robusta —doce caracteres, cambio cada 90 días— sobre una VPN cifrada. ¿Cumple el ENS? Si no, ¿cuál es el mínimo que hay que añadir? **Solución**. **No cumple.** El canal está bien — `mp.com.2.1` exige VPN cifrada y la hay—, pero la autenticación no. Con el sistema en categoría MEDIA, sus dimensiones son al menos de nivel MEDIO, y `op.acc.5` en nivel MEDIO exige `+ [R2 o R3 o R4] + R5` : la opción **R1 (contraseña)** ya no está disponible, por robusta que sea. El **mínimo** para cumplir es añadir **un segundo factor** de la lista **R2** (contraseña de un solo uso) o **R3/R4** (certificado cualificado protegido por segundo factor), **más R5**: registro de accesos con éxito **y fallidos** e información al usuario de su último acceso. Y hay que añadir dos cosas que la pregunta no menciona pero que el ENS exige igualmente: la **política específica de acceso remoto con autorización expresa** (`op.acc.4.5`) y la **limitación del ámbito accesible** al mínimo imprescindible (`mp.eq.3.3`). Obsérvese el matiz: **la longitud de la contraseña es irrelevante para la conformidad**; lo que la norma exige es un **segundo factor**.

3.2.2. Servidores de autenticación, autorización y auditoría

Qué es AAA. Cuando cientos de dispositivos —conmutadores, puntos de acceso, pasarelas VPN, encaminadores— tienen que autenticar a miles de usuarios, no se pueden guardar las credenciales en cada uno. Se **centraliza** en un servidor **AAA**, que presta tres servicios:

- **Autenticación** (*Authentication*): ¿eres quien dices ser?
- **Autorización** (*Authorization*): ¿qué se te permite hacer? Qué VLAN se te asigna, a qué comandos accedes, qué perfil se te aplica.
- **Contabilidad y auditoría** (*Accounting*): registro de la sesión — cuándo empezó, cuánto duró, cuánto tráfico, qué comandos ejecutó. Es lo que da **trazabilidad**.

Los tres protocolos, comparados:

	RADIUS	TACACS+	Diameter
Norma	RFC **2865** (autenticación) y **2866** (contabilidad)	RFC **8907** (informativo)	RFC **6733**
Transporte y puertos	**UDP 1812** (autenticación) y **1813** (contabilidad); históricamente 1645/1646	**TCP 49**	**TCP** o **SCTP**, con TLS/DTLS
Qué cifra	**Solo el campo de la contraseña**; el resto viaja en claro	**Todo el cuerpo** del paquete	**Todo**, con TLS/DTLS
Separación de las tres A	**No**: autenticación y autorización van **juntas**	**Sí**: las tres son independientes	Sí
Origen y uso típico	Estándar IETF, multifabricante: **802.1X**, Wi-Fi corporativa, **VPN**	Origen Cisco: **administración de equipos de red**, control de comandos por usuario	Redes de operador, 4G/5G, IMS
Fiabilidad del transporte	UDP: sin garantía, requiere reintentos	TCP: entrega garantizada	TCP/SCTP

DATO CLAVE

Las **tres diferencias** entre RADIUS y TACACS+: **transporte** (UDP frente a TCP), **qué se cifra** (solo la contraseña frente a todo el cuerpo) y **separación de las tres A** (RADIUS junta autenticación y autorización; TACACS+ las separa). De ahí el reparto de papeles en la práctica: **RADIUS para el acceso de usuarios a la red** (Wi-Fi, 802.1X, VPN) y **TACACS+ para la administración de los equipos de red**, donde interesa autorizar **comando a comando** y registrar cada uno.

DATO CLAVE

Dos novedades verificadas contra el índice del RFC Editor, que casi ningún temario recoge. Primera: **TACACS+ sobre TLS 1.3** está normalizado en el **RFC 9887**, de **diciembre de 2025**, que actualiza el RFC 8907 y resuelve la debilidad histórica del protocolo —su cifrado propio, basado en MD5, nunca fue considerado sólido—. Segunda: **RADIUS/1.1**, en el **RFC 9765**, de **abril de 2025**, elimina el uso de **MD5** apoyándose en la negociación **ALPN** de TLS; su estado es **Experimental**. Antes de ellos, la única forma de proteger RADIUS eran **RadSec** sobre TLS (RFC 6614) o sobre DTLS (RFC 7360), ambos **experimentales**.

802.1X: control de acceso a la red basado en puerto. Es el mecanismo que impide que un equipo desconocido obtenga conectividad por el mero hecho de enchufarse. Tiene **tres actores**:

1. **Suplicante** (*supplicant*): el software del equipo que se quiere conectar.
2. **Autenticador** (*authenticator*): el **conmutador** o el **punto de acceso**. No decide nada: **transporta** el diálogo y aplica el resultado.
3. **Servidor de autenticación**: normalmente **RADIUS**, que es quien decide.

El diálogo viaja en **EAP** (*Extensible Authentication Protocol*, RFC **3748**), encapsulado como **EAPOL** entre suplicante y autenticador, y dentro de RADIUS entre autenticador y servidor. Hasta que la autenticación tiene éxito, el puerto está en estado **no autorizado** y **solo deja pasar EAPOL**: ni siquiera se obtiene dirección IP.

Los métodos EAP que hay que saber nombrar:

Método	Autenticación del cliente	Nota
EAP-TLS	**Certificado** en cliente **y** servidor	El **más robusto**; RFC **5216**, actualizado por el **RFC 9190** para TLS 1.3. Exige PKI
PEAP	Contraseña dentro de un túnel TLS que autentica solo al servidor	Muy extendido; hereda la debilidad de la contraseña
EAP-TTLS	Similar a PEAP, con más flexibilidad en el método interno	—
EAP-MD5	Reto-respuesta con resumen	**Obsoleto e inseguro**: sin cifrado ni autenticación mutua

DATO CLAVE

Una de las funciones más útiles de 802.1X: el servidor RADIUS puede devolver al conmutador, junto con el «acceso concedido», **el identificador de la VLAN** que debe asignar al puerto. Eso permite **asignación dinámica de VLAN**: el mismo cable coloca al empleado en la red de usuarios, al portátil de un proveedor en la de invitados y al equipo que no supera la comprobación de estado en una **VLAN de cuarentena**. Es segmentación (`mp.com.4`) **decidida por identidad**, no por topología.

3.3. Protocolos y servicios para la gestión remota segura

La regla general. La administración remota de sistemas es el acceso de **mayor privilegio** que existe en una organización, y por eso concentra los requisitos más estrictos: cuenta nominal distinta de la ordinaria (`op.acc.1.2`), MFA, origen restringido a **equipos y emplazamientos autorizados** —lo dice el art. 20.b del ENS, que permite exigir incluso **restricciones de horario y puntos de acceso**—, canal cifrado y **registro de todo lo ejecutado**.

SSH: el protocolo de referencia. *Secure Shell* sustituyó a Telnet, rlogin y rsh, que transmitían **las credenciales en claro**. Su arquitectura, definida en los **RFC 4251 a 4254**, tiene **tres capas**:

1. **Capa de transporte** (RFC **4253**): establece el canal cifrado, autentica **al servidor** mediante su clave de máquina y negocia algoritmos. Es donde ocurre el intercambio de claves, cuyas recomendaciones actualiza el **RFC 9142**.
2. **Capa de autenticación** (RFC **4252**): autentica **al cliente**, por contraseña, por **clave pública**, por *host* o por teclado interactivo.
3. **Capa de conexión** (RFC **4254**): multiplexa **varios canales lógicos** sobre la misma conexión: sesión interactiva, ejecución de comandos, **reenvío de puertos** y transferencia de ficheros.

> DATO CLAVE
>
> **SSH escucha en el puerto TCP 22**, y sobre él viajan **SFTP** y **SCP**: no son protocolos independientes con puerto propio. La autenticación **por clave pública** es preferible a la de contraseña —no hay secreto que viaje ni que adivinar—, y la clave privada debe estar **protegida por frase de paso**. La primera conexión a un servidor presenta su **huella de clave de máquina**: aceptarla a ciegas es el punto donde se cuela un ataque de intermediario, y por eso las huellas deben distribuirse por un canal fuera de banda.

El reenvío de puertos, que es un arma de doble filo. La capa de conexión de SSH permite **tunelizar** cualquier conexión TCP dentro de la sesión: reenvío **local** (un puerto del cliente sale por el servidor), **remoto** (un puerto del servidor entra hacia el cliente) y **dinámico** (SSH actúa como proxy SOCKS). Es utilísimo para administrar, y es también **el modo más habitual de saltarse un cortafuegos desde dentro**: un reenvío remoto abre un camino de entrada desde el servidor hacia el interior. Por eso, en un entorno del ENS, el reenvío debe estar **desactivado por defecto** en la configuración del servidor y habilitarse solo donde haga falta.

Los demás protocolos de gestión, con su versión correcta:

Servicio	Protocolo inseguro	Puerto	Alternativa correcta	Puerto
Consola remota de texto	**Telnet**, rlogin, rsh	23, 513, 514	**SSH**	22
Escritorio remoto gráfico	**VNC** sin cifrar	5900	**RDP** con TLS y NLA, o VNC sobre SSH/VPN	3389
Transferencia de ficheros	**FTP**, TFTP	21, 69/UDP	**SFTP** o **FTPS**	22, 990
Gestión de red	**SNMPv1/v2c**	161/UDP	**SNMPv3** con autenticación y cifrado	161/UDP
Registro centralizado	**Syslog** sin cifrar	514/UDP	Syslog **sobre TLS** (RFC 5425)	6514
Directorio	**LDAP**	389	**LDAPS** o LDAP con STARTTLS	636
Gestión fuera de banda	IPMI/BMC expuesto	623/UDP	Solo en **red de administración aislada**, nunca publicado	—

DATO CLAVE

Cuatro afirmaciones clave. **Telnet transmite las credenciales en texto claro**: no se usa jamás, ni siquiera «solo en la red interna». **SNMPv1 y v2c** no tienen seguridad real: la «comunidad» es una cadena en claro, y `public` y `private` siguen siendo las más habituales del mundo. **RDP no se publica a internet**, y debe exigir **autenticación a nivel de red (NLA)**. Y las **interfaces de gestión fuera de banda** (IPMI, iLO, iDRAC) son un acceso de nivel físico al servidor: viven en una **red de administración separada** — que es, además, una de las tres subredes mínimas que exige `mp.com.4.r1.2`.

El salto de administración. El patrón de arquitectura que resuelve todo lo anterior de una vez es el **servidor de salto** (*bastion host* o *jump server*): un único sistema, fuertemente bastionado y monitorizado, desde el que —y **solo** desde el que— se administran los equipos. Toda sesión se registra, con grabación si hace falta, y los administradores no tienen conectividad directa desde su puesto ofimático hacia la red de gestión. Su evolución moderna es la **gestión de accesos privilegiados (PAM)**, que además custodia las contraseñas de administración en una bóveda, las rota automáticamente y las entrega **por tiempo limitado y con justificación**.

EJEMPLO DE APLICACIÓN EN EL AYTO

Un proveedor externo mantiene la aplicación de gestión de multas y necesita entrar a diagnosticar una incidencia. El diseño conforme al ENS es: VPN de acceso remoto **con certificado emitido para ese proveedor**, cuenta **nominal** para el técnico que interviene —no una cuenta genérica del proveedor—, **MFA**, ventana temporal **acotada al ticket**, acceso **exclusivamente al servidor de salto**, desde el salto solo al servidor de la aplicación, **grabación de la sesión** y **revocación automática** al cerrar el ticket. Todo ello está respaldado por `op.acc.4.5` (autorización expresa), `op.acc.4.2` (mínimo privilegio), `mp.eq.3.3` (mínimos imprescindibles desde redes no controladas) y `op.exp.8` (registro de la actividad). La alternativa que se ve en la vida real —una cuenta compartida y un escritorio remoto abierto— incumple al menos cuatro medidas y destruye la trazabilidad.

---

4. Redes privadas virtuales (VPN)

4.1. Conceptos generales y clasificaciones de VPN

Definición precisa. Una **red privada virtual** es una red **lógica y privada** construida **sobre una infraestructura de transporte pública o compartida**, de forma que sus participantes se comunican como si estuvieran en una red propia. Se consigue con dos ingredientes que hay que nombrar siempre juntos:

- **Tunelización** (*tunneling*): **encapsular** un paquete completo dentro de la carga útil de otro paquete, de modo que la red intermedia solo ve el paquete exterior y no sabe —ni necesita saber— qué transporta.
- **Criptografía**: cifrar la carga para dar **confidencialidad**, y firmarla o autenticarla para dar **integridad y autenticidad del origen**.

DATO CLAVE

Túnel no es sinónimo de VPN. GRE (RFC **2784**) encapsula pero **no cifra**: crea un túnel, no una red privada segura. **MPLS** aísla el tráfico de cada cliente en la red del operador, pero **tampoco lo cifra**: es privacidad **administrativa**, no criptográfica. La palabra que convierte un túnel en VPN es **cifrado**. Y a la inversa: TLS cifra pero, salvo que se use para tunelizar tráfico de red, **no crea una VPN**.

Qué aporta y qué no aporta una VPN. Aquí se concentran varios errores frecuentes:

Aporta	No aporta
Confidencialidad del tráfico frente a la red intermedia	**Disponibilidad**: la pasarela VPN es un punto único de fallo y un objetivo de DDoS
Integridad y detección de modificación	**Anonimato**: la organización sabe perfectamente quién se conecta, y debe saberlo
Autenticidad del extremo remoto	**Seguridad del extremo**: si el portátil está infectado, la VPN **transporta el malware limpiamente hasta la red corporativa**
Extensión del direccionamiento privado y del acceso a recursos internos	**Autorización**: la VPN da conectividad; quién puede hacer qué lo decide otra capa

DATO CLAVE

La frase que hay que recordar: **una VPN protege el canal, no los extremos**. Es la razón de que §5 —seguridad del puesto— sea parte del mismo tema: sin control del dispositivo, la VPN es un túnel cifrado y seguro que lleva el problema directamente al centro de la red. Es también la razón de `mp.eq.3.3`.

Las clasificaciones. Hay cuatro criterios y conviene manejar los cuatro:

a) Por su topología y propósito — la clasificación principal, la que da título a los dos epígrafes siguientes: **sitio a sitio** y **de acceso remoto**.

b) Por la capa del modelo en la que operan:

Nivel	Protocolos	Qué encapsula
Nivel 2 (enlace)	PPTP, L2TP, L2TPv3, MPLS L2VPN, VXLAN	**Tramas** completas: el extremo remoto queda **en el mismo dominio de difusión**
Nivel 3 (red)	**IPsec**, GRE, MPLS L3VPN, WireGuard	**Paquetes IP**
Niveles 4-7	**SSL/TLS VPN**, VPN sobre QUIC	**Conexiones o aplicaciones**

c) Por quién la gestiona: **basada en el cliente** (*CPE-based*, la organización monta y gestiona sus pasarelas) o **basada en el proveedor** (*provider-provisioned*, típicamente MPLS del operador).

d) Por el ámbito de la relación: **intranet** (entre sedes de la misma organización), **extranet** (con un tercero: otra Administración, un proveedor) y **de acceso** (usuario individual).

> DATO CLAVE
>
> El detalle clave de la clasificación por nivel: una **VPN de nivel 2** hace que el equipo remoto quede **en el mismo dominio de difusión** que la red destino —ve el tráfico de difusión, puede usar protocolos no IP—, mientras que una **VPN de nivel 3** solo encamina paquetes IP. La primera es más «transparente» y por eso mismo **más peligrosa**: extiende también los ataques de capa 2.

4.1.1. VPN de sitio a sitio

Qué es. Una VPN **de sitio a sitio** (*site-to-site*) une **dos redes completas** de forma **permanente**, mediante un túnel establecido entre las **pasarelas** de cada extremo —normalmente cortafuegos o encaminadores—. Los equipos de cada red **no instalan nada** y **no saben que la VPN existe**: para ellos, la red remota es simplemente otra subred alcanzable.

Características que la definen:

- El túnel es **permanente** o se levanta bajo demanda cuando hay tráfico, y se mantiene con mensajes de comprobación de vida.
- La autenticación se produce **entre pasarelas**, no entre usuarios: con **clave precompartida** (más sencilla, peor práctica en entornos grandes) o con **certificados digitales** (recomendado).
- Se define qué tráfico entra en el túnel mediante el **dominio de cifrado** (*interesting traffic*): pares de subredes origen-destino.
- La tecnología dominante es **IPsec en modo túnel con ESP** (§4.2.1).

Sus variantes:

- **Radial** (*hub and spoke*): todas las sedes se conectan a una central; el tráfico entre dos sedes pasa por el centro. Sencillo de gestionar, concentra la carga.
- **Malla completa** (*full mesh*): todos con todos. Óptimo en latencia, inmanejable a partir de unas decenas de sedes, porque el número de túneles crece con el cuadrado del número de sedes.
- **VPN dinámica multipunto**: túneles radiales permanentes y túneles directos **creados bajo demanda** entre sedes. Es la solución práctica al problema de la malla.
- **SD-WAN**: capa de gestión que elige dinámicamente por qué enlace —fibra, 4G/5G, MPLS— va cada aplicación, montando por debajo túneles IPsec. Optimiza coste y calidad, **no sustituye a IPsec**: lo orquesta.

EJEMPLO DE APLICACIÓN EN EL AYTO

La conexión de una junta municipal de distrito con el CPD central es un caso de manual de VPN de sitio a sitio: dos pasarelas, un túnel **IPsec en modo túnel con ESP**, autenticación **por certificado**, dominio de cifrado limitado a las subredes que realmente deben hablar entre sí, y **redundancia** con dos operadores distintos, porque de ese enlace depende que la oficina pueda atender al ciudadano. Obsérvese que aquí `mp.com.2.1` se cumple con la VPN, pero que la segmentación (`mp.com.4`) sigue siendo necesaria: que la sede esté conectada por un túnel cifrado no significa que sus puestos deban ver toda la red del CPD.

4.1.2. VPN de acceso remoto

Qué es. Una VPN **de acceso remoto** (*remote access*) une **un único dispositivo** con la red de la organización. El usuario ejecuta un **cliente** —o usa el navegador— y se autentica **personalmente**. Es el escenario del teletrabajo de §3.

Las diferencias con la de sitio a sitio:

	Sitio a sitio	Acceso remoto
Qué une	Dos **redes**	Un **dispositivo** y una red
Quién se autentica	Las **pasarelas**	El **usuario** (y preferiblemente el dispositivo)
Software en el extremo	Ninguno en los equipos finales	**Cliente VPN** o navegador
Duración	Permanente	**Por sesión**
Número de extremos	Pocos y conocidos, con **IP fija**	Muchos, cambiantes, con IP dinámica y **detrás de NAT**
Tecnología habitual	**IPsec** modo túnel	**SSL/TLS VPN** o **IPsec con IKEv2**
Riesgo dominante	Configuración del túnel	**El estado del dispositivo del usuario**

Túnel completo frente a túnel dividido. Es la decisión de diseño central de esta sección:

- **Túnel completo** (*full tunnel*): **todo** el tráfico del dispositivo —incluida la navegación a internet— entra en la VPN, sale por la organización y vuelve. Ventajas: **toda** la navegación pasa por el proxy corporativo y queda sujeta a `mp.s.3` ; hay visibilidad y registro completos; el equipo no está simultáneamente en dos redes. Inconvenientes: **consumo de ancho de banda** en la sede central y latencia añadida en servicios de vídeo o de nube.

- **Túnel dividido** (*split tunnel*): solo el tráfico corporativo entra en la VPN; el resto sale directamente por la conexión doméstica. Ventaja: rendimiento. Inconvenientes graves: el equipo tiene **un pie en cada red** —lo que lo convierte en puente potencial—, la navegación **escapa al control corporativo** y la monitorización se vuelve ciega.

> DATO CLAVE
>
> En un entorno sujeto al ENS, **la opción correcta por defecto es el túnel completo**, y el túnel dividido es una **excepción que hay que justificar y acotar** —típicamente, excluyendo del túnel solo servicios de videoconferencia corporativos concretos—. La razón normativa es doble: `mp.s.3` (protección de la navegación web, con su normativa de uso, sus listas y, en ALTA, su registro) **solo es aplicable si la navegación pasa por la organización**; y el art. 9 (líneas de defensa) queda comprometido si el equipo puentea dos redes.

ZTNA: la alternativa moderna a la VPN de acceso remoto. El **acceso a red de confianza cero** (*Zero Trust Network Access*) invierte el planteamiento: en lugar de dar al usuario **una dirección IP en la red** y luego restringir, le da acceso **a una aplicación concreta**, sin exponerle la red y sin que la aplicación sea siquiera visible hasta que la política lo autoriza.

	VPN clásica	ZTNA
Qué concede	Conectividad **a la red**	Acceso **a una aplicación**
Visibilidad para el usuario	Ve el direccionamiento interno; puede escanear	**No ve nada** más que lo autorizado
Momento de la decisión	Al **conectar**	**Continua**, por sesión y reevaluada
Movimiento lateral	Posible si la segmentación es débil	Muy limitado por diseño
Estandarización	**IPsec y TLS son normas del IETF**	Término **de mercado**, sin norma; se apoya en la NIST SP 800-207

> DATO CLAVE
>
> ZTNA **no deroga la VPN**: en España, `mp.com.2.1` seguirá exigiendo **«redes privadas virtuales cifradas cuando la comunicación discurra por redes fuera del propio dominio de seguridad»**. La lectura correcta es que ZTNA **es una forma de cumplir esa medida** con un modelo de autorización más fino, no una alternativa a cumplirla. Cualquier respuesta que afirme que «la confianza cero elimina la VPN» es incorrecta en un examen español.

4.2. Protocolos de tunelización y cifrado en VPN

4.2.1. Arquitectura y protocolos IPSec

Qué es IPsec. *Internet Protocol Security* es un **conjunto de protocolos** —no uno solo— que dota al protocolo IP de seguridad **nativa**: confidencialidad, integridad, autenticación del origen, protección frente a repetición y control de acceso. Su arquitectura general la define el **RFC 4301**, *Security Architecture for the Internet Protocol* (diciembre de 2005), que sustituyó al RFC 2401. Funciona **en la capa de red**, y de ahí su gran ventaja: es **transparente para las aplicaciones**.

Sus tres componentes, que hay que saber separar:

Componente	RFC	Número de protocolo IP	Qué hace
AH — Cabecera de autenticación	**4302**	**51**	Integridad y **autenticación del origen**, incluyendo **parte de la cabecera IP**. **NO cifra**
ESP — Carga de seguridad encapsulada	**4303**	**50**	**Cifra** la carga útil **y** proporciona integridad y autenticación (de la carga, no de la cabecera IP externa)
IKEv2 — Intercambio de claves	**7296** (**STD 79**)	UDP **500**, y **4500** con travesía de NAT	Autentica los extremos, negocia algoritmos y **establece las asociaciones de seguridad**

DATO CLAVE

AH no cifra. Es el dato clave de IPsec y el que más se falla. AH da integridad y autenticidad; **ESP da cifrado, integridad y autenticidad**. Como ESP hace todo lo que hace AH salvo autenticar la cabecera IP externa, **en la práctica se usa ESP y AH está prácticamente en desuso**. Los números de protocolo IP son igualmente memorizables: **AH = 51, ESP = 50**; y son **números de protocolo**, no puertos, porque AH y ESP **no usan puertos**: son protocolos que van directamente sobre IP. Eso, precisamente, es lo que les da problemas con NAT.

Los dos modos de operación. La otra pareja imprescindible:

	Modo transporte	Modo túnel
Qué protege	**Solo la carga útil** del paquete IP	**El paquete IP completo**, cabecera incluida
Cabecera IP	Se **conserva** la original	Se **encapsula** la original y se añade **una nueva**
Entre quiénes	**Extremo a extremo**, entre dos equipos finales	Entre **pasarelas** (o pasarela y equipo)
Direcciones visibles en tránsito	Las **reales** de origen y destino	Las de las **pasarelas**: se oculta el direccionamiento interno
Sobrecarga	Menor	Mayor (20 bytes adicionales de cabecera IPv4)
Uso típico	Comunicación segura entre dos servidores concretos; L2TP/IPsec	**VPN de sitio a sitio** y VPN de acceso remoto

DATO CLAVE

La regla, directa: **VPN de sitio a sitio ⇒ ESP en modo túnel**. Y la consecuencia: en modo túnel, un observador en internet **solo ve las direcciones de las dos pasarelas**; no puede saber qué equipo interno habla con cuál. En modo transporte, ve las direcciones reales — se protege el contenido, no las partes.

Las asociaciones de seguridad. Una **SA** (*Security Association*) es el «contrato» que fija los parámetros de la protección: qué protocolo (AH o ESP), qué algoritmos, qué claves, qué modo y qué tiempo de vida.

DATO CLAVE

Dos datos clave. Primero: **una SA es unidireccional**. Una comunicación bidireccional necesita **dos SA**, una por sentido. Segundo: cada SA se identifica de forma única por el trío **SPI** (*Security Parameter Index*, índice de parámetros de seguridad) **+ dirección IP de destino + protocolo de seguridad (AH o ESP)**. Las SA vivas se guardan en la **SAD** (base de datos de asociaciones de seguridad) y la política que decide qué se protege, en la **SPD** (base de datos de políticas de seguridad), cuyas tres acciones posibles son **descartar**, **omitir IPsec** o **aplicar IPsec**.

IKEv2 y sus dos fases. El **intercambio de claves por internet** resuelve el problema de establecer secretos compartidos sobre un canal inseguro, mediante **Diffie-Hellman** más autenticación

mutua. En IKEv2 —que sustituyó a IKEv1 y simplificó mucho el proceso— la negociación tiene dos intercambios:

1. **IKE_SA_INIT**: negocia los algoritmos y ejecuta el intercambio Diffie-Hellman. Establece el canal seguro de control: la **IKE SA**.
2. **IKE_AUTH**: **autentica** los extremos —por **certificado**, por **clave precompartida** o por **EAP**, lo que permite integrarlo con RADIUS para VPN de usuario— y crea la primera **Child SA**, que es la SA de IPsec que protegerá los datos.

Después, **CREATE_CHILD_SA** crea SA adicionales y ejecuta el **rekey** —renovación periódica de claves—.

> DATO CLAVE
>
> **IKEv1 está formalmente obsoleto**: el **RFC 9395**, de **abril de 2023**, lo declara obsoleto («*Deprecation of the Internet Key Exchange Version 1 (IKEv1) Protocol and Obsoleted Algorithms*») junto con algoritmos ya superados. **IKEv2 es la versión vigente y tiene la categoría de Internet Standard (STD 79)**, lo que en la serie RFC significa el máximo grado de madurez. Ventajas de IKEv2 sobre IKEv1: **menos mensajes** para establecer el túnel, **detección de par muerto** integrada, **soporte nativo de EAP** —y por tanto de MFA—, **travesía de NAT** normalizada y **MOBIKE**, que permite que el cliente **cambie de red** (del Wi-Fi a la red móvil) **sin caerse el túnel**.

IPsec y NAT: el problema clásico. Tiene una respuesta exacta:

> DATO CLAVE
>
> **AH es incompatible con NAT**, porque su comprobación de integridad **incluye campos de la cabecera IP** que el NAT modifica: cualquier traducción invalida la firma. **ESP sobrevive**, porque no protege la cabecera IP externa, pero aun así tropieza: al no tener puertos, un NAT con traducción de puertos no sabe cómo distinguir varias sesiones. La solución normalizada es la **travesía de NAT (NAT-T)**: encapsular ESP dentro de **UDP puerto 4500**, según el **RFC 3948**, *UDP Encapsulation of IPsec ESP Packets*. Por eso en toda pregunta sobre puertos de IPsec la respuesta completa es **UDP 500 (IKE) y UDP 4500 (IKE y ESP con NAT-T)**, más los protocolos IP **50 (ESP)** y **51 (AH)**.

EJERCICIO RESUELTO

Problema. Se levanta un túnel IPsec entre la sede central y una junta de distrito. Funciona en el laboratorio, pero al desplegarlo en la sede real el túnel se negocia y luego **no pasa tráfico**. El extremo de la junta está detrás de un encaminador del operador que hace **NAT**. La configuración usa **AH + ESP** y solo permite **UDP 500** en el cortafuegos. ¿Qué falla y cómo se corrige? **Solución**. Fallan **dos cosas encadenadas**. **Primera**: el uso de **AH** con NAT por delante. AH autentica campos de la cabecera IP; el NAT los reescribe; la comprobación de integridad falla en destino y el paquete se descarta silenciosamente. Como ESP ya proporciona integridad y autenticación de la carga, **la corrección es eliminar AH y usar solo ESP**. **Segunda**: los puertos abiertos. Con NAT en medio, IKEv2 detecta la traducción durante el IKE_SA_INIT y **conmuta a UDP 4500** (NAT-T, RFC 3948), encapsulando ESP en UDP. Si el cortafuegos solo permite **UDP 500**, la negociación inicial funciona —de ahí que el túnel «se levante»— pero **el tráfico de datos no pasa**, que es exactamente el síntoma descrito. **La corrección es permitir también UDP 4500**. Y como comprobación adicional, hay que verificar que los **dominios de cifrado** coinciden en ambos extremos y que no hay **solapamiento de direccionamiento** entre las dos redes, que es el otro motivo clásico de que un túnel establecido no curse tráfico.

Los algoritmos, sin entrar en criptografía. Los requisitos de implementación están en el **RFC 8221** (para ESP y AH) y el **RFC 8247** (para IKEv2), ambos actualizados por el citado RFC 9395. A efectos de estudio basta con la regla: **cifrado autenticado con AES-GCM** como opción preferente, **AES-CBC con HMAC-SHA-256** como alternativa clásica, y **prohibidos DES, 3DES, MD5, SHA-1 y los grupos Diffie-Hellman de menos de 2048 bits**. En el ámbito español, la lista vinculante no la fija el RFC sino la **guía CCN-STIC-807**, a la que remiten `mp.com.2.r1` y `mp.com.3.r2` cuando exigen «algoritmos y parámetros **autorizados por el CCN**».

DATO CLAVE

La amenaza post-cuántica y las VPN. El ataque relevante no es futuro: se llama **«cosecha ahora, descifra después»** (*harvest now, decrypt later*) — un atacante graba hoy el tráfico cifrado y lo descifra cuando disponga de un ordenador cuántico. Afecta especialmente a las VPN, porque protegen información con vida útil larga. Las respuestas normalizadas, verificadas contra el índice del RFC Editor: en **IKEv2**, el **RFC 8784** (mezcla de claves precompartidas post-cuánticas, 2020), el **RFC 9370** (**múltiples intercambios de claves**, 2023) y el **RFC 9867** (noviembre de 2025); en **TLS 1.3**, el **RFC 9954** (julio de 2026, informativo) y el **RFC 10024**, *Post-Quantum Traditional (PQ/T) Hybrid Key Agreement Mechanisms for TLS 1.3*, de **agosto de 2026**. Y el calendario que hay que citar: la **hoja de ruta coordinada de la UE** para la transición a la criptografía post-cuántica, presentada por el **Grupo de Cooperación NIS el 23 de junio de 2025**, fija **31-12-2026** para las hojas de ruta nacionales y los primeros pasos, **31-12-2030** para los **casos de uso de alto riesgo** y **31-12-2035** para completar la transición [PQC-EU].

4.2.2. VPN basadas en SSL y TLS

Por qué existen. IPsec es excelente entre pasarelas, pero incómodo para un usuario que se conecta desde el Wi-Fi de un hotel: requiere cliente instalado y configurado, y sus protocolos —números 50 y 51, UDP 500 y 4500— **son bloqueados con frecuencia** en redes ajenas. Las **VPN SSL/TLS** resuelven ambos problemas apoyándose en el único puerto que está abierto en todas partes: **TCP 443**.

> DATO CLAVE
>
> El motivo real del éxito de las VPN SSL/TLS es la **atravesabilidad**: usan **TCP 443**, indistinguible del tráfico HTTPS ordinario, de modo que funcionan desde cualquier red, incluidas las que filtran agresivamente. Su contrapartida es de rendimiento: al encapsular **TCP dentro de TCP** aparece el fenómeno del **derretimiento de TCP** (*TCP meltdown*), en el que dos controles de congestión superpuestos se estorban y la conexión se degrada en enlaces con pérdidas. Por eso los productos modernos prefieren transportar el túnel sobre **DTLS o QUIC (UDP)** y dejar TCP 443 solo como respaldo.

Las dos modalidades:

	Sin cliente (*clientless*)	Con cliente (*full tunnel* o cliente ligero)
Qué necesita el usuario	Solo un **navegador**	Un **cliente** instalado (o un complemento)
Qué alcanza	Aplicaciones **web** publicadas en un portal; a veces terminales o ficheros mediante pasarelas	**Cualquier** aplicación: se crea un adaptador virtual y se encamina el tráfico IP
Nivel efectivo	Aplicación (7)	Red (3)
Control del puesto	Mínimo	Alto: permite comprobación de estado del dispositivo
Uso típico	Acceso puntual, equipos no gestionados, terceros	**Teletrabajo del empleado** con equipo corporativo

Cómo se protege. El túnel se establece con un saludo TLS ordinario: el servidor presenta su **certificado**, opcionalmente exige **certificado de cliente** —lo que constituye autenticación mutua—, se negocia la suite y se derivan las claves de sesión. A partir de ahí, todo lo que el cliente encamina hacia el adaptador virtual viaja cifrado dentro de esa conexión.

DATO CLAVE

Como toda la seguridad de una VPN SSL/TLS descansa en TLS, **le aplican exactamente los mismos límites de versión que a HTTPS**: **prohibidos SSL 3.0 (RFC 7568), TLS 1.0 y TLS 1.1 (RFC 8996)**; admisibles **TLS 1.2** bien configurado y **TLS 1.3**, cuya especificación vigente es el **RFC 9846, de julio de 2026**, que obsoleta el RFC 8446. Una VPN «SSL» que negocie SSL 3.0 no es que sea antigua: es **no conforme**.

Comparativa IPsec frente a SSL/TLS, que es la tabla decisiva de la sección:

Criterio	IPsec	SSL/TLS VPN
Capa	Red (3)	Transporte-aplicación (4-7)
Alcance	**Todo** el tráfico IP, transparente para las aplicaciones	Lo que se encamine al túnel, o solo aplicaciones web si es sin cliente
Cliente	Necesario y configurado	Navegador o cliente ligero
Paso por cortafuegos ajenos	**Problemático** (protocolos 50/51, UDP 500/4500)	**Excelente** (TCP 443)
NAT	Requiere **NAT-T**	Nativo
Rendimiento bruto	**Mejor**, con aceleración por hardware	Peor, sobre todo TCP sobre TCP
Granularidad de la autorización	Por subredes y servicios	**Por aplicación y usuario**
Escenario ideal	**Sitio a sitio** y enlaces permanentes	**Acceso remoto** de usuarios

EJERCICIO RESUELTO

Problema. Hay que decidir la tecnología para dos necesidades del Ayuntamiento: (a) unir permanentemente el CPD central con un centro de proceso de respaldo, y (b) dar acceso a 900 empleados en teletrabajo desde portátiles corporativos. ¿Qué se elige en cada caso y con qué argumentos? **Solución**. **(a) IPsec en modo túnel con ESP, autenticado por certificados.** Argumentos: son **dos redes** con direccionamiento fijo y pasarelas bajo control propio, el enlace es **permanente** y de alto caudal —donde IPsec rinde mejor y se acelera por hardware—, no hay cortafuegos ajenos que atravesar y la transparencia para las aplicaciones es imprescindible, porque por ese enlace irá replicación de bases de datos y copias de seguridad, no solo tráfico web. Se añadirá **redundancia** de operador y **rekey** periódico. **(b) VPN de acceso remoto con cliente**, indistintamente sobre **IKEv2** o **TLS**, y en la práctica lo habitual es un producto que ofrezca ambos: **IKEv2 con MOBIKE** como opción preferente por rendimiento y por soportar el cambio de red sin cortes, y **TLS sobre 443** como **respaldo** para redes que bloqueen IPsec. Configuración obligatoria: **túnel completo**, **MFA** (`op.acc.5` en nivel MEDIO), **certificado de dispositivo** para exigir equipo corporativo, **comprobación de estado**, **segmento de teletrabajo** con acceso mínimo (`mp.eq.3.3`) y **registro** de accesos con éxito y fallidos. Nótese que la decisión (b) **no es una elección entre IPsec y TLS**, sino un diseño con **camino principal y alternativo**: es lo que hacen los productos reales y lo que responde mejor en un caso práctico.

4.2.3. Protocolos de tunelización en nivel de enlace

Qué aportan y por qué conviene conocerlos. Los protocolos de nivel 2 encapsulan **tramas** en lugar de paquetes, lo que permite transportar **protocolos distintos de IP** y extender el dominio de enlace. Históricamente nacieron para el acceso telefónico; hoy interesan sobre todo por sus **carencias**.

- **PPTP** (*Point-to-Point Tunneling Protocol*, **RFC 2637**, 1999, informativo). Encapsula **PPP** en **GRE** y usa **TCP 1723** para el control. Fue el primer protocolo VPN masivo por venir integrado en Windows. Su autenticación (**MS-CHAPv2**) y su cifrado (**MPPE**, basado en RC4) **están rotos**: se descifra en horas.

DATO CLAVE

PPTP está criptográficamente roto y prohibido en cualquier entorno serio. Es una respuesta falsa siempre que aparezca como opción de VPN segura. Recuérdese además que **no cifra por sí mismo**: cifra MPPE, y la autenticación MS-CHAPv2 es vulnerable a ataques fuera de línea.

- **L2TP** (*Layer 2 Tunneling Protocol*, **RFC 2661**; **L2TPv3** en el **RFC 3931**). Nació de la fusión de PPTP y del protocolo L2F de Cisco. Usa **UDP 1701**. Su característica definitoria: **no cifra ni autentica nada**. Por eso en la práctica **siempre** aparece como **L2TP/IPsec** —L2TP proporciona el túnel de nivel 2 e IPsec, en **modo transporte**, la seguridad—.

DATO CLAVE

L2TP no cifra. La combinación correcta es **L2TP/IPsec**, y dentro de ella IPsec trabaja en **modo transporte**, no en modo túnel, porque el túnel ya lo pone L2TP. Puerto de L2TP: **UDP 1701**.

- **GRE** (*Generic Routing Encapsulation*, **RFC 2784**, protocolo IP **47**). Encapsulación genérica, capaz de transportar cualquier protocolo de red. **No cifra**. Su utilidad real hoy: transportar **multidifusión** y **protocolos de encaminamiento dinámico** —que IPsec puro no puede llevar— dentro de un túnel que después se protege con IPsec. De ahí el patrón **GRE sobre IPsec**.
- **PPPoE** (**RFC 2516**) no es una VPN: es el encapsulado de PPP sobre Ethernet que usan muchos accesos de banda ancha. Aparece a veces como distractor.
- **MPLS**: técnicamente no es un protocolo de tunelización de seguridad, sino de conmutación por etiquetas en la red del operador. Ofrece **VPN de nivel 2 y de nivel 3** con aislamiento entre clientes, pero **sin cifrado**.

DATO CLAVE

La MPLS del operador no cifra. Es un error muy extendido creer que una «VPN MPLS» contratada a un operador cumple `mp.com.2.1`. No lo cumple por sí sola: la medida exige **redes privadas virtuales cifradas** cuando el tráfico sale del dominio de seguridad propio, y la red del operador **es un dominio ajeno**. La solución conforme es **cifrar por encima con IPsec**, que es exactamente lo que hacen las arquitecturas SD-WAN sobre MPLS.

Tabla de cierre de la sección, que resume lo memorizable:

Protocolo	RFC	Nivel	Puerto o número	¿Cifra?	Situación en 2026
PPTP	2637	2	TCP 1723 + GRE	Sí, pero **roto**	**Prohibido**
L2TP / L2TPv3	2661 / 3931	2	UDP **1701**	**No**	Válido **solo** como L2TP/IPsec
GRE	2784	3	Protocolo IP **47**	**No**	Vigente, siempre bajo IPsec
AH	4302	3	Protocolo IP **51**	**No** (solo integridad)	En desuso
ESP	4303	3	Protocolo IP **50**	**Sí**	**El estándar**
IKEv2	7296 (**STD 79**)	—	UDP **500** / **4500**	Negocia claves	**Vigente**; IKEv1 obsoleto (RFC 9395)
TLS	**9846** (obsoleta 8446)	4-7	TCP **443**	**Sí**	**Vigente** (1.2 y 1.3)

RELACIÓN CON OTROS TEMAS

Los fundamentos criptográficos que sostienen todo lo anterior —cifrado simétrico y asimétrico, Diffie-Hellman, funciones resumen, certificados y PKI— corresponden al **Tema 32**. El detalle del saludo TLS y de HTTPS, al **Tema 35**. Los medios de transmisión y las comunicaciones móviles sobre los que viajan estos túneles, al **Tema 33**.

5. Seguridad en el puesto del usuario

5.1. Protección del sistema operativo y del hardware del puesto

Por qué el puesto es la sección más importante del tema. Todo lo anterior protege el camino; esta sección protege el **origen y el destino**. Y los datos son inequívocos: el **60 %** de las intrusiones empieza con un **phishing** que llega a un puesto de trabajo, y el **21,3 %** con la explotación de una vulnerabilidad, muy a menudo también en el puesto [ENISA-ETL]. El perímetro más caro del mundo no impide que un empleado abra un adjunto.

> DATO CLAVE
>
> El **artículo 22.1 del ENS** obliga a prestar «especial atención» a la información almacenada o en tránsito a través de **«los equipos o dispositivos portátiles o móviles, los dispositivos periféricos, los soportes de información y las comunicaciones sobre redes abiertas»**. Es el precepto que ampara, de una vez, el cifrado del portátil, el control de los periféricos y la VPN.

La cadena de confianza del arranque. La protección del puesto empieza antes del sistema operativo:

- **UEFI** sustituye a la BIOS clásica y aporta, entre otras cosas, **arranque seguro** (*Secure Boot*): el firmware solo ejecuta cargadores y controladores **firmados** por claves reconocidas, lo que impide que un **bootkit** se cargue antes que el sistema.
- **TPM** (*Trusted Platform Module*): chip criptográfico soldado o integrado que **custodia claves** y **mide** la integridad de los componentes del arranque. Es la pieza sobre la que se apoya el cifrado de disco para no depender de que el usuario escriba una contraseña larga en cada encendido, y la que permite **atestiguar** ante un servidor que el equipo arrancó en un estado conocido.
- **Contraseña de firmware** y **control del orden de arranque**: sin ellas, cualquiera que tenga el equipo cinco minutos puede arrancar desde un dispositivo USB y leer el disco — salvo que esté cifrado.
- **Control de puertos físicos**: bloqueo o restricción de USB, tanto para exfiltración como para ataques por dispositivo malicioso que se hace pasar por teclado.

El bastionado del sistema operativo. *Bastionar* (*hardening*) es reducir la superficie de exposición del sistema hasta dejar solo lo necesario. Sus operaciones son siempre las mismas:

1. **Retirar cuentas y contraseñas estándar** — `op.exp.2.1`, literal.
2. **Mínima funcionalidad**: desinstalar o desactivar servicios, roles, protocolos y aplicaciones innecesarios — `op.exp.2.2`.
3. **Seguridad por defecto**: la configuración de partida es la segura, y **reducir la seguridad exige un acto consciente del usuario** — `op.exp.2.3`.
4. **Mínimo privilegio en la sesión diaria**: el usuario **no** es administrador de su equipo. Es la medida individual que más ataques neutraliza, porque la mayoría del malware necesita privilegios para persistir.
5. **Aplicar una guía de configuración** por tecnología: en el ámbito español, las **series CCN-STIC 500 y 600**; el art. 20.d del ENS lo exige expresamente.

DATO CLAVE

`op.exp.2` **Configuración de seguridad** aplica en **las tres categorías** y contiene tres reglas nominadas: **retirada de cuentas y contraseñas estándar**, **mínima funcionalidad** y **seguridad por defecto**. Y un cuarto requisito que casi nadie recuerda, `op.exp.2.4` : **las máquinas virtuales se gestionan con el mismo rigor que las físicas** —parcheado, cuentas, antivirus—, **incluyendo la máquina anfitriona**.

El hardware móvil y sus reglas propias. El portátil que sale del edificio pierde toda la protección física del art. 22 y de las medidas `mp.if` . El ENS lo trata aparte:

DATO CLAVE

`mp.eq.3` **Protección de dispositivos portátiles** exige cuatro cosas y añade dos refuerzos. Exige: **inventario** de portátiles con **persona responsable** de cada uno y **control regular** de que está bajo su control (`mp.eq.3.1`); **procedimiento operativo** para informar al servicio de gestión de incidentes de **pérdidas o sustracciones** (`mp.eq.3.2`); **limitación a los mínimos imprescindibles** de lo accesible desde redes no controladas (`mp.eq.3.3`); y **evitar que el portátil contenga claves de acceso remoto** no imprescindibles (`mp.eq.3.4`). Refuerzos: **R1 cifrado del disco duro** «cuando el nivel de confidencialidad de la información almacenada sea de **nivel MEDIO**», y **R2 entornos protegidos**, restringiendo el uso fuera de las instalaciones a lugares «a salvo de hurtos y **miradas indiscretas**». Aplicación: **BÁSICA y MEDIA**, la medida; **ALTA**, `+ R1 + R2` .

Las otras dos medidas del puesto, breves:

- `mp.eq.1` **Puesto de trabajo despejado**: «Los puestos de trabajo permanecerán despejados, sin que exista material distinto del necesario en cada momento». Refuerzo **R1** (MEDIA y ALTA): el material usado se guarda **en lugar cerrado**. Suena menor, pero en una oficina de atención al público es lo que impide que un expediente en papel quede a la vista del ciudadano siguiente.
- `mp.eq.2` **Bloqueo de puesto de trabajo**: bloqueo tras «un tiempo prudencial de inactividad», con **nueva autenticación** para reanudar. Refuerzo **R1** (ALTA): pasado un tiempo mayor, **se cancelan las sesiones abiertas**.

DATO CLAVE

`mp.eq.2` es de dimensión **autenticidad (A)** y su tabla es: **BAJO — no aplica**; **MEDIO — aplica**; **ALTO — + R1**. Es la medida que se falla cuando el enunciado pregunta «¿qué medidas del puesto son exigibles en un sistema de nivel BAJO?»: `mp.eq.1` , `mp.eq.3` y `mp.eq.4` sí; `mp.eq.2` **no**.

5.2. Soluciones de protección del punto final

5.2.1. Antivirus, antimalware y plataformas de detección y respuesta

La evolución en cuatro escalones. Conviene saber **qué añade cada escalón** al anterior:

Escalón	Qué es	Qué añade	Qué sigue sin resolver
Antivirus	Detección de **código dañino conocido**, por **firmas** y por heurística sobre ficheros	La base: bloquear lo ya catalogado	Ciego ante lo **desconocido** y ante los ataques **sin fichero**
EPP (*Endpoint Protection Platform*)	**Plataforma** de protección del punto final gestionada desde consola central	Integra antivirus, **cortafuegos personal**, control de dispositivos y de aplicaciones, cifrado y filtrado web	Sigue centrado en **prevenir**, no en investigar
EDR (*Endpoint Detection and Response*)	**Detección y respuesta**: registra continuamente el **comportamiento** del equipo y permite investigar y actuar	**Telemetría** e historial, detección por comportamiento, **aislamiento remoto** del equipo, caza de amenazas, respuesta guiada	Solo ve **el punto final**
XDR (*Extended Detection and Response*)	Correlación **extendida**: punto final **más** red, correo, identidad y nube	Visión conjunta y correlación entre dominios	Complejidad e integración

Y una variante que no es tecnológica sino de servicio: **MDR** (*Managed Detection and Response*), en la que un tercero opera el EDR o XDR con analistas propios, 24 horas. Es lo que en la práctica contratan las organizaciones que no pueden sostener un SOC propio.

DATO CLAVE

La diferencia clave entre EPP y EDR es que el EPP **previene** —bloquea lo que reconoce como malo— y el EDR **detecta y responde** —asume que algo entrará y aporta lo necesario para verlo, investigarlo y contenerlo—. La capacidad más característica del EDR es el **aislamiento del equipo en red desde la consola**: dejarlo sin comunicación con todo salvo con la propia consola, para cortar la propagación sin perder la evidencia. Un antivirus no puede hacer eso.

El anclaje normativo, que es lo que da la respuesta completa:

DATO CLAVE

`op.exp.6` **Protección frente a código dañino**. Requisitos literales: mecanismos de prevención **y reacción** (`op.exp.6.1`); software antimalware **«en todos los equipos: puestos de usuario, servidores y elementos perimetrales»** (`op.exp.6.2`); **todo fichero de fuente externa se analiza antes de trabajar con él** (`op.exp.6.3`); bases de datos de detección **permanentemente actualizadas** (`op.exp.6.4`); y **protección en tiempo real** en los puestos (`op.exp.6.5`). Tabla de aplicación: **BÁSICA** = la medida; **MEDIA** = `+ R1 + R2` (**escaneo periódico** de todo el sistema y **revisión de las funciones críticas al arrancar**); **ALTA** = `+ R1 + R2 + R3 + R4` , donde **R3 es la lista blanca de aplicaciones** —«solamente se podrán ejecutar aquellas aplicaciones previamente autorizadas»— y **R4 es, literalmente, el EDR**: «herramientas de seguridad orientadas a detectar, investigar y resolver actividades sospechosas en puestos de usuario y servidores (**EDR – Endpoint Detection and Response**)».

Ese último dato es de los más rentables del tema: **el ENS nombra el EDR por su sigla**, en `op.exp.6.r4` , y lo hace exigible en **categoría ALTA**. Del mismo modo, **la lista blanca de aplicaciones** (R3) es la medida más eficaz contra el ransomware y la que más resistencia organizativa genera.

Los tipos de código dañino que hay que saber nombrar:

- **Virus**: se **inserta en un fichero anfitrión** y necesita que se ejecute.
- **Gusano** (*worm*): se **propaga solo** por la red, sin anfitrión ni intervención humana. Es el que convierte una red plana en un incendio.
- **Troyano**: se presenta como algo legítimo y esconde función maliciosa.
- **Ransomware**: cifra los datos y extorsiona; hoy con **doble extorsión** (exfiltra y amenaza con publicar).
- **Programa espía** (*spyware*), **registrador de teclas** (*keylogger*), **publicidad no deseada** (*adware*).
- **Puerta trasera** (*backdoor*) y **rootkit**: persistencia y ocultación, a veces por debajo del sistema operativo.

- **Red de equipos zombis** (*botnet*): conjunto de equipos comprometidos gobernados desde un servidor de **mando y control**; es la infraestructura de los DDoS.
- **Malware sin fichero** (*fileless*): vive en memoria y abusa de herramientas legítimas del sistema —lo que se llama *living off the land*—. **Es invisible para un antivirus basado en ficheros**, y es exactamente el motivo por el que existe el EDR.

5.2.2. Cortafuegos personales y cifrado de almacenamiento

El cortafuegos personal. Es el cortafuegos que se ejecuta **en el propio equipo** y filtra sus conexiones entrantes y salientes. Su valor no está en sustituir al perimetral, sino en **cubrir precisamente donde este no llega**:

- Cuando el portátil está **fuera** de la red corporativa —en casa, en un hotel, en una red pública—, es el **único** cortafuegos que hay.
- Dentro de la red, filtra el **tráfico entre equipos del mismo segmento**, que nunca pasa por el cortafuegos perimetral. Es la defensa de primera línea contra el **movimiento lateral**, y la base de la microsegmentación en el puesto.
- Permite reglas **por aplicación**, no solo por puerto.

> DATO CLAVE
>
> La justificación del cortafuegos personal es esta: **el cortafuegos perimetral no ve el tráfico entre dos puestos de la misma VLAN**. Si un equipo se infecta y ataca a su vecino, el perímetro no se entera. De ahí que el cortafuegos personal —gestionado centralmente, con perfiles distintos para «en la oficina» y «fuera»— sea una capa **independiente**, en el sentido del art. 9 del ENS, y no una redundancia inútil.

El cifrado del almacenamiento. Protege la **confidencialidad en reposo**. Tres modalidades:

Modalidad	Qué cifra	Cuándo protege
Cifrado de disco completo (BitLocker, LUKS, FileVault)	Todo el volumen, incluido el sistema	Con el equipo **apagado**: pérdida, robo, retirada del disco
Cifrado de fichero o carpeta	Elementos concretos	También con el equipo encendido, si el contenedor está cerrado
Cifrado de soportes extraíbles	USB, discos externos	Traslado y extravío del soporte

DATO CLAVE

El cifrado de disco completo no protege frente al malware. Con el equipo encendido y la sesión iniciada, el disco está **descifrado para el sistema**, y por tanto para cualquier proceso que se ejecute con esos permisos, incluido un ransomware. Protege **exclusivamente** frente al acceso físico al equipo apagado. Confundir ambas cosas es error frecuente y muy penalizado. La medida que lo exige es `mp.eq.3.r1` —cifrado del disco cuando la confidencialidad es de **nivel MEDIO**—, complementada por `mp.si.2` **Criptografía** para los soportes, que **no aplica en nivel BAJO** y sí desde MEDIO.

Y el problema de las claves de recuperación. Un cifrado bien implantado exige **custodia centralizada de las claves de recuperación** —en el directorio corporativo o en una bóveda—, porque de lo contrario un empleado que olvida su PIN convierte el cifrado en una **pérdida de disponibilidad**. Es un caso claro de que una medida de confidencialidad mal desplegada puede dañar otra dimensión.

El resto de la protección del punto final, en una lista corta:

- **Control de dispositivos**: qué USB se admite, con qué permisos y para qué usuarios.
- **Control de aplicaciones** o lista blanca (`op.exp.6.r3`).
- **Prevención de fuga de información (DLP)**: detecta y bloquea la salida de datos sensibles por correo, web o USB.
- **Gestión de vulnerabilidades del puesto**: inventario y análisis continuo, que alimenta el ciclo de parcheado de §5.3.
- **Copia de seguridad del puesto**, que es lo único que revierte de verdad un ransomware — con la regla **3-2-1** y, sobre todo, **una copia desconectada o inmutable**, porque el ransomware moderno busca y cifra las copias en red antes de actuar.

EJEMPLO DE APLICACIÓN EN EL AYTO

Un portátil municipal se pierde en el transporte público. Si el disco está **cifrado** (`mp.eq.3.r1`) y el equipo estaba **apagado o bloqueado** (`mp.eq.2`), el incidente es una pérdida patrimonial y una incidencia de inventario, pero **no** una violación de seguridad de datos personales en el sentido del art. 33 del RGPD, porque la información **sigue siendo inaccesible**. Si el disco **no** estuviera cifrado, el mismo hecho se convierte en una **brecha notificable a la AEPD en 72 horas** y, según el riesgo, comunicable a los interesados (art. 34). La misma pérdida, dos consecuencias jurídicas completamente distintas: **la diferencia la marca una medida técnica**. En ambos casos se activa `mp.eq.3.2` , el procedimiento de comunicación de pérdidas y sustracciones.

5.3. Gestión centralizada de directivas de seguridad y actualizaciones

La idea de fondo. Ninguna medida del puesto sirve si depende de que cada usuario la configure. La seguridad del puesto es, ante todo, un **problema de gestión centralizada**: definir una configuración segura, **imponerla**, **verificar** que se mantiene y **corregir** las desviaciones.

La línea base de seguridad. Es el documento —y su implementación técnica— que define la configuración segura estándar de cada tipo de equipo: qué servicios corren, qué directivas de contraseña, qué registros se generan, qué está prohibido. Se construye a partir de las **guías CCN-STIC de las series 500 y 600** y se despliega mediante:

- **Directivas de grupo (GPO)** en un dominio de directorio, para equipos de escritorio y servidores Windows.
- **Herramientas de gestión de configuración** (Ansible, Puppet, Chef, Salt) en entornos Linux y mixtos.
- **MDM/UEM** (*Mobile Device Management* / *Unified Endpoint Management*) para móviles, tabletas y, cada vez más, también portátiles: aplica perfiles, exige cifrado y PIN, permite el **borrado remoto** y separa el **contenedor corporativo** del uso personal en escenarios BYOD.

> DATO CLAVE
>
> `op.exp.3` **Gestión de la configuración de seguridad** es la medida que cierra este círculo: exige que la configuración **se mantenga en el tiempo**, que se conserve **en todo momento la regla de mínimo privilegio** (`op.exp.3.2`) y que el sistema **reaccione a las vulnerabilidades notificadas** (`op.exp.3.4`). Aplica en las tres categorías, con **R1** en MEDIA y **R1 + R2 + R3** en ALTA. Y el **art. 21 del ENS** añade que la inclusión o modificación de **cualquier elemento** en el catálogo de activos requiere **autorización formal previa**.

El ciclo de gestión de actualizaciones. Es la segunda medida más rentable del tema, después de la formación. Sus fases:

1. **Inventario** de activos y de su software — sin él no se sabe qué hay que parchear (`op.exp.1`).
2. **Vigilancia** de los boletines del fabricante y de los avisos del **CCN-CERT** y del **INCIBE-CERT** — `op.exp.4.1` lo llama «seguimiento continuo de los anuncios de defectos».
3. **Análisis y priorización**, en función del riesgo real: criticidad de la vulnerabilidad, exposición del sistema y existencia de explotación activa.
4. **Prueba en preproducción**, en un entorno «consistente en configuración al entorno de producción».
5. **Despliegue por anillos**: primero un grupo piloto, después el resto, con ventana de mantenimiento.

6. **Verificación** de que el parche se ha aplicado realmente, y **plan de reversión** por si aparecen efectos adversos.

> DATO CLAVE
>
> `op.exp.4` **Mantenimiento y actualizaciones de seguridad**, literal: hay que disponer de «un **procedimiento para analizar, priorizar y determinar cuándo aplicar** las actualizaciones de seguridad, parches, mejoras y nuevas versiones», con priorización basada en **la variación del riesgo**; y «el mantenimiento **solo podrá realizarse por personal debidamente autorizado**». Tabla: **BÁSICA** = la medida; **MEDIA** = **+ R1**, pruebas en **preproducción**; **ALTA** = **+ R1 + R2**, donde **R2 es la previsión de un mecanismo para revertir** configuraciones y parches «en caso de aparición de efectos adversos». Existen además **R3** —comprobación periódica de la **integridad del firmware** de la infraestructura de red y las BIOS— y **R4** —**monitorización continua** de amenazas y vulnerabilidades—.

El fin de soporte, que es donde falla la Administración.

> DATO CLAVE
>
> Un sistema **fuera de soporte** deja de recibir parches, y **ninguna otra medida lo compensa**: el antivirus no tapa una vulnerabilidad del núcleo. **Windows 10 terminó su soporte el 14 de octubre de 2025**; el programa de pago **Extended Security Updates (ESU)** prolonga **solo** las actualizaciones **críticas e importantes** —sin correcciones funcionales ni soporte técnico— hasta el **12 de octubre de 2027**. Mantener puestos fuera de soporte sin plan de migración documentado es un **incumplimiento directo de** `op.exp.4` y aparece sistemáticamente como no conformidad en las auditorías del ENS (`op.exp.4` en relación con el art. 21).

El inventario, que es la medida invisible. `op.exp.1` exige un **inventario de activos** actualizado, y `mp.eq.3.1` uno específico de portátiles **con persona responsable**. Es la medida menos vistosa y la que más incidentes explica: no se puede parchear, cifrar ni recuperar lo que no se sabe que existe. Cuando se pregunta «cuál es el primer paso» de casi cualquier proceso de seguridad, la respuesta correcta suele ser **el inventario**.

EJEMPLO DE APLICACIÓN EN EL AYTO

Un ayuntamiento con miles de puestos no puede parchear todo a la vez sin arriesgarse a paralizar la atención al ciudadano. El diseño conforme al ENS es por **anillos**: anillo 0, los equipos del propio equipo de sistemas; anillo 1, un 5 % de puestos representativos de cada tipo de oficina; anillo 2, el resto de puestos administrativos; anillo 3, los **puestos críticos de atención presencial** y los sistemas del CPD, en ventana nocturna y con **plan de reversión** documentado (`op.exp.4.r2`). Cada anillo se separa del siguiente por un periodo de observación. Es lento, y precisamente por eso hay que separar el **canal de emergencia**: cuando aparece una vulnerabilidad con explotación activa en un servicio publicado, el procedimiento de `op.exp.4.2` debe permitir **saltarse los anillos** con autorización expresa, porque la priorización se hace «teniendo en cuenta la variación del riesgo».

5.4. Concienciación y buenas prácticas para la seguridad del empleado público

La última capa no es tecnológica. Con el **60 %** de las intrusiones entrando por **phishing**, la formación del personal no es un complemento: es una **medida de seguridad** con el mismo rango normativo que un cortafuegos. Y el ENS la trata exactamente así.

DATO CLAVE

`mp.per.3` **Concienciación** y `mp.per.4` **Formación** aplican en **las tres categorías**, incluida la **BÁSICA**. `mp.per.3` obliga a recordar **periódicamente** tres cosas concretas: **(1)** «La normativa de seguridad relativa al **buen uso** de los equipos o sistemas **y las técnicas de ingeniería social más habituales**»; **(2)** «La **identificación** de incidentes, actividades o comportamientos sospechosos que deban ser reportados»; y **(3)** «El **procedimiento para informar** sobre incidentes de seguridad, **sean reales o falsas alarmas**». `mp.per.4` exige formar en **configuración de sistemas**, **detección y reacción ante incidentes** y **gestión de la información** en cualquier soporte —almacenamiento, transferencia, copias, distribución y destrucción—, y añade que **«se evaluará la eficacia de las acciones formativas»**.

Ese inciso final —**«sean reales o falsas alarmas»**— es el más importante de los tres: la organización debe **premiar** que se avise, aunque la alarma resulte falsa. Si notificar un correo sospechoso conlleva reproche o burocracia, **el empleado dejará de notificar**, y con ello se pierde el sensor más rápido que tiene la organización.

El phishing, y cómo se reconoce. Las señales que hay que saber enumerar:

- **Urgencia y amenaza**: «su cuenta será bloqueada en 24 horas», «último aviso antes de sanción».
- **Remitente que no cuadra**: nombre correcto pero dominio ajeno o con letras cambiadas (*typosquatting*), o dominio con caracteres de otro alfabeto que se ven igual (ataque

homógrafo).

- **Enlace cuyo destino real no coincide** con el texto visible.
- **Solicitud de credenciales**: ninguna organización pide la contraseña por correo.
- **Adjunto inesperado**, especialmente ejecutable, comprimido con contraseña o documento que pide «habilitar macros».
- **Contexto plausible pero no verificado**: el **fraude del CEO** o del proveedor que «ha cambiado de número de cuenta» — el fraude que más dinero mueve en el sector público, y que se resuelve **verificando por un canal distinto**, nunca respondiendo al mismo correo.
- **Fatiga de MFA**: recibir notificaciones de aprobación repetidas hasta que la persona acepta por cansancio. La respuesta correcta es **denegar y avisar**, nunca aceptar «para que pare».

> DATO CLAVE
>
> El **80 %** de la ingeniería social observada a principios de 2025 ya usaba **contenido generado o mejorado con IA** [ENISA-ETL]. Consecuencia práctica: **las señales clásicas de detección han perdido fiabilidad**. Un correo de phishing generado con un modelo de lenguaje **no tiene faltas de ortografía**, imita el estilo institucional y puede personalizarse con datos públicos del organismo. Enseñar a detectar phishing «por las faltas» es hoy una formación obsoleta: lo que hay que enseñar es a **verificar el remitente y el enlace** y a **desconfiar de la urgencia**, no del estilo.

El decálogo del empleado público, que es un buen esqueleto de respuesta para un caso práctico:

1. **Contraseñas robustas y no reutilizadas**, con gestor de contraseñas corporativo, y **MFA** siempre que se ofrezca.
2. **Bloquear el equipo al levantarse** — `mp.eq.2`, y en la práctica un simple atajo de teclado.
3. **Puesto despejado** y documentación bajo llave — `mp.eq.1`.
4. **No instalar software** por cuenta propia ni conectar dispositivos USB de origen desconocido.
5. **Verificar antes de actuar** ante cualquier petición urgente de dinero, datos o credenciales, y hacerlo **por otro canal**.
6. **Notificar de inmediato** cualquier sospecha, error propio incluido: haber pinchado en un enlace y avisar en cinco minutos convierte un incidente grave en uno menor.
7. **No usar servicios personales** —correo, almacenamiento en nube, mensajería— para información municipal.
8. **Cuidado en redes públicas**: conectar siempre por **VPN corporativa** y desconfiar de redes Wi-Fi abiertas con nombres verosímiles.
9. **Proteger la pantalla y la conversación** fuera de la oficina — `mp.eq.3.r2`, «a salvo de miradas indiscretas».

10. **Comunicar de inmediato la pérdida o el robo** del equipo o del teléfono — `mp.eq.3.2`.

Cómo se hace bien la concienciación. Cuatro criterios que distinguen un programa eficaz de un curso de una hora:

- **Continua**, no anual: el ENS dice «regularmente».
- **Segmentada**: no es lo mismo formar a un tramitador de ventanilla, a un directivo —objetivo de *whaling*— o a un administrador de sistemas.
- **Práctica**, con **simulaciones de phishing** cuyo objetivo declarado sea **medir y formar**, no sancionar; y con métricas de mejora, no de castigo.
- **Evaluada**: `mp.per.4` exige literalmente **evaluar la eficacia** de las acciones formativas — es decir, medir si el porcentaje de clics baja, no cuántas personas asistieron.

EJEMPLO DE APLICACIÓN EN EL AYTO

Una campaña de concienciación municipal bien planteada mide **tres indicadores** y no solo uno: el **porcentaje de clics** en una simulación de phishing (que debe bajar), el **porcentaje de notificaciones** al buzón de incidencias (que debe **subir**, y es el indicador que casi nadie mide) y el **tiempo medio hasta la primera notificación** (que debe bajar, porque en un incidente real determina si se contiene o no). Un organismo donde el 20 % pincha pero el 60 % notifica en menos de cinco minutos está objetivamente mejor protegido que otro donde solo pincha el 5 % y **nadie avisa**. Y ambos indicadores alimentan `op.mon.2`, el **sistema de métricas** del ENS.

RELACIÓN CON OTROS TEMAS

La **administración del sistema operativo y del software de base**, incluido el bastionado y el ciclo de parcheado desde la óptica del administrador, corresponde al **Tema 27**. El **control remoto del puesto de usuario y la gestión de incidencias** —el CAU municipal—, al **Tema 29**. La **virtualización del puesto de trabajo**, al **Tema 28**. Y la **seguridad física de las instalaciones** (medidas `mp.if`), al **Tema 32**.

Los ocho datos que no se pueden fallar

Cierre memorístico del tema. Si solo queda tiempo para repasar una página, que sea esta.

1. `mp.com.1` **(perímetro) aplica en las tres categorías, incluida la BÁSICA;** `mp.com.4` **(segmentación) NO aplica en BÁSICA.** Y `mp.com.1` remite a una **Instrucción Técnica de Seguridad de Interconexión** que **no está publicada**: solo hay **cuatro ITS** en el BOE (Conformidad e Informe del Estado de la Seguridad, de 2016; Auditoría y Notificación de Incidentes, de 2018).

1. **IDS = espejo, avisa; IPS = camino, bloquea.** El falso positivo de un IDS es ruido; el de un IPS es **servicio público cortado**. Y las firmas no ven el día cero; las anomalías sí, pero con falsos positivos.

1. **AH no cifra (protocolo IP 51); ESP sí (protocolo IP 50).** IKEv2 en **UDP 500** y **UDP 4500** con travesía de NAT. **AH es incompatible con NAT**; ESP encapsulado en UDP 4500 (RFC 3948) sí pasa. **IKEv1 está obsoleto** desde el RFC 9395 (2023); **IKEv2 es STD 79**.

1. **Modo transporte cifra la carga; modo túnel cifra el paquete entero y añade cabecera IP nueva.** Regla: **sitio a sitio ⇒ ESP en modo túnel**. Y una **SA es unidireccional**: hacen falta **dos** por conexión, identificadas por **SPI + IP destino + protocolo**.

1. **L2TP no cifra (UDP 1701); GRE no cifra (protocolo IP 47); MPLS no cifra; PPTP está roto y prohibido.** La única combinación válida de nivel 2 es **L2TP/IPsec**, con IPsec en **modo transporte**.

1. **MFA = dos factores de categorías distintas.** `op.acc.5` en **nivel MEDIO y ALTO** exige `+ [R2 o R3 o R4] + R5` : **la contraseña sola deja de valer**, y hay que **registrar accesos con éxito y fallidos**. Añádase siempre `op.acc.4.5` : **política específica de acceso remoto con autorización expresa**.

1. **El ENS nombra el EDR literalmente** en `op.exp.6.r4` , exigible en **categoría ALTA**, junto con la **lista blanca de aplicaciones** (R3). Y `op.exp.6.2` obliga a antimalware **en puestos, servidores y elementos perimetrales**, no solo en los puestos. El **cifrado de disco** (`mp.eq.3.r1`) protege **solo el equipo apagado**, nunca frente al malware.

1. **El vector dominante es humano: 60 % phishing, 21,3 % explotación de vulnerabilidades** (ENISA, ETL 2025, sobre 4.875 incidentes de julio de 2024 a junio de 2025). Por eso **`mp.per.3` y `mp.per.4` aplican en las tres categorías** y por eso hay que notificar **«sean reales o falsas alarmas»**. El **DDoS** es el ataque más frecuente (**77 %**) y el menos dañino (**2 %** de interrupciones reales).

Diagramas

Índice de diagramas

ID	Título	Sección	Tipo
D1	Mapa del tema: las cinco capas de defensa	§ intro	Mapa de secciones
D2	Las cinco dimensiones de seguridad y los principios del ENS	§1.1	Comparativa + principios
D3	Amenazas y vectores de ataque: qué dice el ETL 2025	§1.2	Taxonomía + cifras
D4	Ataque por capa de la pila TCP/IP y su contramedida	§1.3	Capas + tabla
D5	Protocolos en claro y su versión segura: tabla de puertos	§1.3.2	Tabla de equivalencias
D6	El ENS en la red: qué medida aplica en qué categoría	§1.4	Matriz normativa
D7	Del perímetro-muralla al perímetro distribuido	§2.1	Evolución en tres etapas
D8	Las cinco generaciones de cortafuegos	§2.2.1	Escala evolutiva
D9	Proxy directo, proxy inverso y pasarela de aplicación	§2.2.2	Topología comparada
D10	IDS frente a IPS: ubicación y matriz de decisión	§2.3	Comparativa + matriz
D11	DMZ: tres patas, doble cortafuegos y segmentación interna	§2.4.1	Arquitecturas
D12	Confianza cero: los siete principios y los componentes	§2.4.2	Principios + PDP/PEP
D13	Acceso remoto del empleado municipal, paso a paso	§3.1	Flujo numerado
D14	Los tres factores de autenticación y qué exige el ENS	§3.2.1	Factores + tabla `op.acc.5`
D15	AAA y 802.1X: RADIUS, TACACS+ y el flujo de autenticación	§3.2.2	Comparativa + flujo
D16	Taxonomía de VPN: tipo, nivel y protocolo	§4.1	Doble clasificación
D17	IPsec: AH y ESP, modo transporte y modo túnel	§4.2.1	Estructura de paquete

ID	Título	Sección	Tipo
D18	IPsec frente a SSL/TLS: tabla de decisión	§4.2.2	Comparativa
D19	El puesto blindado: de antivirus a EDR y capas de defensa	§5.1 · §5.2	Escalera + capas

D1 · Mapa del tema: las cinco capas de defensa

Sección: § Convenciones — visión de conjunto de las cinco secciones **Propósito**: Ordenar el tema entero como **cinco capas concéntricas** sobre un mismo escenario municipal, mostrando qué protege cada sección y con qué medida del ENS se respalda. Es el diagrama de orientación: conviene volver a él al terminar cada sección.



[Fuente: ENS, RD 311/2022, arts. 9 y 23 y anexo II · ENISA ETL 2025]

D2 · Las cinco dimensiones de seguridad y los principios del ENS

Sección: §1.1 — Principios de la seguridad de la información y de las comunicaciones **Propósito**: Fijar las **cinco** dimensiones (CITAD) frente a la tríada CIA, con qué las rompe y qué las protege en una red, y enlazarlas con la regla de derivación de la **categoría** del sistema, que es donde se concentran los errores.

En España son CINCO dimensiones, no tres: C · I · T · A · D

DIMENSIÓN	QUÉ GARANTIZA	QUÉ LA ROMPE EN UNA RED	CON QUÉ SE PROTEGE
CONFIDENCIALIDAD C	Solo accede quien está autorizado	Escucha del tráfico, acceso a un segmento ajeno	Cifrado: IPsec, TLS, MACsec. Segmentación
INTEGRIDAD I	La información no se altera, y si se altera se detecta	Alteración en tránsito, inyección de datos falsos	HMAC dentro de IPsec, TLS o SSH
TRAZABILIDAD T	Se puede reconstruir quién hizo qué y cuándo	Falta de registros, cuentas compartidas, reloj desfasado	op.exp.8, sincronización horaria, SIEM
AUTENTICIDAD A	El origen es quien dice ser	Suplantación de IP o MAC, punto de acceso impostor	Certificados, 802.1X, autenticación mutua
DISPONIBILIDAD D	El servicio está accesible cuando se necesita	DDoS, corte de enlace, saturación del cortafuegos	Redundancia, mp.s.4, mitigación aguas arriba

DE NIVEL A CATEGORÍA: LA REGLA CLAVE

El NIVEL se fija POR DIMENSIÓN
Cada una de las cinco recibe su propio BAJO, MEDIO o ALTO

La CATEGORÍA se DERIVA
Alguna ALTO → categoría ALTA. Si no, alguna MEDIO → MEDIA. Resto: BÁSICA

EL ERROR MÁS PENALIZADO
Confundir dimensión (C, I, T, A, D) con categoría (BÁSICA, MEDIA, ALTA)

[Fuente: ENS, RD 311/2022, arts. 5 a 11 y anexos I y II — verificado contra el PDF del BOE]

D3 · Amenazas y vectores de ataque: qué dice el ETL 2025

Sección: §1.2 — Amenazas, vulnerabilidades y vectores de ataque **Propósito**: Separar los cuatro conceptos del análisis de riesgos, clasificar los ataques por la dimensión que rompen y contrastarlo con las **cifras reales** del informe de ENISA, que corrigen la intuición: el ataque más frecuente no es el más dañino.

Sobre la amenaza no se actúa: se actúa sobre la vulnerabilidad y el impacto

LA CADENA DEL RIESGO

AMENAZA (Existe fuera de mí) → aprovecha → **VULNERABILIDAD** (Debilidad propia) → produce → **RIESGO** (Probabilidad × impacto) → lo reduce → **SALVAGUARDA** (Deja riesgo residual)

CLASIFICACIÓN POR LA DIMENSIÓN QUE ROMPEN

TIPO	DIMENSIÓN	EJEMPLOS EN RED	¿SE DETECTA?
INTERCEPTACIÓN · pasivo	Confidencialidad	Escucha de tráfico, captura de credenciales	Muy difícil: prevenir
MODIFICACIÓN · activo	Integridad	Alterar un paquete, envenenar la caché DNS	Sí: HMAC y alertas
FABRICACIÓN · activo	Autenticidad	Suplantar IP o MAC, correo falsificado	Sí: autenticación
INTERRUPCIÓN · activo	Disponibilidad	DoS y DDoS, corte de enlace, agotamiento	Sí, y de inmediato

LAS CIFRAS QUE CORRIGEN LA INTUICIÓN · ENISA ETL 2025 · 4.875 INCIDENTES · 1-7-2024 A 30-6-2025

77 % de los incidentes son DDoS… pero solo el 2 % interrumpe

60 % de los accesos iniciales son PHISHING

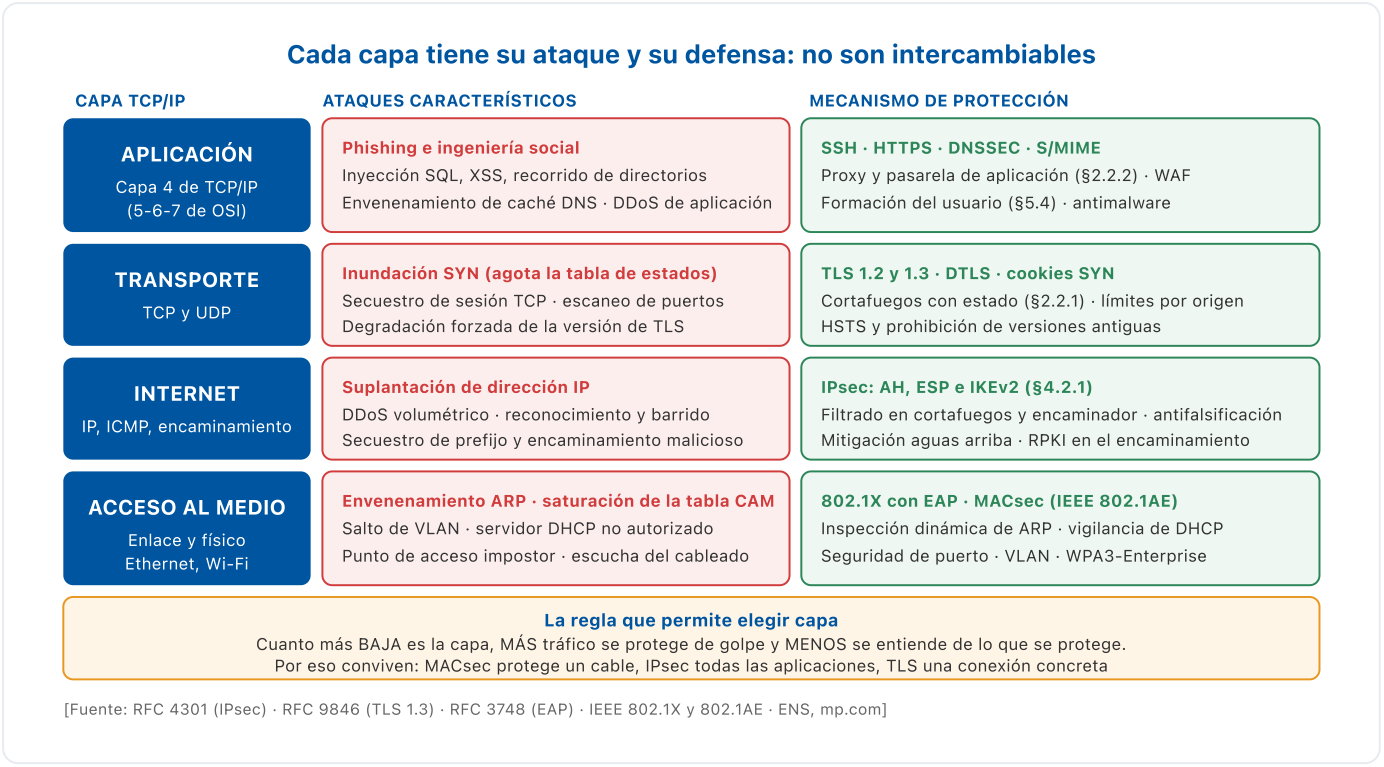
21,3 % explotación de VULNERABILIDADES

80 % de la ingeniería social ya usa IA (principios de 2025)

[Fuente: ENISA Threat Landscape 2025 · MAGERIT v3 · ENS, RD 311/2022, mp.com.3.2]

D4 · Ataque por capa de la pila TCP/IP y su contramedida

Sección: §1.3 — Mecanismos de protección en la pila de protocolos TCP/IP **Propósito**: Mostrar que **cada capa tiene su ataque y su defensa**, y que un mecanismo de una capa **no protege** de los ataques de otra. Es el diagrama que explica por qué un cortafuegos de capa 3 no detiene un envenenamiento ARP.



[Fuente: RFC 4301 (IPsec) · RFC 9846 (TLS 1.3) · RFC 3748 (EAP) · IEEE 802.1X y 802.1AE · ENS, mp.com]

D5 · Protocolos en claro y su versión segura: tabla de puertos

Sección: §1.3.2 — Seguridad en la capa de transporte y aplicación **Propósito**: Concentrar en una sola imagen **la tabla de puertos más rentable del tema**. Aquí los puertos van emparejados con el protocolo inseguro que sustituyen.

Todo protocolo clásico de internet nació en claro y tiene hoy su versión protegida

SERVICIO	EN CLARO — NO USAR	PUERTO	VERSIÓN SEGURA	PUERTO
Consola remota de texto	**Telnet**	TCP 23	**SSH**	TCP 22
Sesión remota (heredado)	**rlogin · rsh · rcp**	TCP 513-514	**SSH y sus derivados**	TCP 22
Transferencia de ficheros	**FTP · TFTP**	TCP 21 · UDP 69	**SFTP (en SSH) · FTPS (en TLS)**	TCP 22 · 990
Web	**HTTP**	TCP 80	**HTTPS (HTTP sobre TLS)**	TCP 443
Correo entre servidores	**SMTP sin cifrar**	TCP 25	**SMTP con STARTTLS**	TCP 25 · 587
Envío desde el cliente	**SMTP en claro**	TCP 25	**Envío con TLS implícito**	TCP 465 · 587
Lectura de correo	**POP3 · IMAP**	TCP 110 · 143	**POP3S · IMAPS**	TCP 995 · 993
Directorio	**LDAP**	TCP 389	**LDAPS o LDAP con STARTTLS**	TCP 636
Gestión de red	**SNMPv1 y v2c**	UDP 161	**SNMPv3 (autenticación y cifrado)**	UDP 161
Resolución de nombres	**DNS sin cifrar**	UDP/TCP 53	**DoT · DoH (DNSSEC firma, no cifra)**	TCP 853 · 443
Registro centralizado	**Syslog sin cifrar**	UDP 514	**Syslog sobre TLS (RFC 5425)**	TCP 6514

Y el que se usa mal: RDP, escritorio remoto, TCP y UDP 3389 — NUNCA se publica a internet; se accede por VPN o pasarela

[Fuente: RFC 8314 (correo con TLS) · RFC 9846 (TLS 1.3) · RFC 4251-4254 (SSH) · RFC 5425 (syslog sobre TLS) · RFC 7858 y 8484 (DoT y DoH)]

D6 · El ENS en la red: qué medida aplica en qué categoría

Sección: §1.4 — Cumplimiento del ENS en redes de la Administración Pública **Propósito**: Es **la tabla que convierte una respuesta técnica en una respuesta de oposición**. Reúne las medidas del anexo II que este tema necesita, con su tabla de aplicación literal, y marca en rojo las tres que **no aplican** en el nivel o categoría más bajos, que es donde se falla.

Las medidas del anexo II que hay que citar en este tema

CÓDIGO	DENOMINACIÓN OFICIAL	DIM.	BÁSICA	MEDIA	ALTA
mp.com.1	Perímetro seguro	Todas	aplica	aplica	aplica
mp.com.2	Protección de la confidencialidad — exige VPN cifrada	C	aplica	+ R1	+ R1 + R2 + R3
mp.com.3	Protección de la integridad y de la autenticidad	I · A	aplica	+ R1 + R2	+ R1 a R4
mp.com.4	Separación de flujos en la red — VLAN, VPN o física	Todas	NO APLICA	+ [R1 o R2 o R3]	+ [R2 o R3] + R4
op.mon.1	Detección de intrusión — IDS o IPS	Todas	aplica	+ R1 (por reglas)	+ R1 + R2
op.mon.3	Vigilancia — recolección de eventos; R1 es el SIEM	Todas	aplica	+ R1 + R2	+ R1 a R6
op.acc.5	Mecanismo de autenticación (usuarios externos)	Todas	+ [R1 a R4]	+ [R2 o R3 o R4] + R5	igual que MEDIA
op.exp.6	Protección frente a código dañino — R4 es el EDR	Todas	aplica	+ R1 + R2	+ R1 + R2 + R3 + R4
mp.eq.1	Puesto de trabajo despejado	Todas	aplica	+ R1	+ R1
mp.eq.2	Bloqueo de puesto de trabajo	A	NO APLICA	aplica	+ R1 (cierra sesiones)
mp.eq.3	Protección de dispositivos portátiles — R1 cifra disco	Todas	aplica	aplica	+ R1 + R2
mp.per.3 y 4	Concienciación y Formación	Todas	aplica	aplica	aplica

El detalle que casi nadie sabe: mp.com.1 remite a una ITS de INTERCONEXIÓN que NO está publicada — solo hay cuatro ITS en el BOE

[Fuente: ENS, RD 311/2022, anexo II — tablas de aplicación verificadas contra el PDF del BOE, BOE-A-2022-7191]

D7 · Del perímetro-muralla al perímetro distribuido

Sección: §2.1 — Concepto y arquitectura del perímetro de seguridad **Propósito**: Contar en **tres etapas** por qué el modelo perimetral clásico entró en crisis y qué lo sustituye, dejando claro el matiz clave: el perímetro **no desaparece**, deja de ser suficiente.

El perímetro no ha desaparecido: ha dejado de ser suficiente



QUÉ ROMPIÓ EL MODELO CLÁSICO

- **TELETRABAJO** — El usuario ya no está dentro del edificio
- **NUBE** — El servicio ya no está dentro del CPD
- **MOVILIDAD Y BYOD** — Dentro hay equipos que no son de la organización
- **MOVIMIENTO LATERAL** — Un puesto comprometido recorre la red plana

LAS DOS REGLAS QUE DEFINEN UN PERÍMETRO, Y QUE SIGUEN VIGENTES

- **1 · Todo el tráfico atraviesa el sistema** — mp.com.1.1 — si existe una salida alternativa, el perímetro no existe
- **2 · Denegación por defecto** — mp.com.1.2 — todos los flujos autorizados PREVIAMENTE

[Fuente: ENS, RD 311/2022, art. 9, art. 23 y mp.com.1 · NIST SP 800-207 (Zero Trust Architecture, 2020)]

D8 · Las cinco generaciones de cortafuegos

Sección: §2.2.1 — Cortafuegos de red, estado e inspección de aplicación **Propósito**: Ordenar las generaciones por **la capa que examina cada una** y fijar la diferencia clave —la **tabla de estados**—, además de separar el **WAF**, que no es un cortafuegos de red.

Cada generación mira una capa más arriba, y sabe algo más de lo que deja pasar

GENERACIÓN	CAPA	QUÉ EXAMINA	SU LIMITACIÓN CARACTERÍSTICA
1 · FILTRO DE PAQUETES Sin estado (stateless)	3 y 4	Cada paquete AISLADO: IP origen y destino, protocolo, puertos, banderas TCP	No recuerda nada: hay que abrir reglas en los DOS sentidos
2 · CON ESTADO Stateful inspection	3 y 4	El paquete Y LA CONEXIÓN a la que pertenece, mediante una TABLA DE ESTADOS	No entiende el contenido: para él, todo lo que va por 443 es "web"
3 · PASARELA (PROXY) Rompe la conexión en dos	7	El CONTENIDO del protocolo. Rompe la conexión en dos y actúa de intermediario	Coste de proceso, y hay que implementar un proxy POR protocolo
UTM Gestión unificada	3-7	Varias funciones en una sola caja: cortafuegos, IPS, antivirus, filtro web, antispam y VPN	Punto único de fallo, y penaliza el rendimiento al activarlo todo
NGFW Nueva generación	3-7	La APLICACIÓN y el USUARIO, no solo el puerto y la IP. Integra IPS, antimalware y descifrado TLS	Necesita descifrar TLS para ver el contenido: mp.s.3.r1.2 lo regula

LA DIFERENCIA CLAVE
Filtro de paquetes frente a cortafuegos con estado: la TABLA DE ESTADOS: las reglas se escriben en un solo sentido

EL WAF NO ES UN CORTAFUEGOS DE RED
Protege UNA aplicación web frente a inyección SQL, XSS y recorrido de directorios. mp.s.2 ya exige + [R1 o R2] en BÁSICA

[Fuente: CCN-STIC-408 (Seguridad perimetral — cortafuegos) · CCN-STIC-140 (taxonomía) · ENS, mp.com.1 y mp.s.2]

D9 · Proxy directo, proxy inverso y pasarela de aplicación

Sección: §2.2.2 — Pasarelas de aplicación y servidores proxy de seguridad **Propósito**: Distinguir gráficamente **a quién protege cada proxy** y con qué medida del ENS se corresponde. La confusión entre directo e inverso es error frecuente y aquí se resuelve por su posición en el dibujo.

La diferencia está en a quién tapa: al que sale o al que se publica

PROXY DIRECTO (FORWARD) · PROTEGE Y CONTROLA A LOS CLIENTES QUE SALEN

PUESTOS — Red interna municipal → PROXY DIRECTO — Autentica al usuario → INTERNET — Destino real

Qué permite hacer · mp.s.3
Filtrar por URL y categoría · registrar QUIÉN navegó · analizar descargas · caché · listas

PROXY INVERSO (REVERSE) · PROTEGE Y OCULTA A LOS SERVIDORES PUBLICADOS

CIUDADANO — Desde internet → PROXY INVERSO — Termina TLS · WAF → SEDE — Granja de servidores

Qué permite hacer · mp.s.2
Terminar TLS · equilibrar carga · cachear ocultar la topología interna · integrar el WAF

LA RUPTURA DEL CANAL CIFRADO: LO QUE EL ENS EXIGE ANTES DE INSPECCIONAR

mp.s.3.r1.2 — refuerzo R1, exigible en categoría ALTA
«Se establecerá una función para la ruptura de canales cifrados a fin de inspeccionar su contenido, indicando QUÉ SE ANALIZA, QUÉ SE REGISTRA, DURANTE CUÁNTO TIEMPO se retienen y QUÉ USO prevé hacer el organismo de estas inspecciones», con excepción para destinos de confianza

mp.s.3.r1.1 · registrar la navegación | mp.s.3.r1.3 · lista negra de destinos | mp.s.3.r2.1 · lista blanca: todo lo demás vetado

[Fuente: ENS, RD 311/2022, mp.s.2 y mp.s.3 — texto literal del anexo II · RFC 1928 (SOCKS)]

D10 · IDS frente a IPS: ubicación y matriz de decisión

Sección: §2.3 — Sistemas de prevención y detección de intrusiones **Propósito**: Resolver de una vez la pareja que más se confunde, con las **dos ideas que la explican**: dónde se coloca cada uno y qué pasa cuando se equivoca. Incluye la matriz de los cuatro resultados posibles y la tabla de aplicación de `op.mon.1`.

IDS = espejo, avisa. IPS = camino, bloquea. Todo lo demás se deriva de ahí

DÓNDE SE COLOCA CADA UNO

IDS · FUERA DE LÍNEA

Internet → Conmutador → Red interna

IDS (copia) — Recibe una COPIA del tráfico

IPS · EN LÍNEA

Internet → IPS → Red interna

Todo el tráfico lo ATRAVIESA: si se avería y no tiene derivación, la red queda incomunicada

CONSECUENCIAS DE LA UBICACIÓN

CRITERIO	IDS	IPS
Qué hace ante un ataque	Detecta y ALERTA	Detecta y BLOQUEA o reinicia la conexión
Si el aparato se avería	No afecta al servicio	Puede cortar la red entera
Efecto de un falso positivo	Una alerta molesta	Corta TRÁFICO LEGÍTIMO: servicio público caído
Latencia que introduce	Ninguna	Sí: analiza antes de reenviar

LOS CUATRO RESULTADOS POSIBLES

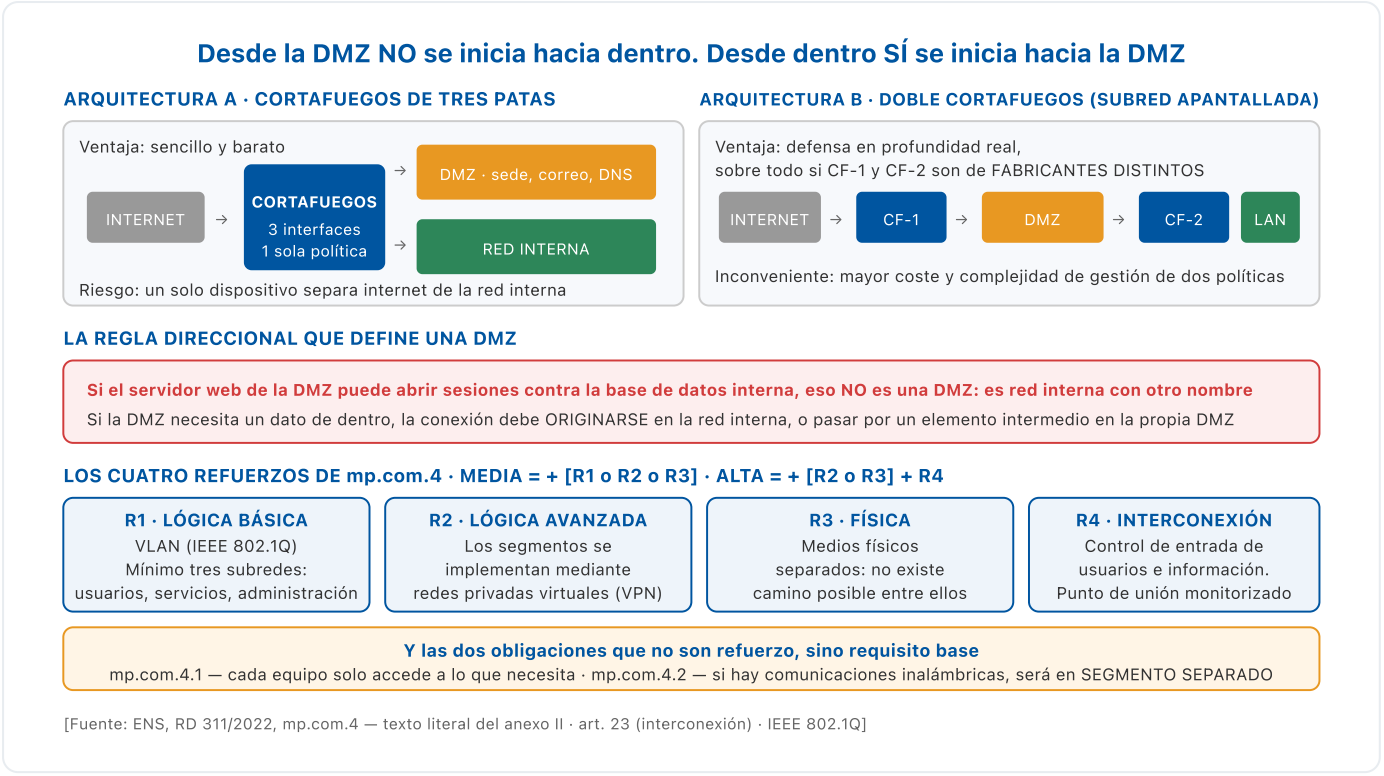
	HAY ATAQUE	NO HAY ATAQUE
Alerta	Verdadero positivo	FALSO POSITIVO
Calla	FALSO NEGATIVO (peor)	Verdadero negativo

op.mon.1 Detección de intrusión — aplica ya en BÁSICA
MEDIA: + R1, detección BASADA EN REGLAS
ALTA: + R1 + R2, PROCEDIMIENTOS DE RESPUESTA a las alertas

[Fuente: ENS, RD 311/2022, op.mon.1 y op.mon.3 — texto y tablas del anexo II verificados contra el PDF del BOE]

D11 · DMZ: tres patas, doble cortafuegos y segmentación interna

Sección: §2.4.1 — Redes desmilitarizadas y subredes internas **Propósito**: Dibujar las **dos arquitecturas de DMZ**, fijar la regla direccional que la define y enlazar con los cuatro refuerzos de `mp.com.4`, incluida la segmentación mínima obligatoria en tres subredes.



[Fuente: ENS, RD 311/2022, mp.com.4 — texto literal del anexo II · art. 23 (interconexión) · IEEE 802.1Q]

D12 · Confianza cero: los siete principios y los componentes

Sección: §2.4.2 — Modelo de seguridad de confianza cero **Propósito**: Fijar los **siete principios** de la NIST SP 800-207 y la separación **PDP / PEP** —quién decide frente a quién ejecuta—, con la advertencia de qué **no** es la confianza cero.

«Nunca confíes, verifica siempre»: estar dentro de la red ya no da ningún derecho

LOS SIETE PRINCIPIOS · NIST SP 800-207 (AGOSTO DE 2020)

1. Todas las fuentes de datos y servicios de computación se consideran RECURSOS
2. TODA comunicación se protege, con independencia de la ubicación en la red — también la interna
3. El acceso a cada recurso se concede POR SESIÓN, de una en una
4. El acceso se determina por POLÍTICA DINÁMICA: identidad, aplicación, estado del dispositivo, comportamiento y entorno
5. La organización MIDE Y VIGILA la integridad y el estado de seguridad de todos sus activos
6. Autenticación y autorización son DINÁMICAS y estrictamente exigidas ANTES de permitir el acceso
7. Se recopila toda la información posible sobre activos, infraestructura y comunicaciones, y SE USA PARA MEJORAR la política

LOS COMPONENTES LÓGICOS: QUIÉN DECIDE Y QUIÉN EJECUTA

PDP · PUNTO DE DECISIÓN

- **MOTOR (PE)** — Decide SI se concede
- **ADMIN. (PA)** — Ejecuta la decisión

consulta cada vez →

PEP · APLICACIÓN

- **DEJA PASAR O NO** — Pasarela, agente, proxy

SOBRE QUÉ DECIDE

Identidad y MFA (§3.2)
Estado del dispositivo (§5)
Microsegmentación (§2.4.1)

LO QUE LA CONFIANZA CERO NO ES

No es un producto · no elimina el cortafuegos · no deroga la VPN · no es incompatible con el ENS
En España, mp.com.1 (perímetro) y mp.com.2 (VPN cifrada) siguen siendo obligatorios

[Fuente: NIST SP 800-207, Zero Trust Architecture (agosto de 2020) · ENS, RD 311/2022, mp.com.1, mp.com.2, mp.com.4 y op.acc.4]

D13 · Acceso remoto del empleado municipal, paso a paso

Sección: §3.1 — Requisitos y arquitectura de acceso remoto en el ámbito público **Propósito**: Recorrer la **secuencia completa** de una conexión de teletrabajo conforme al ENS, marcando en cada paso la medida que lo respalda. Es el diagrama que se copia como esqueleto de respuesta en un caso práctico.

Seis pasos, seis medidas del ENS: el teletrabajador NO entra en «la red»

DOMICILIO DEL EMPLEADO		DMZ DEL AYUNTAMIENTO		RED CORPORATIVA
PORTÁTIL CORPORATIVO Cifrado · EDR · parcheado	→ **INTERNET** Red no controlada	→ **PASARELA VPN** En la DMZ, nunca dentro	→ **AAA + DIRECTORIO** RADIUS · MFA	→ **SEGMENTO** de teletrabajo

Si no supera el estado: VLAN de CUARENTENA

Todo lo que ocurre se registra y se envía al SIEM · op.exp.8 y op.mon.3.r1

LOS SEIS PASOS Y SU RESPALDO NORMATIVO

1. El equipo arranca con disco cifrado y el usuario se autentica en él
   mp.eq.3.r1 (cifrado si la confidencialidad es MEDIA) · mp.eq.2 (bloqueo)
2. El cliente VPN establece el túnel cifrado con la pasarela publicada en la DMZ
   mp.com.2.1 (VPN cifrada fuera del dominio propio) · mp.com.3
3. Se exige SEGUNDO FACTOR y se valida contra el servidor AAA y el directorio
   op.acc.5 en nivel MEDIO: + [R2 o R3 o R4] + R5 — la contraseña sola ya no vale
4. Se comprueba el ESTADO del dispositivo: corporativo, cifrado, parcheado, con EDR activo
   op.exp.4 y op.exp.6 · principio 4 y 5 de la NIST SP 800-207
5. Se concede acceso a un SEGMENTO DE TELETRABAJO con lo mínimo imprescindible
   mp.eq.3.3 (mínimos imprescindibles desde redes no controladas) · mp.com.4
6. Todo queda registrado, incluidos los intentos fallidos, y se revoca al cesar el empleado
   op.exp.8 · op.acc.5.r5 · op.acc.5.6 · y sobre todo op.acc.4.5

Base legal: art. 47 bis del TREBEP (RDL 29/2020) — teletrabajo autorizado, voluntario y reversible, con MEDIOS a cargo de la Administración

[Fuente: ENS, RD 311/2022, op.acc.4.5, op.acc.5, mp.com.2, mp.eq.3 · TREBEP art. 47 bis (RDL 29/2020)]

D14 · Los tres factores de autenticación y qué exige el ENS

Sección: §3.2.1 — Autenticación multifactor y uso de certificados digitales **Propósito**: Separar los **tres factores** —y desmontar los falsos MFA— y traducir la tabla de aplicación de `op.acc.5`, que es donde se decide si un teletrabajo cumple o no cumple.

MFA = dos factores de CATEGORÍAS DISTINTAS. Contraseña + PIN no es MFA

LOS TRES ÚNICOS FACTORES

ALGO QUE SE SABE	ALGO QUE SE TIENE	ALGO QUE SE ES
Contraseña · PIN · pregunta	Tarjeta criptográfica · token OTP	Huella · iris · rostro · voz
Su debilidad	**Su debilidad**	**Su debilidad**
Se adivina, se reutiliza, se roba	Se pierde, se roba, puede clonarse	NO se puede cambiar si se compromete

NO es MFA: contraseña + PIN (los dos son «algo que se sabe»)

SÍ es MFA: contraseña + código del móvil, o certificado + PIN

LOS REFUERZOS DE op.acc.5, ORDENADOS POR ROBUSTEZ

REFUERZO	MECANISMO	¿VALE EN NIVEL BAJO?	¿VALE EN MEDIO Y ALTO?
R1	Contraseña con complejidad y robustez mínimas	SÍ	NO — ya no vale
R2	Contraseña de un solo uso (OTP)	SÍ	SÍ
R3 y R4	Certificado CUALIFICADO protegido por segundo factor	SÍ	SÍ
R5	Registro de accesos con ÉXITO y FALLIDOS	Opcional	OBLIGATORIO

Tabla literal · BAJO: op.acc.5 + [R1 o R2 o R3 o R4] · MEDIO: op.acc.5 + [R2 o R3 o R4] + R5 · ALTO: igual que MEDIO

[Fuente: ENS, RD 311/2022, op.acc.5 y op.acc.6 — texto y tabla del anexo II · Reglamento (UE) 2024/1183 (eIDAS 2)]

D15 · AAA y 802.1X: RADIUS, TACACS+ y el flujo de autenticación

Sección: §3.2.2 — Servidores de autenticación, autorización y auditoría **Propósito**: Comparar los tres protocolos AAA por sus tres diferencias y dibujar el flujo **802.1X** con sus tres actores, incluida la asignación dinámica de VLAN.

RADIUS para el acceso de usuarios a la red · TACACS+ para administrar los equipos

CRITERIO	RADIUS	TACACS+	DIAMETER
Norma	RFC 2865 y 2866	RFC 8907 (informativo)	RFC 6733
Transporte y puertos	UDP 1812 y 1813	TCP 49	TCP o SCTP con TLS/DTLS
Qué cifra	SOLO la contraseña	TODO el cuerpo del mensaje	Todo, con TLS
¿Separa las tres A?	NO: van juntas	SÍ: las tres independientes	Sí
Uso típico	802.1X, Wi-Fi corporativa, VPN	Administración de equipos de red	Redes de operador, 4G y 5G

Dos novedades verificadas contra el índice del RFC Editor que casi ningún temario recoge
RFC 9887 (diciembre de 2025): TACACS+ sobre TLS 1.3 · RFC 9765 (abril de 2025): RADIUS/1.1 elimina MD5 usando ALPN — estado Experimental

802.1X · CONTROL DE ACCESO A LA RED BASADO EN PUERTO: TRES ACTORES

Hasta que la autenticación tiene éxito, el puerto está NO AUTORIZADO y solo deja pasar EAPOL: ni siquiera se obtiene dirección IP

1 · SUPLICANTE — El equipo que se conecta
→ EAPOL →
2 · AUTENTICADOR — Conmutador o punto de acceso
→ RADIUS →
3 · SERVIDOR AAA — RADIUS: es quien DECIDE
DIRECTORIO — Identidades

MÉTODOS EAP Y LA FUNCIÓN MÁS ÚTIL

EAP-TLS (RFC 5216, y 9190 para TLS 1.3): certificado en AMBOS extremos

El RADIUS puede devolver el ID de VLAN: asignación DINÁMICA de VLAN

[Fuente: RFC 2865, 2866, 6733, 8907, 9765, 9887, 3748, 5216 y 9190 — verificados contra el índice del RFC Editor · IEEE 802.1X]

D16 · Taxonomía de VPN: tipo, nivel y protocolo

Sección: §4.1 — Conceptos generales y clasificaciones de VPN **Propósito**: Cruzar las **dos clasificaciones** —por topología y por nivel del modelo— y dejar en una sola imagen qué protocolo **cifra** y cuál no, que es el error más repetido de la sección.

Túnel + cifrado = VPN. Sin cifrado solo hay túnel

CLASIFICACIÓN 1 · POR TOPOLOGÍA Y PROPÓSITO

SITIO A SITIO — une DOS REDES

Red CPD — GW — WAN — GW — Distrito

Permanente · autentican las PASARELAS · el usuario no instala nada
Tecnología: IPsec en MODO TÚNEL con ESP

ACCESO REMOTO — une UN DISPOSITIVO

Portátil — Internet — Pasarela — Segmento teletrabajo

Por sesión · autentica el USUARIO · requiere cliente o navegador
Tecnología: SSL/TLS VPN o IPsec con IKEv2

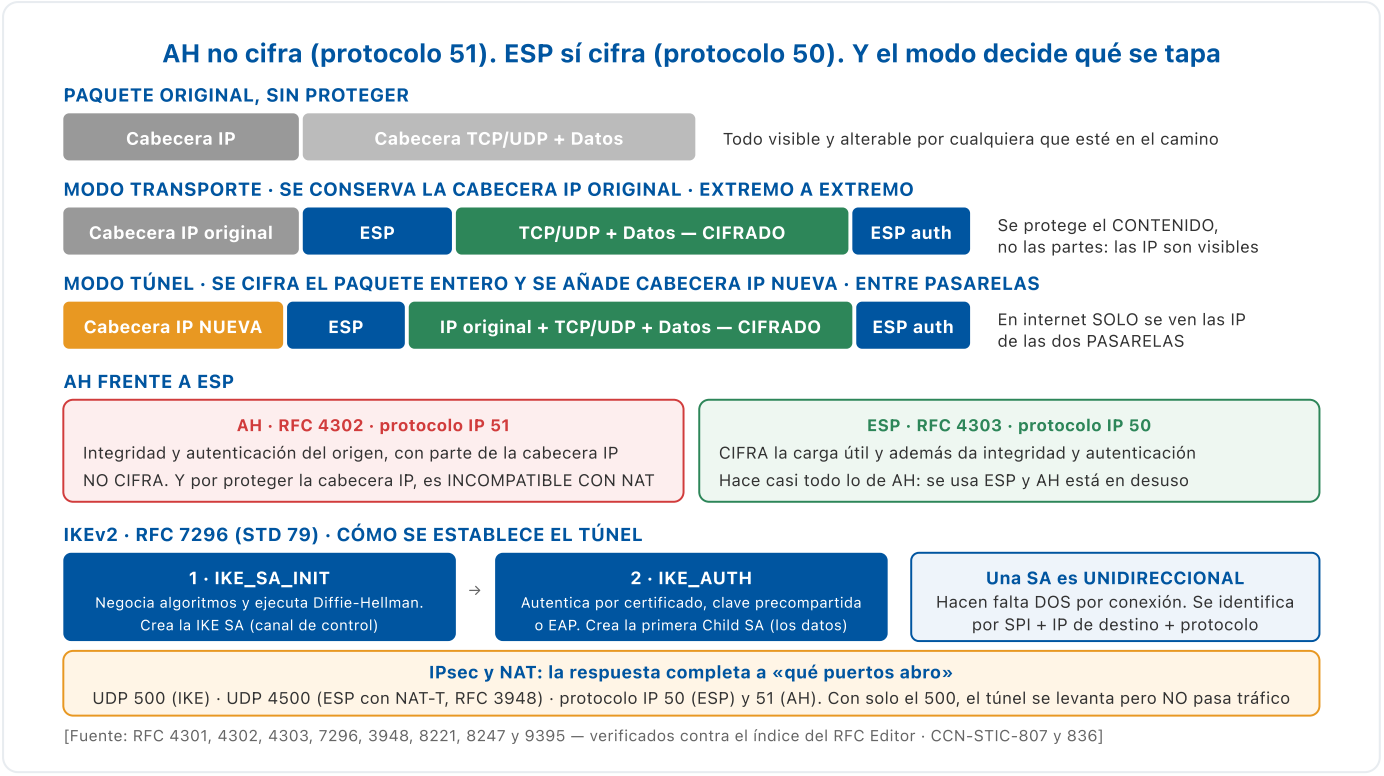
CLASIFICACIÓN 2 · POR NIVEL DEL MODELO, Y QUIÉN CIFRA DE VERDAD

NIVEL	PROTOCOLO	RFC	PUERTO O Nº	¿CIFRA?	SITUACIÓN EN 2026
2 · Enlace	PPTP	2637	TCP 1723 + GRE	Sí, pero ROTO	PROHIBIDO
2 · Enlace	L2TP y L2TPv3	2661 · 3931	UDP 1701	NO	Válido SOLO como L2TP/IPsec
3 · Red	GRE	2784	Protocolo IP 47	NO	Vigente, siempre bajo IPsec
3 · Red	IPsec — AH	4302	Protocolo IP 51	NO — integridad	En desuso; falla con NAT
3 · Red	IPsec — ESP	4303	Protocolo IP 50	SÍ	EL ESTÁNDAR
— · Claves	IKEv2	7296 (STD 79)	UDP 500 y 4500	Negocia las claves	Vigente; IKEv1 obsoleto
4-7	SSL/TLS VPN	9846	TCP 443	SÍ	Vigente: TLS 1.2 y 1.3

[Fuente: RFC 2637, 2661, 2784, 3931, 4302, 4303, 7296, 9395 y 9846 — verificados contra el índice oficial del RFC Editor · CCN-STIC-836]

D17 · IPsec: AH y ESP, modo transporte y modo túnel

Sección: §4.2.1 — Arquitectura y protocolos IPSec **Propósito**: El diagrama más denso del tema. Muestra **la estructura del paquete** en los dos modos, la diferencia entre AH y ESP, las dos fases de IKEv2 y el problema de NAT, que son los cuatro puntos clave.



[Fuente: RFC 4301, 4302, 4303, 7296, 3948, 8221, 8247 y 9395 — verificados contra el índice del RFC Editor · CCN-STIC-807 y 836]

D18 · IPsec frente a SSL/TLS: tabla de decisión

Sección: §4.2.2 — VPN basadas en SSL y TLS **Propósito**: Dar la **tabla de decisión** que resuelve el caso práctico típico —qué tecnología para qué necesidad— y fijar la razón real del éxito de las VPN SSL/TLS: el puerto 443.

No se elige «la mejor»: se elige la que encaja con el escenario

CRITERIO	IPsec	SSL/TLS VPN
Capa en la que opera	Red (3)	Transporte-aplicación (4-7)
Alcance	**TODO el tráfico IP, transparente**	Solo lo que se encamine al túnel
Software en el extremo	Cliente necesario y configurado	**Navegador o cliente ligero**
Paso por cortafuegos ajenos	**Problemático: protocolos 50/51, UDP 500/4500**	**Excelente: TCP 443, como HTTPS**
Traducción de direcciones (NAT)	Requiere NAT-T (RFC 3948)	**Nativo, sin configuración**
Rendimiento bruto	**Mejor, con aceleración por hardware**	**Peor: TCP dentro de TCP degrada**
Granularidad de la autorización	Por subredes y servicios	**Por aplicación y usuario**
ESCENARIO IDEAL	SITIO A SITIO y enlaces permanentes	ACCESO REMOTO de usuarios

LAS DOS MODALIDADES DE VPN SSL/TLS

SIN CLIENTE (clientless)
Solo navegador. Portal con aplicaciones web publicadas
Nivel efectivo: aplicación. Control del puesto: mínimo. Para terceros

CON CLIENTE (túnel completo)
Adaptador virtual: encamina CUALQUIER tráfico IP
Nivel efectivo: red. Permite comprobar el estado del dispositivo

Mismos límites de versión que HTTPS: prohibidos SSL 3.0 (RFC 7568) y TLS 1.0 y 1.1 (RFC 8996). Admisibles TLS 1.2 y TLS 1.3 (RFC 9846)

[Fuente: RFC 9846, 8996, 7568, 3948 y 7296 — verificados contra el índice del RFC Editor · ENS, mp.com.2 · CCN-STIC-836]

D19 · El puesto blindado: de antivirus a EDR y capas de defensa

Sección: §5.1 y §5.2 — Protección del puesto y del punto final **Propósito**: Cerrar el tema con la **escalera antivirus → EPP → EDR → XDR** y con las capas de defensa del puesto, cada una con su medida del ENS. Incluye los dos datos que más se fallan: qué exige el ENS en categoría ALTA y qué **no** protege el cifrado de disco.

El ENS nombra el EDR por su sigla, en op.exp.6.r4, y lo exige en categoría ALTA

LA ESCALERA DE LA PROTECCIÓN DEL PUNTO FINAL: QUÉ AÑADE CADA ESCALÓN

ANTIVIRUS
Firmas y heurística sobre FICHEROS
Ciego ante lo desconocido

EPP
Plataforma: antivirus + cortafuegos + cifrado + control
Sigue centrado en PREVENIR

EDR
Telemetría de COMPORTAMIENTO, investigación y AISLAMIENTO remoto
op.exp.6.r4 — exigible en ALTA

XDR
Correlación extendida: puesto, red, correo, identidad y nube
MDR: lo mismo, por un tercero

LAS CAPAS DEL PUESTO MUNICIPAL, DE ABAJO ARRIBA, Y SU MEDIDA

6 · LA PERSONA — concienciación y formación, incluida la ingeniería social	mp.per.3 y mp.per.4 — en las TRES categorías
5 · GESTIÓN CENTRALIZADA — línea base por GPO o MDM, parcheado por anillos, inventario	op.exp.2, op.exp.3, op.exp.4 y op.exp.1
4 · DETECCIÓN Y RESPUESTA — antimalware en tiempo real, escaneo periódico, lista blanca, EDR	op.exp.6 y sus refuerzos R1 a R4
3 · AISLAMIENTO LOCAL — cortafuegos personal con perfiles «en la oficina» y «fuera»	Frena el MOVIMIENTO LATERAL · art. 9
2 · DATOS EN REPOSO — cifrado de disco completo anclado al TPM, bloqueo por inactividad	mp.eq.3.r1, mp.eq.2 y mp.si.2
1 · ARRANQUE Y HARDWARE — UEFI con arranque seguro, contraseña de firmware, control de USB	op.exp.2 (mínima funcionalidad) y art. 22

EL ERROR QUE MÁS SE PENALIZA
El cifrado de disco protege SOLO el equipo APAGADO. Con la sesión abierta el disco está descifrado, también para el ransomware

op.exp.6 · LA TABLA QUE HAY QUE SABER
BÁSICA: la medida · MEDIA: + R1 + R2 (escaneo periódico y al arranque)
ALTA: + R1 + R2 + R3 (LISTA BLANCA) + R4 (EDR)

[Fuente: ENS, RD 311/2022, op.exp.6, op.exp.2, op.exp.4, mp.eq.1 a mp.eq.4 y mp.per.3 y 4 — verificado contra el PDF del BOE]

Casos prácticos

Los tres casos giran sobre el supuesto de referencia del tema (ver la pestaña Contenido, «Convenciones»): la **red corporativa municipal** gestionada por el IAM, con su CPD, una oficina de atención a la ciudadanía de distrito y los portátiles de los empleados que teletrabajan. El **Caso 1** trabaja el **perímetro y la segmentación** de una oficina de distrito; el **Caso 2**, el **acceso remoto y la VPN** de 900 teletrabajadores; y el **Caso 3**, un **incidente real de ransomware** que entra por un portátil, con su contención y su respuesta.

Caso 1 — Rediseño del perímetro y la red de una oficina de distrito

Enunciado

La Junta Municipal de un distrito va a reformar su Oficina de Atención a la Ciudadanía. La situación de partida, verificada en una visita técnica, es la siguiente:

- **Toda la oficina comparte un único segmento de red** (una sola VLAN, direccionamiento `10.30.7.0/24`): los 18 puestos de los tramitadores, dos impresoras multifunción, las pantallas de gestión de turnos, ocho cámaras de videovigilancia IP y un punto de acceso Wi-Fi abierto para el público.
- La oficina se conecta al CPD central por una **línea del operador contratada como «VPN MPLS»**. El pliego del operador afirma que «el tráfico viaja aislado del de otros clientes».
- Existe además un **encaminador 4G de respaldo**, contratado directamente por la Junta el año pasado, conectado a un puerto del conmutador «por si se cae la línea principal».
- El cortafuegos del CPD tiene, para esta oficina, una regla que permite **todo el tráfico** desde `10.30.7.0/24` hacia la red de servidores, «porque son de casa».
- Se quiere además **publicar en internet** un nuevo servicio de **cita previa** para trámites presenciales, alojado en un servidor que hoy está en la red de servidores del CPD.
- El sistema de información municipal afectado está categorizado **MEDIA** conforme al ENS.

Se solicita un informe técnico de rediseño previo a la reforma.

Cuestiones

Cuestión 1 — Segmentación de la oficina (3 puntos). Analice el diseño de red actual de la oficina, identifique los riesgos y proponga la segmentación que exige el ENS, indicando la medida y el refuerzo aplicables.

Cuestión 2 — El perímetro y sus dos reglas (2,5 puntos). Valore el encaminador 4G de respaldo y la regla del cortafuegos del CPD. Cite los preceptos y medidas que resultan vulnerados.

Cuestión 3 — La «VPN MPLS» del operador (2 puntos). ¿Cumple el enlace contratado la medida `mp.com.2` del ENS? Justifique la respuesta y proponga la solución conforme.

Cuestión 4 — Publicación del servicio de cita previa (2,5 puntos). Diseñe la publicación del nuevo servicio indicando dónde se ubica, qué arquitectura de DMZ propone y qué reglas direccionales deben respetarse.

▾ Ver solución orientativa

Solución orientativa

Cuestión 1 — Segmentación (§2.4.1, §1.4)

El diseño actual concentra en un único dominio de difusión cinco poblaciones con perfiles de riesgo radicalmente distintos. Los riesgos concretos:

Elemento en el segmento común	Riesgo que introduce
Wi-Fi abierto al público	Cualquier ciudadano en la sala de espera obtiene enlace en la misma red que los puestos de tramitación: puede escanear, envenenar ARP y colocarse como intermediario
Cámaras IP	Dispositivos IoT, con firmware raramente actualizado y credenciales por defecto frecuentes: son la puerta de entrada clásica
Impresoras multifunción	Almacenan temporalmente documentos escaneados y suelen exponer interfaces de administración sin autenticar
Puestos de tramitación	Tratan datos personales de ciudadanos; comprometer uno da acceso al gestor de expedientes

Propuesta de segmentación, con su respaldo normativo:

- `mp.com.4.2` —obligación base, no refuerzo— exige que, si hay comunicaciones inalámbricas, sea **en un segmento separado**: el Wi-Fi público sale a una VLAN propia, con salida directa a internet y **sin ninguna ruta hacia la red municipal**.
- `mp.com.4.r1.2` exige segregar como mínimo en **usuarios, servicios y administración**. Se propone: VLAN de puestos, VLAN de dispositivos (impresoras, turnos, cámaras), VLAN de administración de los equipos de red y VLAN de invitados.

- Como el sistema es de **categoría MEDIA**, la tabla de aplicación de `mp.com.4` es `+ [R1 o R2 o R3]`: basta con **VLAN (R1)**, aunque conviene anotar que en categoría **ALTA** el R1 dejaría de ser suficiente.
- `mp.eq.4` alcanza expresamente a **impresoras, dispositivos multimedia, IoT y BYOD**, exigiéndoles configuración de seguridad adecuada; en nivel MEDIO de confidencialidad añade **R1**, productos del **CPSTIC**.
- Medidas complementarias de capa 2 (§1.3.1): **802.1X** en las rosetas de la zona de público, **seguridad de puerto**, **inspección dinámica de ARP** y **vigilancia de DHCP**.

Cuestión 2 — El perímetro (§2.1, §1.4)

El encaminador 4G es el hallazgo más grave del caso. Constituye una **salida alternativa no controlada** que vulnera directamente `mp.com.1.1`: «Todo el tráfico deberá atravesar dicho sistema». Si existe un camino que no pasa por el perímetro, **el perímetro no existe**. Además:

- Vulnera el **art. 21 del ENS**: la inclusión de cualquier elemento en el catálogo de activos **requiere autorización formal previa**, y este fue contratado por la Junta al margen del IAM.
- Vulnera el **art. 23**, porque introduce una **interconexión** cuyos riesgos no se han analizado y cuyo punto de unión no se controla.
- La solución no es retirar la redundancia —que es legítima y deseable por disponibilidad— sino **integrarla**: el respaldo debe terminar en el **mismo equipo perimetral**, con la misma política, conmutación automática y el túnel cifrado levantándose igualmente sobre él.

La regla «permitir todo desde la oficina hacia los servidores» vulnera `mp.com.1.2` («todos los flujos… autorizados previamente»), el principio de **denegación por defecto** y el **mínimo privilegio** del art. 20 y de `op.acc.4.2`. Debe sustituirse por reglas explícitas: **origen** la VLAN de puestos —no la oficina entera—, **destino** los servidores concretos del gestor de expedientes y del directorio, **servicios** los puertos concretos, y regla final de **denegar y registrar**.

Cuestión 3 — La «VPN MPLS» (§4.1, §4.2.3)

No cumple `mp.com.2`. El razonamiento, que es el núcleo de la cuestión:

- `mp.com.2.1` exige «**redes privadas virtuales cifradas** cuando la comunicación discurra por **redes fuera del propio dominio de seguridad**». La red del operador **es un dominio ajeno**.
- **MPLS aísla, pero no cifra**: proporciona privacidad **administrativa** —el tráfico de un cliente no se entrega a otro— pero no **criptográfica**. El operador, o quien comprometa su red, ve el tráfico en claro.

- El nombre comercial «VPN MPLS» induce a error, y es exactamente el tipo de afirmación de pliego que un técnico debe saber contradecir.

Solución conforme: **cifrar por encima** con un túnel **IPsec en modo túnel con ESP** entre la pasarela de la oficina y la del CPD, autenticado **por certificados** —no por clave precompartida—, sobre el enlace MPLS. Al ser el sistema de categoría MEDIA, aplica `mp.com.2 + R1` : **algoritmos y parámetros autorizados por el CCN**, es decir, conformes a la **CCN-STIC-807**; y `mp.com.3 + R1 + R2` para integridad y autenticidad. Es, además, la arquitectura habitual de **SD-WAN sobre MPLS**.

Cuestión 4 — Publicación de la cita previa (§2.4.1)

El servicio **no puede quedarse en la red de servidores**: pasa a ser alcanzable desde internet y debe alojarse en una **DMZ**.

- **Arquitectura propuesta**: **doble cortafuegos** (subred apantallada) si el presupuesto lo permite, idealmente de **fabricantes distintos**, por defensa en profundidad; o **cortafuegos de tres patas** como mínimo aceptable, documentando el riesgo de concentrar en un solo equipo la separación entre internet y la red interna.
- **Reglas direccionales**: internet → DMZ solo por **TCP 443**; DMZ → red interna **prohibido iniciar**. Si la aplicación de cita previa necesita consultar el calendario de la oficina, la conexión debe **originarse en la red interna** o resolverse con un servicio intermedio en la propia DMZ.
- Delante del servicio, un **proxy inverso** que termine el TLS, equilibre carga, oculte la topología e integre **WAF** — medida `mp.s.2` , que ya en categoría BÁSICA exige `+ [R1 o R2]` .
- `op.mon.1 + R1` por ser categoría MEDIA: detección de intrusiones **basada en reglas** sobre el tráfico publicado.
- `mp.s.4` , protección frente a denegación de servicio: **aplica desde nivel MEDIO** de disponibilidad, y la mitigación real debe estar **aguas arriba**, en el operador, porque el cortafuegos propio no sirve contra un ataque volumétrico.

Criterios de evaluación

Cuestión	Elemento evaluado	Puntos
C1	Identificar los riesgos del segmento único, en especial Wi-Fi público y cámaras IoT	1,0
C1	Citar `mp.com.4.2` (inalámbrica en segmento separado) y `mp.com.4.r1.2` (usuarios, servicios, administración)	1,0
C1	Situar correctamente la tabla de aplicación en categoría MEDIA y citar `mp.eq.4`	1,0
C2	Detectar el encaminador 4G como salida no controlada y vincularlo a `mp.com.1.1`	1,5
C2	Corregir la regla «permitir todo» invocando `mp.com.1.2` y el mínimo privilegio	1,0
C3	Afirmar que MPLS **no cifra** y que por sí solo no cumple `mp.com.2.1`	1,2
C3	Proponer IPsec ESP en modo túnel con certificados y citar el refuerzo R1 (CCN-STIC-807)	0,8
C4	Ubicar el servicio en DMZ y elegir arquitectura justificándola	1,0
C4	Enunciar correctamente la regla direccional DMZ → interna	1,0
C4	Añadir proxy inverso con WAF (`mp.s.2`) y mitigación DDoS aguas arriba (`mp.s.4`)	0,5

Caso 2 — Acceso remoto y VPN para 900 empleados en teletrabajo

Enunciado

El Ayuntamiento va a regularizar el teletrabajo de **900 empleados municipales**, dos días por semana. La propuesta que llega a la mesa técnica es la siguiente:

- Se usará una **VPN de acceso remoto** con la pasarela **instalada en la red interna**, publicada a internet mediante una redirección de puertos en el cortafuegos.

- Autenticación con **usuario y contraseña** del directorio corporativo, «con política de contraseña robusta de 12 caracteres y caducidad de 90 días».
- **Túnel dividido**, «para no saturar el enlace de la sede central con el vídeo de las reuniones y la navegación personal».
- Una vez conectado, el empleado **queda en la misma VLAN de puestos** que si estuviera en la oficina, «para que todo le funcione igual».
- Los empleados usarán **su equipo personal**, «porque no hay presupuesto para 900 portátiles», con un cliente VPN instalado.
- Para los proveedores externos se creará **una cuenta por empresa**, compartida entre sus técnicos.
- Además, se pide dimensionar la solución para el **enlace permanente con el centro de proceso de respaldo** que el Ayuntamiento tiene en otro emplazamiento.
- El sistema está categorizado **MEDIA**, con confidencialidad de nivel **MEDIO**.

Cuestiones

Cuestión 1 — Identificación y autenticación (3 puntos). Valore la propuesta de autenticación y la de cuentas de proveedor. Indique qué exige el ENS y cuál es el mínimo para cumplir.

Cuestión 2 — Arquitectura del acceso (3 puntos). Analice la ubicación de la pasarela, la decisión sobre el túnel y el alcance concedido al empleado conectado. Proponga el diseño correcto.

Cuestión 3 — El equipo del empleado (2 puntos). Valore el uso del equipo personal y proponga alternativas viables, con su fundamento jurídico.

Cuestión 4 — Tecnología para cada escenario (2 puntos). Elija la tecnología de VPN para el teletrabajo y para el enlace con el centro de respaldo, justificando ambas decisiones.

▾ Ver solución orientativa

Solución orientativa

Cuestión 1 — Identificación y autenticación (§3.2)

La autenticación propuesta no cumple. Con confidencialidad de nivel **MEDIO**, `op.acc.5` exige `+ [R2 o R3 o R4] + R5`:

- **La opción R1 —contraseña sola— deja de estar disponible** a partir de nivel MEDIO, **por robusta que sea**. La longitud y la caducidad son irrelevantes para la conformidad: lo que falta es un **segundo factor**.
- Mínimo para cumplir: añadir **R2** (contraseña de un solo uso, por aplicación autenticadora preferentemente al SMS) o **R3/R4** (**certificado cualificado** protegido por segundo factor,

con registro previo); **más R5**: registrar los accesos **con éxito y fallidos** e informar al usuario de su **último acceso**.

- Debe añadirse la **limitación del número de intentos** (`op.acc.5.8`) y la **política específica de acceso remoto con autorización expresa** (`op.acc.4.5`).

Las cuentas compartidas por empresa proveedora están prohibidas. `op.acc.1.3` exige un **identificador singular** por cada entidad, y una cuenta compartida **destruye la trazabilidad**: ninguna acción es atribuible a una persona, lo que además incumple `op.exp.8` y el art. 24. Lo correcto: **cuenta nominal** para cada técnico del proveedor, **certificado** emitido para él, **ventana temporal acotada al ticket**, acceso **exclusivamente al servidor de salto** y **revocación automática** al cierre. Complementariamente, `op.acc.1.2` : los administradores no administran con su cuenta ofimática.

Cuestión 2 — Arquitectura (§3.1, §4.1.2)

Tres errores encadenados:

1. **La pasarela no puede estar en la red interna.** Debe ubicarse en la **DMZ**, publicada con la superficie mínima. Una redirección de puertos hacia un equipo interno significa que, si se compromete la pasarela, el atacante está **dentro** sin cruzar ninguna otra frontera. Es contrario al art. 23 y a la lógica de `mp.com.1` .
2. **El túnel dividido es la opción incorrecta por defecto en un entorno del ENS.** Con él, la navegación del empleado **escapa al control corporativo** y `mp.s.3` (protección de la navegación web, con su normativa de uso, sus listas y su registro) deja de ser aplicable; y el equipo queda **con un pie en cada red**, convertido en puente potencial, lo que compromete el art. 9. Lo correcto es **túnel completo**, y si el ancho de banda es un problema real, tratarlo como **excepción justificada y acotada** —por ejemplo, excluyendo únicamente el servicio corporativo de videoconferencia—, nunca como regla general que incluya la navegación personal.
3. **Dejar al teletrabajador en la VLAN de puestos vulnera** `mp.eq.3.3` , que obliga a limitar «la información y los servicios accesibles a los mínimos imprescindibles» cuando la conexión llega por redes no controladas. Diseño correcto: **segmento de teletrabajo** propio, desde el que se alcanzan el gestor de expedientes, el correo, la intranet y la impresión, y **no** se alcanzan la red de administración de sistemas, la de videovigilancia ni los puestos de otros compañeros.

Debe añadirse **comprobación del estado del dispositivo** antes de conceder acceso, con desvío a **cuarentena** para remediación si no cumple, y **registro** completo enviado al SIEM (`op.mon.3.r1` , exigible en MEDIA).

Cuestión 3 — El equipo del empleado (§5, §3.1)

El uso del equipo personal es la decisión de mayor riesgo del caso, y además es **jurídicamente discutible**:

- El **art. 47 bis del TREBEP** dispone que **«la Administración proporcionará a la persona los medios tecnológicos necesarios»** para el teletrabajo. La propuesta traslada al empleado una obligación que la norma sitúa en la Administración.
- Técnicamente, un equipo personal **no puede cumplir** `op.exp.2` (bastionado y mínima funcionalidad), `op.exp.4` (parcheado gestionado), `op.exp.6` (antimalware corporativo con protección en tiempo real) ni `mp.eq.3.r1` (cifrado de disco), y no es inventariable conforme a `mp.eq.3.1`. Una VPN sobre un equipo no controlado es un túnel cifrado y seguro que lleva el problema directamente al centro de la red: **la VPN protege el canal, no los extremos**.

Alternativas viables, en orden de preferencia:

1. **Portátil corporativo gestionado**, con MDM/UEM, cifrado, EDR y línea base — la opción conforme.
2. **Escritorio virtual (VDI)** o publicación de aplicaciones: el dato **nunca sale** del CPD y el equipo personal actúa solo como terminal, con el portapapeles y la redirección de unidades deshabilitados. Es la solución de compromiso más defendible si no hay presupuesto para equipos.
3. **VPN SSL/TLS sin cliente** contra un portal de aplicaciones web concretas, para casos puntuales y de bajo riesgo.
4. Si aun así se admitiera BYOD, `mp.eq.4` lo alcanza expresamente y exigiría, como mínimo, contenedor corporativo separado, exigencia de cifrado y PIN, y borrado remoto del contenedor.

Cuestión 4 — Tecnología para cada escenario (§4.2)

Teletrabajo — VPN de acceso remoto con cliente. Se propone un producto que ofrezca **IKEv2 como camino principal** —mejor rendimiento, y **MOBIKE** permite pasar del Wi-Fi doméstico a la red móvil sin que se caiga el túnel— y **TLS sobre TCP 443 como respaldo**, para redes ajenas que bloqueen IPsec. La decisión no es «IPsec **o** TLS», sino un diseño con **camino principal y alternativo**. Configuración: túnel completo, MFA, certificado de dispositivo, comprobación de estado y segmento de teletrabajo.

Enlace con el centro de respaldo — IPsec en modo túnel con ESP. Argumentos: son **dos redes** con direccionamiento fijo y pasarelas propias; el enlace es **permanente y de alto caudal** —por él irán replicación de bases de datos y copias de seguridad—, y ahí IPsec rinde mejor y se acelera por hardware; la **transparencia para las aplicaciones** es imprescindible; y no hay cortafuegos ajenos que atravesar. Autenticación **por certificados**, **rekey** periódico,

algoritmos conformes a la **CCN-STIC-807**, y producto del **CPSTIC** por exigirlo `op.pl.5` desde categoría MEDIA. Recuérdese abrir **UDP 500 y 4500** y los protocolos IP **50** —y no solo el 500, error clásico que deja el túnel levantado sin cursar tráfico—.

Criterios de evaluación

Cuestión	Elemento evaluado	Puntos
C1	Afirmar que la contraseña sola no cumple en nivel MEDIO y citar `+ [R2 o R3 o R4] + R5`	1,5
C1	Prohibir la cuenta compartida por trazabilidad, citando `op.acc.1.3` y `op.exp.8`	1,0
C1	Añadir `op.acc.4.5`, política específica con autorización expresa	0,5
C2	Trasladar la pasarela a la DMZ y justificarlo	1,0
C2	Rechazar el túnel dividido con el argumento de `mp.s.3` y del art. 9	1,0
C2	Crear un segmento de teletrabajo invocando `mp.eq.3.3`	1,0
C3	Invocar el art. 47 bis del TREBEP (medios a cargo de la Administración)	1,0
C3	Proponer una alternativa viable (equipo corporativo o VDI) con su razonamiento	1,0
C4	Elegir IKEv2 con respaldo TLS para el acceso remoto, con argumentos	1,0
C4	Elegir IPsec ESP en modo túnel para el enlace permanente, con argumentos	1,0

Caso 3 — Incidente: ransomware entrado por un portátil municipal

Enunciado

Un lunes a las 08:40, el CAU municipal recibe tres llamadas de una misma unidad administrativa: «los ficheros de la carpeta compartida se abren con caracteres raros y ha aparecido un documento de texto pidiendo dinero». La investigación inicial establece:

- El **viernes anterior a las 19:10**, una empleada recibió en su correo corporativo un mensaje que aparentaba proceder de un proveedor habitual, redactado en castellano correcto y con el asunto de un expediente real en tramitación. Abrió el enlace y **escribió sus credenciales** en una página que imitaba el acceso a la intranet.
- La empleada **se dio cuenta a los diez minutos** de que la página no era la corporativa, pero **no avisó**: «era viernes por la tarde y me dio apuro, pensé que si no había pasado nada no hacía falta molestar».
- El **sábado por la mañana**, esas credenciales se usaron para conectarse a la **VPN de acceso remoto**, que solo pide usuario y contraseña.
- Desde el segmento de teletrabajo, el atacante alcanzó **un servidor de ficheros** cuya versión de sistema operativo **está fuera de soporte desde octubre de 2025**, y desde él se movió a otros seis servidores.
- El **antivirus** de los servidores estaba actualizado y **no detectó nada**: el atacante empleó herramientas legítimas del propio sistema.
- Los **registros del cortafuegos** existen, pero **nadie los revisa**: no hay correlación ni alertas.
- Las **copias de seguridad** se guardan en un recurso compartido de la propia red, montado permanentemente en el servidor de copias. **Están cifradas por el atacante**.
- El sistema está categorizado **ALTA** por su dimensión de disponibilidad.

Cuestiones

Cuestión 1 — Cadena del incidente y medidas incumplidas (3 puntos). Reconstruya la cadena del ataque paso a paso e identifique, en cada eslabón, la medida del ENS que habría debido detenerlo.

Cuestión 2 — Contención inmediata (2,5 puntos). Enumere y ordene las acciones de contención de las primeras dos horas, justificando el orden.

Cuestión 3 — Obligaciones de notificación (2 puntos). Indique a quién y en qué plazo debe notificarse el incidente, distinguiendo las obligaciones que concurren.

Cuestión 4 — Plan de mejora (2,5 puntos). Proponga las medidas que impedirían la repetición, ordenadas por eficacia y con su respaldo normativo.

▾ Ver solución orientativa

Solución orientativa

Cuestión 1 — La cadena y sus eslabones (§1.2, §5, §2.3)

Eslabón	Qué ocurrió	Medida del ENS que lo habría detenido
1. Acceso inicial	Phishing dirigido, con contexto real y castellano correcto — coherente con el dato de que más del 80 % de la ingeniería social ya usa IA	`mp.per.3` (concienciación: ingeniería social) y `mp.s.1` (protección del correo, con SPF, DKIM y DMARC y aislamiento de enlaces)
2. No notificación	La empleada detectó el error y **no avisó** por temor al reproche	`mp.per.3.3` : el procedimiento para informar **«sean reales o falsas alarmas»**. Es un fallo **de cultura organizativa**, no de la persona
3. Entrada por la VPN	Credencial robada + VPN **sin segundo factor**	`op.acc.5` : en categoría ALTA, `+ [R2 o R3 o R4] + R5` . **Un segundo factor habría cortado el ataque aquí**, con la credencial ya en poder del atacante
4. Alcance excesivo	Desde el segmento de teletrabajo se llegaba a servidores de ficheros	`mp.eq.3.3` (mínimos imprescindibles desde redes no controladas) y `mp.com.4` (en ALTA, `+ [R2 o R3] + R4`)
5. Servidor vulnerable	Sistema **fuera de soporte** desde octubre de 2025	`op.exp.4` : procedimiento de análisis, priorización y aplicación de actualizaciones. Y art. 21 (integridad y actualización del sistema)
6. Movimiento lateral	Seis servidores más, con herramientas legítimas del sistema	`op.exp.6.r4` (**EDR**, exigible en ALTA) y `op.exp.6.r3` (**lista blanca**). El antivirus por firmas es ciego ante el **malware sin fichero**
7. Nadie lo vio	Registros sin revisar, sin correlación ni alertas	`op.mon.1` (detección de intrusión; en ALTA, `+ R1 + R2` con **procedimientos de respuesta**) y `op.mon.3.r1` (**correlación**, el SIEM)
8. Copias cifradas	Recurso de copia **montado permanentemente** en la red	`mp.info.6.r2.1` , exigible en nivel **ALTO**: «al menos, una de las copias de seguridad se almacenará de forma **separada en lugar diferente**, de tal manera que **un incidente no pueda afectar tanto al repositorio original como a la copia**

Eslabón	Qué ocurrió	Medida del ENS que lo habría detenido
		simultáneamente». Es literalmente lo que ocurrió

La lectura de conjunto es la que importa: **ninguno de los ocho eslabones era inevitable**, y el art. 9 del ENS —líneas de defensa— presupone precisamente que varios fallarán. Aquí fallaron **todos**, porque en realidad **no había capas independientes**: había una sola, la contraseña.

Cuestión 2 — Contención en las dos primeras horas (§2.3, §5.2.1)

Orden propuesto, con su justificación:

1. **Activar el procedimiento de gestión de incidentes** y constituir el equipo (`op.exp.7`). Sin mando único, las acciones se pisan.
2. **Cortar el acceso remoto**: deshabilitar la cuenta comprometida y, si es necesario, **suspender la VPN** completa. Es el camino por el que el atacante sigue entrando.
3. **Aislar en red los sistemas afectados**, con EDR si lo hay, o desconectando el puerto del conmutador. **No apagar los equipos**: apagar destruye la memoria volátil, que es la evidencia más valiosa.
4. **Segmentar de urgencia**: cortar el tráfico entre el segmento afectado y el resto, para frenar la propagación.
5. **Preservar evidencias**: registros del cortafuegos, de la VPN, del directorio y de los servidores, con **copia y sellado** antes de que roten.
6. **Rotar credenciales** de las cuentas privilegiadas y forzar cambio de contraseña, empezando por las de administración del dominio.
7. **Verificar el estado real de las copias**: localizar la copia más reciente **no comprometida**, incluidas cintas o copias fuera de línea, antes de plantear cualquier restauración.
8. **Comunicación interna** controlada: qué se dice al personal y a los responsables, y **canal alternativo** si el correo está comprometido.

Lo que **no** debe hacerse: pagar el rescate; restaurar sobre los mismos sistemas sin haber determinado el vector, porque se vuelven a cifrar; ni «limpiar y seguir» sin análisis forense.

Cuestión 3 — Notificaciones (§1.1, §1.4)

Concurren **dos obligaciones distintas, por vías distintas**, y confundirlas es error habitual:

- **Por el ENS**: notificación al **CCN-CERT** conforme al **art. 33** del ENS (capacidad de respuesta a incidentes) y a la **Instrucción Técnica de Seguridad de Notificación de Incidentes de Seguridad** (Resolución de 13 de abril de 2018), con la clasificación y los plazos que esta fija según la peligrosidad y el impacto.

- **Por protección de datos**: si el incidente afecta a datos personales —y aquí los afecta, por el contenido de los expedientes—, notificación a la **AEPD** en un plazo máximo de **72 horas** desde que se tuvo conocimiento (**art. 33 del RGPD**), y **comunicación a los interesados** si el riesgo para sus derechos es alto (**art. 34**). Debe documentarse el incidente en el **registro de violaciones de seguridad**, con independencia de que se notifique o no.
- Debe valorarse además la **denuncia** ante las Fuerzas y Cuerpos de Seguridad del Estado, y la comunicación a los responsables de la información y del servicio (art. 11).

Cuestión 4 — Plan de mejora, ordenado por eficacia (§5, §3.2, §2.4)

Prioridad	Medida	Por qué es la más eficaz	Respaldo
1	**MFA obligatorio** en la VPN y en todo acceso remoto	Habría cortado el ataque **con la credencial ya robada**: es el único control que neutraliza el 60 % de los vectores de entrada	`op.acc.5` en nivel ALTO
2	**Copias fuera de línea o inmutables**, con prueba de restauración	Es lo único que revierte de verdad un ransomware ya consumado	`mp.info.6.r2` (copia separada) y `mp.info.6.r1` (probar la restauración)
3	**EDR** en puestos y servidores, con capacidad de aislamiento	Detecta el **malware sin fichero** y el movimiento lateral, que el antivirus no ve	`op.exp.6.r4`, exigible en ALTA
4	**Plan de salida de sistemas fuera de soporte**, con calendario y presupuesto	Elimina la vulnerabilidad explotada; ninguna otra medida la compensa	`op.exp.4` · art. 21
5	**Segmentación efectiva** y revisión del alcance del segmento de teletrabajo	Convierte un incidente total en un incidente local	`mp.com.4` en ALTA · `mp.eq.3.3`
6	**SIEM con correlación y procedimientos de respuesta** a las alertas	Reduce el tiempo de detección, que aquí fue de **más de 48 horas**	`op.mon.3.r1` · `op.mon.1.r2`
7	**Programa de concienciación** con simulaciones y, sobre todo, **cultura de notificación sin reproche**	Diez minutos de aviso el viernes habrían evitado todo lo demás	`mp.per.3` y `mp.per.4`

El punto 7 merece un desarrollo propio, porque es el que suele quedar peor tratado. El indicador que hay que medir no es solo el **porcentaje de clics** —que debe bajar— sino el **porcentaje de notificaciones** —que debe **subir**— y el **tiempo hasta la primera notificación** —que debe bajar—. Un organismo donde el 20 % pincha pero el 60 % avisa en cinco minutos

está objetivamente mejor protegido que otro donde solo pincha el 5 % y nadie avisa. Ambos indicadores alimentan `op.mon.2`, el sistema de métricas del ENS, y `mp.per.4` exige expresamente **evaluar la eficacia** de las acciones formativas.

Criterios de evaluación

Cuestión	Elemento evaluado	Puntos
C1	Reconstruir la cadena completa en orden, sin saltarse eslabones	1,0
C1	Identificar el MFA ausente como el punto de corte más eficaz	1,0
C1	Vincular al menos cuatro eslabones con su medida concreta del ENS	1,0
C2	Ordenar correctamente: cortar el acceso antes de aislar y aislar antes de restaurar	1,0
C2	Indicar que **no se apagan** los equipos, por preservación de evidencias	0,7
C2	Verificar el estado de las copias antes de plantear la restauración	0,8
C3	Distinguir las dos vías: CCN-CERT por el ENS y AEPD en 72 horas por el RGPD	1,2
C3	Citar el art. 33 del ENS y la ITS de Notificación de Incidentes	0,8
C4	Priorizar el MFA y las copias inmutables por delante del resto	1,2
C4	Incluir la cultura de notificación y proponer indicadores medibles	1,3

Fuentes

Tier 1 — Normativa y estándares

Normativa española y europea

ID	Referencia
`[ENS]`	Real Decreto **311/2022, de 3 de mayo**, por el que se regula el **Esquema Nacional de Seguridad** (BOE núm. 106, de 4 de mayo de 2022), texto consolidado. Es la fuente principal de este tema. Se citan, **verificados contra el PDF del BOE**: los **principios básicos** de los arts. 5 a 11 —en especial el **art. 9 (líneas de defensa)**, el **art. 10 (vigilancia continua)** y el **art. 11 (diferenciación de responsabilidades)**—; el **art. 20 (mínimo privilegio)**, el **art. 21 (integridad y actualización)**, el **art. 22 (protección de la información almacenada y en tránsito)**, el **art. 23 (prevención ante otros sistemas interconectados)** —base legal de la seguridad perimetral—, el **art. 24 (registro de actividad)**, el **art. 32 (informe del estado de la seguridad)** y el **art. 33 (capacidad de respuesta a incidentes)**; y del **anexo II**, las medidas `op.pl.5` (componentes certificados y CPSTIC), `op.acc.1` **a** `op.acc.6` —con `op.acc.4.5`, política específica de acceso remoto—, `op.exp.1` **a** `op.exp.8` —con `op.exp.2`, `op.exp.4` y `op.exp.6` y sus refuerzos R3 (lista blanca) y **R4 (EDR)**—, `op.mon.1` **a** `op.mon.3`, `mp.per.3` **y** `mp.per.4`, `mp.eq.1` **a** `mp.eq.4`, `mp.com.1` **a** `mp.com.4`, `mp.si.2`, `mp.info.6` y `mp.s.1` **a** `mp.s.4`.
`[ITS]`	**Instrucciones Técnicas de Seguridad** del ENS. Las **cuatro publicadas** en el BOE: **Conformidad con el ENS** e **Informe del Estado de la Seguridad** (Resoluciones de 13 y 7 de octubre de 2016, `BOE-A-2016-10109` y `BOE-A-2016-10108`); **Auditoría de la Seguridad de los Sistemas de Información** (Resolución de 27 de marzo de 2018, `BOE-A-2018-4573`); y **Notificación de Incidentes de Seguridad** (Resolución de 13 de abril de 2018, `BOE-A-2018-5370`). **Verificado en el portal oficial del ENS del CCN**: **no** están publicadas la ITS de **Interconexión de Sistemas de Información** —a la que remite `mp.com.1`—, la de **Criptología** ni la de **Adquisición de productos de seguridad**.
`[L40-2015]`	Ley **40/2015, de 1 de octubre**, de Régimen Jurídico del Sector Público. **Art. 156.2**, fundamento legal del ENS y del ENI; art. 38 (sede electrónica) y art. 41 (actuación administrativa automatizada).
`[L39-20`	Ley **39/2015, de 1 de octubre**, del Procedimiento Administrativo Común. Sistemas de **identificación** (art. 9) y de **firma** (art. 10) de los interesados, y derecho a relacionarse electrónicamente (art. 14).

ID	Referencia
`15`	
`]`	
`[TREBEP]`	Real Decreto Legislativo **5/2015, de 30 de octubre**, texto refundido de la Ley del Estatuto Básico del Empleado Público. **Artículo 47 bis (teletrabajo)**, introducido por el **Real Decreto-ley 29/2020, de 29 de septiembre** (`BOE-A-2020-11415`): teletrabajo **expresamente autorizado**, **voluntario y reversible**, compatible con la modalidad presencial, y con la Administración obligada a **proporcionar los medios tecnológicos** necesarios.
`[RGPD]`	Reglamento (UE) **2016/679**, General de Protección de Datos. Art. **5.1.f** (integridad y confidencialidad), art. **32** (seguridad del tratamiento, con mención expresa del **cifrado**) y arts. **33 y 34** (notificación de violaciones de seguridad: **72 horas** a la autoridad de control, y comunicación a los interesados cuando el riesgo sea alto).
`[LOPDGDD]`	Ley Orgánica **3/2018, de 5 de diciembre**, de Protección de Datos Personales y garantía de los derechos digitales. Relevante, además, por sus derechos digitales en el ámbito laboral (arts. 87 a 91: intimidad frente al uso de dispositivos, videovigilancia y desconexión digital).
`[NIS2]`	Directiva (UE) **2022/2555**, relativa a las medidas destinadas a garantizar un elevado nivel común de **ciberseguridad** en la Unión. **Pendiente de transposición en España en agosto de 2026**: el **anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad** fue aprobado por el Consejo de Ministros el **14 de enero de 2025** y continúa en tramitación, sin publicación en el BOE; el plazo de transposición del art. 41 venció el **17 de octubre de 2024** y la Comisión Europea remitió a España **dictamen motivado** en 2025.
`[EIDAS2]`	Reglamento (UE) **2024/1183**, que modifica el Reglamento (UE) 910/2014 en lo relativo al **marco europeo de identidad digital**. Marco de los **certificados cualificados** exigidos por `op.acc.5.r3` y `op.acc.5.r4` , y de la **cartera de identidad digital**.
`[LSSI]`	Ley **34/2002, de 11 de julio**, de servicios de la sociedad de la información y de comercio electrónico. Citada por el régimen de **cookies** del art. 22.2, relevante en la política de navegación de `mp.s.3.7` .

Guías del Centro Criptológico Nacional (serie CCN-STIC)

ID	Referencia
`[CCN-408]`	**CCN-STIC-408**, *Seguridad perimetral — cortafuegos*. Guía de acceso público del CCN-CERT. Referencia española para el diseño y la configuración del cortafuegos perimetral.
`[CCN-836]`	**CCN-STIC-836**, *Seguridad en VPN en el marco del ENS*. Guía de referencia para la sección 4 completa: selección de tecnología, algoritmos, parámetros y despliegue de VPN conformes al ENS.
`[CCN-807]`	**CCN-STIC-807**, *Criptología de empleo en el Esquema Nacional de Seguridad*. Fija los **algoritmos y parámetros criptográficos autorizados** y sus longitudes de clave por nivel. Es la guía a la que remiten `mp.com.2.r1` y `mp.com.3.r2` cuando exigen «algoritmos y parámetros **autorizados por el CCN**», y la referencia correcta en un pliego, en lugar de congelar un número de RFC.
`[CCN-105]`	**CCN-STIC-105**, *Catálogo de Productos y Servicios de Seguridad de las TIC (CPSTIC)*. Tres secciones: productos **aprobados** (información clasificada), productos y servicios **cualificados** (información sensible en el ámbito del ENS) y productos y servicios de conformidad y gobernanza. Es el catálogo al que remite **`op.pl.5`**, exigible **desde categoría MEDIA**. Versión de **agosto de 2026**.
`[CCN-140]`	**CCN-STIC-140**, *Taxonomía de referencia para productos y servicios de seguridad TIC*. Clasifica los productos en categorías y familias y define los **Requisitos Fundamentales de Seguridad (RFS)** de cada familia, que es lo que debe cumplir un cortafuegos, una pasarela VPN o un EDR para entrar en el CPSTIC.
`[CCN-500]`	Series **CCN-STIC 500 y 600**, guías de **bastionado** por tecnología (sistemas operativos, servidores web, servidores de correo, DNS, SSH, equipos de red). Exigidas por el **art. 20.d** del ENS y por `op.exp.2`.

Especificaciones del IETF (RFC) — verificadas contra el índice del RFC Editor

ID	Referencia
`[RFC-ED]`	**RFC Editor**, `rfc-index.txt`. Índice oficial de la serie: número, título, autores, fecha, formato, relaciones `Obsoletes` / `Obsoleted by` / `Updates` y estado. Fuente de verificación de todas las entradas de esta tabla.
`[RFC 4301]`	*Security Architecture for the Internet Protocol* (diciembre de 2005). Arquitectura general de **IPsec**; obsoleta el RFC 2401. Define las **SA**, la **SAD** y la **SPD** con sus tres acciones (descartar, omitir IPsec, aplicar IPsec).
`[RFC 4302]`	*IP Authentication Header* (**AH**). Protocolo IP **51**: integridad y autenticación del origen, **sin cifrado**. Obsoleta el RFC 2402.
`[RFC 4303]`	*IP Encapsulating Security Payload* (**ESP**). Protocolo IP **50**: cifrado, integridad y autenticación. Obsoleta el RFC 2406. Es el protocolo que se usa en la práctica.
`[RFC 7296]`	*Internet Key Exchange Protocol Version 2* (**IKEv2**), octubre de 2014. **Internet Standard, STD 79**. Actualizado por los RFC 7427, 7670, 8247, 8983, 9370 y **9827** (noviembre de 2025). Puertos **UDP 500** y **UDP 4500**.
`[RFC 9395]`	*Deprecation of the Internet Key Exchange Version 1 (IKEv1) Protocol and Obsoleted Algorithms* (**abril de 2023**). Declara **obsoleto IKEv1** y actualiza los RFC 8221 y 8247.
`[RFC 3948]`	*UDP Encapsulation of IPsec ESP Packets* (enero de 2005). **Travesía de NAT**: encapsula ESP en **UDP 4500**.
`[RFC 8221]`	*Cryptographic Algorithm Implementation Requirements and Usage Guidance for ESP and AH*. Obsoleta el RFC 7321; actualizado por el RFC 9395.
`[RFC 8247]`	*Algorithm Implementation Requirements and Usage Guidance for IKEv2*. Obsoleta el RFC 4307; actualizado por el RFC 9395.
`[RFC 9846]`	*The Transport Layer Security (TLS) Protocol Version 1.3*, **julio de 2026**. **Obsoleta los RFC 5077, 5246, 6961, 7627, 8422 y 8446**: es la especificación vigente de TLS 1.3 y sustituye a la de 2018.

ID	Referencia
[RFC 8446]	*The Transport Layer Security (TLS) Protocol Version 1.3* (agosto de 2018). **Obsoletado por el RFC 9846**. Se conserva la referencia porque es la que recogen los temarios al uso.
[RFC 8996]	*Deprecating TLS 1.0 and TLS 1.1* (marzo de 2021). Prohíbe ambas versiones.
[RFC 7568]	*Deprecating Secure Sockets Layer Version 3.0* (junio de 2015).
[RFC 10015]	*Deprecating Obsolete Key Exchange Methods in TLS 1.2 and DTLS 1.2*, **julio de 2026**. Actualiza, entre otros, los RFC 5246 y 9325.
[RFC 9325]	*Recommendations for Secure Use of TLS and DTLS* (**BCP 195**), noviembre de 2022. Obsoleta el RFC 7525. Referencia de buenas prácticas de configuración.
[RFC 9147]	*The Datagram Transport Layer Security (DTLS) Protocol Version 1.3* (abril de 2022).
[RFC 4251]	*The Secure Shell (SSH) Protocol Architecture* (enero de 2006), junto con los **RFC 4252** (autenticación), **4253** (capa de transporte) y **4254** (capa de conexión y **reenvío de puertos**). Puerto **TCP 22**.
[RFC 9142]	*Key Exchange (KEX) Method Updates and Recommendations for Secure Shell (SSH)* (enero de 2022).
[RFC 2865]	*Remote Authentication Dial In User Service* (**RADIUS**), junio de 2000, y **RFC 2866** (contabilidad). Puertos **UDP 1812** y **1813**. Actualizados por los RFC 2868, 3575, 5080, 6929, 8044 y **9765**.
[RFC 9765]	*RADIUS/1.1: Leveraging Application-Layer Protocol Negotiation (ALPN) to Remove MD5*, **abril de 2025**. Estado **Experimental**. Actualiza los RFC 2865, 2866, 5176, 6613, 6614 y 7360.

ID	Referencia
[RFC 6614]	*TLS Encryption for RADIUS* (**RadSec**), mayo de 2012, estado Experimental; y **RFC 7360**, *DTLS as a Transport Layer for RADIUS*, también experimental.
[RFC 8907]	*The Terminal Access Controller Access-Control System Plus (TACACS+) Protocol*, septiembre de 2020, estado **Informational**. Puerto **TCP 49**.
[RFC 9887]	*TACACS+ over TLS 1.3*, **diciembre de 2025**. Estado **Proposed Standard**; actualiza el RFC 8907. Resuelve la debilidad histórica del cifrado propio de TACACS+.
[RFC 6733]	*Diameter Base Protocol* (octubre de 2012). Sucesor de RADIUS; obsoleta el RFC 3588.
[RFC 3748]	*Extensible Authentication Protocol* (**EAP**), junio de 2004. Obsoleta el RFC 2284.
[RFC 5216]	*The EAP-TLS Authentication Protocol* (marzo de 2008). Actualizado por los RFC 8996, **9190** y 9965.
[RFC 9190]	*EAP-TLS 1.3: Using the Extensible Authentication Protocol with TLS 1.3* (febrero de 2022).
[RFC 2637]	*Point-to-Point Tunneling Protocol* (**PPTP**), julio de 1999, estado Informational. **Criptográficamente roto**: no debe usarse.
[RFC 2661]	*Layer Two Tunneling Protocol* (**L2TP**), agosto de 1999, y **RFC 3931** (**L2TPv3**, marzo de 2005). **UDP 1701**. **No cifra**.
[RFC 2784]	*Generic Routing Encapsulation* (**GRE**), marzo de 2000. Protocolo IP **47**. **No cifra**.
[RFC 1918]	*Address Allocation for Private Internets* (**BCP 5**) y **RFC 3022** (NAT tradicional).

ID	Referencia
]	
[RFC 1928]	*SOCKS Protocol Version 5* (marzo de 1996). Proxy genérico de nivel de sesión; **no inspecciona contenido**.
[RFC 5424]	*The Syslog Protocol* (marzo de 2009) y **RFC 5425** (syslog sobre **TLS**, puerto **TCP 6514**).
[RFC 4120]	*The Kerberos Network Authentication Service (V5)* (julio de 2005).
[RFC 8784]	*Mixing Preshared Keys in IKEv2 for Post-quantum Security* (junio de 2020); **RFC 9370**, *Multiple Key Exchanges in IKEv2* (mayo de 2023); y **RFC 9867** (noviembre de 2025), que extiende la mezcla a los intercambios IKE_INTERMEDIATE y CREATE_CHILD_SA.
[RFC 10024]	*Post-Quantum Traditional (PQ/T) Hybrid Key Agreement Mechanisms for TLS 1.3*, **agosto de 2026**, Proposed Standard; y **RFC 9954**, *Hybrid Key Exchange in TLS 1.3* (julio de 2026, Informational).
[RFC 7348]	*Virtual eXtensible Local Area Network (VXLAN)* (agosto de 2014). Superposición de segmentos de nivel 2 sobre una red IP.
[RFC 9525]	*Service Identity in TLS* (noviembre de 2023). Obsoleta el RFC 6125. Validación del nombre del servidor en el certificado.
[RFC 6797]	*HTTP Strict Transport Security (HSTS)* (noviembre de 2012).

Normas ISO/IEC, IEEE y publicaciones del NIST

ID	Referencia
`[NIST-ZT]`	**NIST SP 800-207**, *Zero Trust Architecture*, **agosto de 2020**. Fuente de los **siete principios** de la confianza cero y de los componentes lógicos **PE**, **PA** —que forman el **PDP**— y **PEP**. Complementada por la **SP 800-207A** para entornos multinube nativos.
`[IEEE8021X]`	**IEEE 802.1X**, *Port-Based Network Access Control*. Suplicante, autenticador y servidor de autenticación; estado del puerto y **EAPOL**.
`[IEEE8021AE]`	**IEEE 802.1AE**, **MACsec**: confidencialidad e integridad **salto a salto** en la trama Ethernet.
`[IEEE8021Q]`	**IEEE 802.1Q**, etiquetado de **VLAN**. Mecanismo con el que se implementa `mp.com.4.r1`.
`[ISO27001]`	**UNE-EN ISO/IEC 27001** y **27002**, sistemas de gestión de la seguridad de la información y controles. Marco de gestión complementario al ENS.
`[MAGERIT]`	**MAGERIT v3** (2012), *Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información*, del entonces Ministerio de Hacienda y Administraciones Públicas, y su herramienta de apoyo **PILAR**, del CCN. Origen del vocabulario activo–amenaza–vulnerabilidad–riesgo–salvaguarda–riesgo residual.
`[WPA3]`	**Wi-Fi Alliance**, *WPA3 Specification*. **SAE** (autenticación simultánea de iguales) y cifrado individualizado en redes abiertas.

Tier 2 — Informes, hojas de ruta y documentación de estado

ID	Referencia
`[ENISA-ETL]`	**ENISA**, *Threat Landscape 2025* (octubre de 2025). Datos citados, verificados en la publicación oficial: **4.875 incidentes** analizados entre el **1 de julio de 2024 y el 30 de junio de 2025**; el **DDoS** supone el **77 %** de los incidentes notificados pero solo el **2 %** provocó interrupción real; el **ransomware** es la amenaza de mayor impacto en la UE; **phishing (60 %)** y **explotación de vulnerabilidades (21,3 %)** son los dos vectores de acceso inicial dominantes; y a principios de 2025 **más del 80 %** de la ingeniería social observada en el mundo se apoyaba en contenido generado o mejorado con **IA**.
`[PQC-EU]`	**Grupo de Cooperación NIS** y Comisión Europea, *Coordinated Implementation Roadmap for the Transition to Post-Quantum Cryptography*, **23 de junio de 2025**. Tres hitos: **31-12-2026** (hojas de ruta nacionales y primeros pasos), **31-12-2030** (casos de uso de **alto riesgo** transicionados) y **31-12-2035** (transición completa en la medida de lo posible).
`[MS-EOL]`	**Microsoft**, *Windows 10 support has ended on October 14, 2025* y *Extended Security Updates (ESU) program for Windows 10*. El soporte de Windows 10 finalizó el **14 de octubre de 2025**; el programa **ESU** proporciona únicamente actualizaciones **críticas e importantes**, sin correcciones funcionales ni soporte técnico, hasta el **12 de octubre de 2027**.
`[CCN-CERT]`	**CCN-CERT**, avisos, informes de código dañino e informes de amenazas y tendencias. Junto con **INCIBE-CERT**, es la fuente de vigilancia a la que remite `op.exp.4.1` («seguimiento continuo de los anuncios de defectos»).
`[OWASP]`	**OWASP Top 10:2025**. Citado únicamente como catálogo de referencia de los ataques que mitiga un **WAF**; el desarrollo seguro de aplicaciones web corresponde al **Tema 23**.
`[CPSTIC-WEB]`	Portal del **CPSTIC** del Centro Criptológico Nacional, con el listado vivo de productos cualificados por familia. Es la fuente que hay que consultar en el momento de redactar un pliego, porque el catálogo se actualiza periódicamente.

Tier 3 — Contexto municipal

ID	Referencia
`[IAM]`	**Informática del Ayuntamiento de Madrid (IAM)**, organismo autónomo responsable de los sistemas de información municipales. Marco organizativo de todos los ejemplos y casos prácticos de este tema.
`[MADRID-SEDE]`	**Sede electrónica del Ayuntamiento de Madrid** y portal `madrid.es`. Servicio publicado que sirve de referencia en §2.4.1 y en el Caso 1.
`[BOAM-10032]`	**BOAM núm. 10.032**, convocatoria y temario oficial de la categoría de **Técnico Auxiliar de Informática** del Ayuntamiento de Madrid. Fuente del enunciado oficial de este tema y de las referencias cruzadas a los Temas 23, 27, 28, 29, 30, 31, 32, 33, 34, 35 y 37.